

Campus Entry Authentication System

Phase 1 Report: User Studies, Requirements, Design and Prototype

CSE 347/652 | DES 306/525 Usable Security and Privacy
IIIT-Delhi · Monsoon 2026 · Instructor: Dr. Arun Balaji Buduru

Phase 1: User Studies to evolve Requirements, Design and Workflows
Submission: 4 October 2026

Team: [INSERT TEAM MEMBER NAMES AND ROLL NUMBERS]

Primary research status: instruments complete; fieldwork data not yet collected. All placeholders are marked [DATA REQUIRED]. No primary data has been fabricated.

Table of Contents

1. Executive Summary	4
2. Problem Statement	5
3. Motivation	6
4. Project Objectives	7
5. Scope	8
6. User Groups	9
7. Current System	10
8. Current Workflow	11
9. User Research Methodology	12
10. Primary Research	14
11. Primary Research Findings	15
12. Secondary Research	19
13. Technology Comparison: QR vs RFID vs NFC	23
14. Existing System Comparison	25
15. Research Gap	26
16. Personas	27
17. User Journeys	29
18. User Tasks	32
19. Functional Requirements	33
20. Security Requirements	35
21. Privacy Requirements	39
22. Usability Requirements	41
23. Non-Functional Requirements	42
24. Threat Model	43
25. Attack Scenarios	48
26. Credential Lifecycle	51
27. Security Architecture	54
28. System Architecture	56
29. Data Flow Diagram	57
30. Privacy Data Flow	58
31. Workflows	59
32. Failure Handling and Edge Cases	61
33. Design Principles	63
34. Design Decisions	64
35. Prototype	68
36. Heuristic Evaluation	74
37. Requirement Traceability	76
38. Security–Usability–Privacy Trade-offs	78

39. Limitations	79
40. Phase 2 Plan	80
41. Conclusion	82
42. References	83
Appendix A. Student Questionnaire	85
Appendix B. Security Guard Interview Protocol	87
Appendix C. Participant Information and Consent Statement	89
Appendix D. Contextual Inquiry (Observation) Protocol	90
Appendix E. Data Collection Template	92
Appendix F. Requirements Matrix	93
Appendix G. Threat Model	94
Appendix H. Risk Register	95
Appendix I. Prototype Screens	96
Appendix J. Workflow Diagrams	107

1. Executive Summary

This report documents Phase 1 of a course project for CSE 347/652 | DES 306/525 Usable Security and Privacy (IIIT-Delhi, Monsoon 2026). The project addresses authentication and authorization at the campus entry gate. Today, entry is controlled by a physical college ID card that a security guard inspects by eye. The card proves possession, not identity: a lost, stolen, borrowed, forged, expired, or revoked card is visually identical to a valid one, and a guard working a busy gate has seconds to decide.

Phase 1 follows the course structure: user studies → requirements → design → workflows → prototype. We designed a three-method primary research plan (a student questionnaire, semi-structured interviews with security staff, and a non-interfering contextual inquiry at the gate), completed a literature and existing-system review, built a threat model with twelve threat actors and seventeen threats, compared QR, RFID and NFC against sixteen criteria, wrote a formal requirements catalogue (18 functional, 20 security, 12 privacy, 14 usability, 12 non-functional requirements), designed the credential lifecycle, security and system architecture, data-flow and privacy data-flow diagrams, and produced a twenty-screen lo-fi prototype with an initial heuristic evaluation and a full traceability matrix.

Status of primary data. The primary research instruments, consent statement, data-collection template, and analysis framework are complete. Fieldwork results are not included in this version. Every place where primary evidence belongs is marked [DATA REQUIRED] or with a specific placeholder such as [INSERT ACTUAL NUMBER]. No participant counts, percentages, averages, quotes, or observations have been invented. Sections that rest on secondary research or on explicitly labelled design assumptions are marked as such.

Provisional technology direction. Based on the threat model and secondary research, the design direction is a hybrid credential: a cryptographically authenticated contactless credential (ISO/IEC 14443 NFC-class, either a smart card with challenge-response or a phone-based NFC credential) as the primary path, a short-lived signed QR code generated by a student mobile app as the secondary path, and time-bound signed QR passes for visitors. Static QR codes and low-frequency 125 kHz RFID were rejected as a sole primary mechanism because they are trivially copied. This direction is provisional until primary data on device ownership, acceptance, and gate conditions is collected.

Security depth. The design treats authentication ("who is this credential bound to?") and authorization ("is this principal allowed through this gate now?") as separate decisions with separate failure messages, applies fail-secure behaviour for network and database outages (a bounded, signed offline revocation list rather than an open gate), enforces least privilege and role-based visibility (the guard sees a photo, first name, role, and a decision, never a phone number or address), minimises stored personal data, and makes every access and administrative decision auditable in an append-only log. No custom cryptography is proposed; Phase 2 will use established primitives and libraries only.

2. Problem Statement

Access to the IIIT-Delhi campus is controlled at the gate by a security guard who visually checks a physical college identity card. The card carries a printed photo, name, roll number, programme, and validity date. In practice the guard decides in a few seconds, often while several people wait, whether the card looks genuine and whether the photo resembles the holder.

This process authenticates the card, not the person, and it conflates two different questions:

Question	Meaning	How the current system answers it
Authentication — "Who are you?"	Is this credential genuine and bound to this individual?	Guard compares printed photo to face; judges whether the card looks real
Authorization — "Are you allowed to enter here, now?"	Is this individual currently permitted at this gate?	Guard assumes any current-looking card implies permission

The failure modes that follow from this design are the problems this project addresses:

- Lost or stolen cards remain usable by whoever holds them until the card physically expires, because there is no revocation check at the gate.
- Borrowed cards: a student can hand a card to a friend or outsider; photo comparison under time pressure is unreliable.
- Forged or altered cards: a printed card with a laminate can be replicated with consumer equipment.
- Expired cards are frequently accepted because the date is small and rarely read.
- Revoked status (a suspended, withdrawn, or graduated student) is not visible on the card at all.
- Visitors are handled by a separate manual register that is slow, error-prone, and stores personal information on paper.
- Manual verification errors in both directions: legitimate students refused, unauthorised people admitted.
- Queues and delay at peak times (morning classes, hostel curfew), which increases pressure to wave people through.
- No reliable audit trail: there is no record of who entered when, which hampers incident response.
- Privacy: the card exposes roll number, programme and sometimes more to anyone who sees it, and visitor registers expose phone numbers and addresses to anyone standing near the desk.
- No defined behaviour for failures: if lighting is poor, the guard is new, or the gate is short-staffed, there is no fallback procedure other than personal judgement.

The problem, stated precisely: the campus lacks a mechanism that (a) authenticates the individual rather than the artefact, (b) checks current authorization at the point of entry, (c) does so in a few seconds under queue pressure, (d) fails securely when infrastructure fails, and (e) exposes only the minimum personal information needed to make the decision.

3. Motivation

Security motivation. Physical access control is the outer perimeter of every other security control on campus: laboratories, hostels, data centres, examination halls. A perimeter that accepts any plausible-looking card provides little assurance. Published research on deployed access credentials shows that "looks secure" and "is secure" diverge sharply: MIFARE Classic cards used in buildings and transit were shown to be cloneable in 2008 [4, 5], and hotel lock systems covering millions of doors were shown in 2018 and 2024 to be openable from a single discarded or read keycard [8, 9]. A campus system designed without a threat model will repeat these mistakes.

Usability motivation. The usable-security literature consistently finds that security mechanisms that add friction are circumvented by the very people they protect, and that the circumvention is rational, not careless [10, 11]. A gate that takes 15 seconds per person at 8:55 a.m. will be bypassed by the guard. Any design must therefore be as fast as, or faster than, the current glance-at-a-card.

Privacy motivation. An electronic gate necessarily creates a record of movement. Without deliberate data minimisation and retention limits, this becomes a surveillance dataset of every student's daily pattern. India's Digital Personal Data Protection Act, 2023 [22] establishes purpose limitation and data minimisation as legal obligations for data fiduciaries, and the campus would be one.

Course motivation. The project is a vehicle for demonstrating that security, privacy and usability can be designed in from the start rather than bolted on. The Phase 1 deliverables (user studies, requirements, prototype) exist precisely to show the evidence chain from user need to design decision before any code is written.

4. Project Objectives

Primary objective. Design a campus entry authentication system that provides strong authentication and authorization while protecting user privacy, resisting common attacks, handling failures securely, and remaining fast and easy to use for students and security staff.

Phase 1 objectives

ID	Objective	Measurable Phase 1 output
O1	Understand the current entry experience and its problems from the perspective of students, guards, and administration	Questionnaire, interview protocol, contextual inquiry protocol, analysis framework (Sections 9–11, Appendices A–E)
O2	Ground the design in published evidence on authentication technologies, attacks, usable security and privacy	Literature review, existing-system review, technology comparison (Sections 12–15)
O3	Separate authentication from authorization and carry the distinction through every artefact	Architecture, requirements, workflows, threat model, prototype all use the distinction explicitly
O4	Produce a formal, traceable requirements catalogue covering functional, security, privacy, usability and non-functional needs	Sections 19–23, Appendix F
O5	Model threats and attack scenarios with mitigations and residual risk	Sections 24–25, Appendices G–H
O6	Design the credential lifecycle, security and system architecture, and all failure-handling workflows without insecure bypasses	Sections 26–32, Appendix J
O7	Produce a lo-fi prototype derived from the requirements and evaluate it heuristically	Sections 35–36, Appendix I
O8	Demonstrate traceability from user finding to prototype screen to future test	Section 37, Appendix F

Qualities the design must demonstrate: strong security, usability, privacy, functional correctness, reliability, accessibility, and human-centred design, with the greatest depth in security.

5. Scope

In scope for Phase 1

- Entry authentication and authorization at campus perimeter gates (pedestrian and, conceptually, vehicle gates).
- Three principal roles: students, security guards (gate operators), and administrators (security office / ID cell).
- Visitor entry with pre-approval and time-bound credentials.
- Credential lifecycle from issuance to deletion.
- Failure handling: lost, forgotten, expired, revoked, forged and borrowed credentials; reader, network, database and power failure; emergency entry; suspicious repeated attempts.
- Threat model, requirements, architecture, workflows, lo-fi prototype, heuristic evaluation.

Explicitly out of scope for Phase 1

- Working software. Phase 1 delivers design artefacts only.
- Building-level or room-level access (labs, hostels), though the architecture should not preclude it.
- Payment, library, mess, or attendance functions of the ID card.
- Biometric enrolment or biometric matching by the system. Photo comparison remains a human task; we discuss biometrics only as a Phase 2 option that would need separate ethical review.
- Procurement decisions or vendor selection.
- Faculty and staff as a separately studied population (they are treated as a role variant of "authorised member" in the requirements, but were not a required study population).

Assumptions (labelled)

- A1: Gates are staffed during operating hours; the system assists guards rather than replacing them.
- A2: Mains power and campus network are normally available at gates but cannot be assumed to be always available.
- A3: Most, but not all, students carry a smartphone. The proportion is [DATA REQUIRED] from the questionnaire; the design must not exclude students without one.
- A4: The institution already maintains an authoritative student roster (admissions/registrar) that can act as the identity source.

6. User Groups

Group	Role in the system	What we need to learn	Study method
A. Students	Credential holders; the most frequent users; also the data subjects whose movement is logged	Current experience, forgotten/lost ID frequency, waiting time, security and privacy concerns, preferred authentication method, accessibility needs, trust	Questionnaire (Appendix A); optional short follow-up interviews
B. Security guards	Gate operators; make or confirm the access decision; handle every exception	Verification workflow, how suspicious/fake/lost IDs are handled, visitor process, busy-hour problems, what information they need and what they should not see, device and network problems, training	Semi-structured interviews (Appendix B); contextual inquiry (Appendix D)
C. Administration / security office / ID cell	Issue, replace and revoke credentials; approve visitors; define access policies; review logs and incidents	Issuance and revocation process, lost-ID handling, visitor management, restricted areas, log access, admin privileges	Interview (adapted from Appendix B) if access is granted; otherwise documented as [DATA REQUIRED]
D. Visitors (secondary)	Occasional users with no standing credential	Registration friction, what data they are asked for, how they are identified to guards	Persona synthesised from secondary research and guard interviews; direct study optional

Faculty, staff, contractors and delivery personnel are acknowledged as additional roles. They are treated as authorization-policy variants (different permitted gates/hours) rather than as separately studied populations in Phase 1.

7. Current System

Description (based on team observation of the publicly visible process and general knowledge of the campus; specifics to be confirmed by the contextual inquiry — [DATA REQUIRED]).

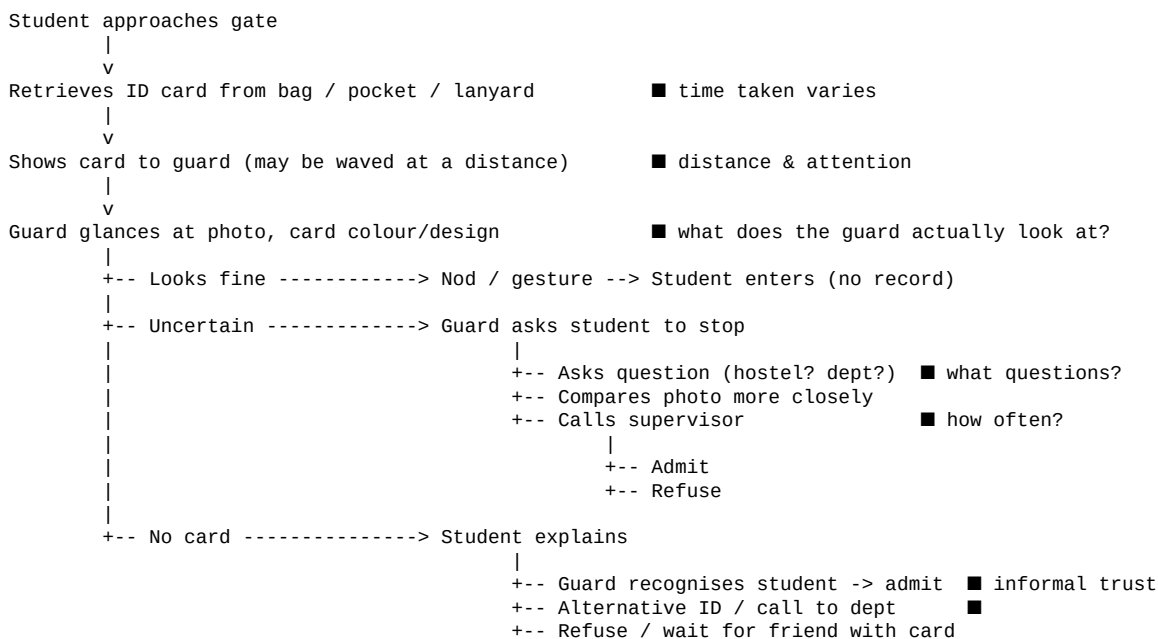
- **Credential:** a printed, laminated photo ID card issued at admission. It displays photo, name, roll number, programme, and a validity period. Some cards include a barcode or magnetic stripe used for library or other services; whether the gate uses any machine-readable feature is [DATA REQUIRED].
- **Verification:** a guard at the pedestrian gate visually inspects the card. At vehicle gates a sticker or the same card is shown through the window.
- **Decision:** the guard admits, questions, or refuses the person. There is no electronic record of the decision.
- **Exceptions:** a student without a card may be asked for another form of ID, asked to name a hostel or department, or refused. The actual procedure is [DATA REQUIRED].
- **Visitors:** sign a paper register (name, phone number, person visited, purpose, time in/out) and may deposit a government ID or receive a visitor badge. Details [DATA REQUIRED].
- **Revocation:** when a card is reported lost, a replacement is issued; there is no mechanism to prevent the lost card being used at the gate, since the gate performs no lookup.
- **Logging:** none for students; paper register for visitors.

Properties of the current system against the project's qualities

Quality	Current system
Authentication strength	Low: possession of a plausible-looking card; photo match under time pressure
Authorization check	None distinct from authentication; any current card implies permission
Revocation	Not enforced at gate
Expiry	Printed date; rarely read
Audit	None for students; paper for visitors
Speed	Fast when uncontested (a glance); slow when guard questions the holder. Actual timings [DATA REQUIRED]
Privacy	Card exposes roll number and programme to bystanders; visitor register exposes phone numbers to anyone near the desk
Failure handling	Undefined; depends on individual guard
Accessibility	Card is device-independent, which is a strength; but a student with a motor impairment may find retrieving a card from a bag difficult, and there is no non-visual feedback

8. Current Workflow

The current-state workflow, as the team understands it before fieldwork. Steps marked ☐ are where the contextual inquiry (Appendix D) must confirm or correct the description.



Visitor path (current)

Visitor arrives -> States purpose and host -> Paper register (name, phone, host, purpose, time)
 -> May deposit govt. ID / receive badge -> Guard may phone host -> Admit -> Manual sign-out (often skipped)

Known and suspected pain points in the current workflow (to be validated; each is a hypothesis until fieldwork data replaces it)

#	Hypothesised pain point	Affects	Status
H1	Retrieving the card from a bag causes delay and queue formation	Students, guards	[DATA REQUIRED] — timing from contextual inquiry
H2	Guards do not read the expiry date	Security	[DATA REQUIRED] — interview Q4, observation
H3	Guards rely on facial familiarity rather than the card, especially for regulars	Security	[DATA REQUIRED] — interview Q3, observation
H4	Forgotten ID is common and handled inconsistently	Students, guards	[DATA REQUIRED] — questionnaire Q6–Q8, interview Q6
H5	Lost cards are not blocked; replacement takes days	Students, security	[DATA REQUIRED] — questionnaire Q9, admin interview
H6	Visitor register is slow and exposes visitor phone numbers	Visitors, privacy	[DATA REQUIRED] — observation, interview Q7
H7	Peak-hour pressure leads guards to wave people through	Security	[DATA REQUIRED] — interview Q8, observation at peak
H8	No record exists to support incident investigation	Administration	[DATA REQUIRED] — admin interview
H9	Students are uneasy about how their data would be used by an electronic system	Privacy, trust	[DATA REQUIRED] — questionnaire Q13–Q15

9. User Research Methodology

9.1 Approach

The research follows a mixed-methods design-research approach as required by the course brief: quantitative data to size problems (how often, how long, how many) and qualitative data to understand why they occur and how people work around them. Three primary methods are triangulated with secondary research so that no single source drives a requirement.

Method	Population	Data type	Primary purpose
Online questionnaire (Appendix A)	Students	Quantitative (Likert, frequency, ranking) + short qualitative	Size the problem; measure attitudes to security, privacy, technology options, accessibility
Semi-structured interviews (Appendix B)	Security guards; security office/admin if accessible	Qualitative	Understand real verification workflow, exceptions, workarounds, information needs, constraints
Contextual inquiry / non-participant observation (Appendix D)	Gate environment	Quantitative timing + qualitative field notes	Ground truth for step counts, timing, queueing, environment, deviations from stated procedure
Secondary research (Section 12)	Literature, standards, existing systems	Evidence from publications	Threats, technology properties, usable-security and privacy principles

9.2 Research questions

RQ	Question	Answered by
RQ1	How does campus entry currently work in practice, and where does it deviate from the intended procedure?	Interviews, observation
RQ2	How frequently do students forget, lose, or have trouble with their ID, and what happens when they do?	Questionnaire, interviews
RQ3	How long does entry take, and when do queues form?	Observation, questionnaire
RQ4	What security weaknesses do guards and students perceive, and which have they witnessed?	Questionnaire, interviews
RQ5	What information do guards need to make a confident decision, and what information should not be shown to them?	Interviews, observation
RQ6	What are students' privacy concerns about an electronic entry system, and what would make them trust it?	Questionnaire
RQ7	Which authentication methods (card tap, phone tap, phone QR, other) do students prefer and why? What proportion has a compatible phone?	Questionnaire
RQ8	What accessibility needs exist at the gate?	Questionnaire, observation
RQ9	How are visitors handled, and what data is collected about them?	Interviews, observation
RQ10	What happens when the guard, the device, or the network is unavailable?	Interviews, observation

9.3 Sampling plan

- Students: convenience sample recruited through class groups, hostel groups and notice boards. Target: at least 40 responses across programmes and years; minimum viable: 25. Actual: [INSERT NUMBER OF PARTICIPANTS].
- Security guards: purposive sample. Target: 3–6 guards across shifts (morning peak, afternoon, night) and gates. Actual: [INSERT NUMBER OF PARTICIPANTS]. Permission from the security supervisor must be obtained before approaching guards on duty; interviews should be scheduled off-shift or during quiet periods.
- Administration / security office: 1–2 interviews if access is granted. Actual: [INSERT NUMBER / "not accessible"].
- Observation: at least 3 sessions of 30–45 minutes each, covering one morning peak, one off-peak, and one evening/hostel-return period, ideally at two different gates. Actual: [INSERT SESSIONS CONDUCTED].

9.4 Ethics

- Participation is voluntary and anonymous; no names, roll numbers, phone numbers or e-mail addresses are collected in the questionnaire.
- Interviews are recorded only in written notes unless the participant explicitly consents to audio; audio, if any, is deleted after transcription.
- Observation is non-participant and non-interfering: observers do not speak to people in the queue, do not record faces, names, or card details, and stop if asked by security staff.

- Guards are a vulnerable population in the employment sense (contract staff, may fear criticism). The consent statement makes clear that findings are reported in aggregate, that no individual guard's performance is assessed, and that participation cannot affect their employment.
- The consent statement (Appendix C) is read aloud before interviews and shown as the first page of the questionnaire.
- Data is stored on a password-protected team drive accessible only to team members and deleted at the end of the course.

9.5 Data collection procedure

Step	Activity	Output	Responsible
1	Obtain permission from security supervisor / relevant office for interviews and observation	Written or e-mail permission	Team lead
2	Pilot questionnaire with 3–5 students; fix ambiguous wording	Revised form	Team
3	Distribute questionnaire (Google Forms); leave open 7 days	Response CSV	Team
4	Conduct observation sessions using Appendix D checklist	Field notes + timing sheets in Data_Collection_Template.xlsx	Two observers per session
5	Conduct guard interviews using Appendix B protocol	Notes template per interview	Interviewer + note-taker
6	Conduct admin interview if available	Notes	Team lead
7	Transcribe / clean; enter into Data_Collection_Template.xlsx	Cleaned dataset	Team
8	Quantitative analysis: frequencies, Likert medians and distributions, ranking scores	Tables and charts	Team
9	Qualitative analysis: open coding of interview and open-text responses; affinity clustering into themes	Affinity map, theme table	Whole team, 1 session
10	Map findings to user needs and requirements; update traceability matrix	Updated Section 37 and Appendix F	Team

9.6 Analysis framework

Quantitative

- Frequency distributions for every categorical item (bar charts).
- For Likert items (5-point): report median, mode, and full distribution; do not report means as the sole summary. Group "agree" and "strongly agree" only when the full distribution is also shown.
- For ranking items: Borda-count style scores (rank 1 = n points) plus first-choice frequency.
- Cross-tabulations of interest: authentication-method preference vs. smartphone ownership; privacy concern vs. trust; year of study vs. forgotten-ID frequency.
- Observation: mean, median and range of per-person processing time, split by "uncontested" vs "questioned"; queue length at fixed intervals.

Qualitative

- Open coding of all interview notes and open-text questionnaire answers by two team members independently; codes reconciled.
- Affinity diagramming: codes clustered into themes; each theme labelled with a user-voice statement.
- Themes classified into: pain point, security concern, privacy concern, usability concern, accessibility concern, design opportunity.
- Each theme linked to at least one requirement or explicitly marked as out of scope.

Evidence labelling convention used in this report

Label	Meaning
[PRIMARY]	Finding from our own questionnaire, interviews or observation. Must cite the question/session.
[SECONDARY]	Finding from a cited published source.
[ASSUMPTION]	Team judgement not yet backed by evidence; must be validated.
[DATA REQUIRED]	Slot for primary evidence not yet collected.

10. Primary Research

10.1 Student Questionnaire

Full instrument with question types, options, required flags and purposes is in Appendix A. Summary: 20 questions in six sections (Background; Current Entry Experience; Problems and Failures; Security Perceptions; Privacy and Trust; Preferences, Accessibility and Features). Estimated completion time 6–8 minutes. Designed for Google Forms. No personally identifying information collected.

10.2 Security Guard Interviews

Full protocol with introduction, consent statement, 14 core questions, follow-up probes and notes template is in Appendix B. Semi-structured, 20–30 minutes, conducted off-shift or during a quiet period with supervisor permission. The same protocol, with the administrative block (Q13–Q14) expanded, is used for the security office / ID cell interview if access is obtained.

10.3 Contextual Inquiry

Full protocol with observation checklist, timing method, what-to-record / what-not-to-record lists and ethical constraints is in Appendix D. Non-participant observation from a position agreed with security staff. Two observers per session: one timing, one taking field notes.

10.4 Participant Information

All participant information is reported in aggregate only.

Population	Target	Actual	Notes
Students (questionnaire)	≥40	[INSERT NUMBER OF PARTICIPANTS]	Programme and year distribution: [INSERT DISTRIBUTION]
Security guards (interview)	3–6	[INSERT NUMBER OF PARTICIPANTS]	Shifts and gates covered: [INSERT]
Administration (interview)	1–2	[INSERT NUMBER / "not accessible"]	Office: [INSERT]
Observation sessions	≥3	[INSERT NUMBER]	Dates, times, gates: [INSERT]

10.5 Data Collection Procedure

As described in Section 9.5. Actual dates: questionnaire open [INSERT DATES]; interviews conducted [INSERT DATES]; observation sessions [INSERT DATES]. Deviations from plan: [INSERT or "none"].

11. Primary Research Findings

Status: [DATA REQUIRED]. This section is a structured template. No primary data has been collected at the time of writing. Every value below is a placeholder. Nothing in this section may be cited as a finding until the placeholders are replaced with actual results from Appendix E (Data_Collection_Template.xlsx). The team must also delete any placeholder row for which no data exists rather than estimate.

11.1 Quantitative Findings

11.1.1 Participant profile

- Total valid responses: [INSERT ACTUAL NUMBER]
- Programme: UG [n] / PG [n] / PhD [n]
- Year of study distribution: [INSERT DISTRIBUTION]
- Hosteller / day scholar: [n] / [n]
- Smartphone ownership (Q17): [INSERT ACTUAL PERCENTAGE] own a smartphone; [INSERT ACTUAL PERCENTAGE] report NFC capability; [INSERT ACTUAL PERCENTAGE] don't know

11.1.2 Frequency distributions

Item	Question	Result
Entries per day	Q3	[INSERT DISTRIBUTION]
How ID is carried	Q4	[INSERT DISTRIBUTION]
Guard actually looks at card	Q5	[INSERT DISTRIBUTION]
Forgotten ID in last month	Q6	[INSERT ACTUAL PERCENTAGE] at least once
What happened when ID forgotten	Q7	[INSERT DISTRIBUTION]
Ever lost ID	Q9	[INSERT ACTUAL PERCENTAGE]
Days to replacement	Q10	median [INSERT ACTUAL VALUE]
Typical wait at peak	Q11	[INSERT DISTRIBUTION]
Witnessed someone enter with another's ID / no check	Q12	[INSERT ACTUAL PERCENTAGE]
Preferred method (first choice)	Q16	[INSERT DISTRIBUTION]

11.1.3 Likert-scale summaries

Report median, mode and full 5-point distribution for each.

Statement	Q	SD	D	N	A	SA	Median
"The current ID check reliably stops unauthorised people"	Q13a	[n]	[n]	[n]	[n]	[n]	[x]
"I am concerned that a lost card could be used by someone else"	Q13b	[n]	[n]	[n]	[n]	[n]	[x]
"I would be comfortable with the college recording the time I enter campus"	Q14a	[n]	[n]	[n]	[n]	[n]	[x]
"I would want to see my own entry records"	Q14b	[n]	[n]	[n]	[n]	[n]	[x]
"I would trust an electronic system more than a visual check"	Q15a	[n]	[n]	[n]	[n]	[n]	[x]
"I am worried that entry data could be used for purposes other than security"	Q15b	[n]	[n]	[n]	[n]	[n]	[x]
"Retrieving my ID card at the gate is inconvenient"	Q11b	[n]	[n]	[n]	[n]	[n]	[x]

11.1.4 Ranking results (Q16: preferred authentication method)

Option	Rank-1 count	Borda score
Tap physical smart card	[n]	[x]
Tap phone (NFC)	[n]	[x]
Show QR code on phone	[n]	[x]
Keep current visual check	[n]	[x]
Other (specify)	[n]	[x]

11.1.5 Observation timings (Appendix D)

Measure	Peak session	Off-peak session	Evening session
People observed	[n]	[n]	[n]
Median time from reaching guard to passing (uncontested)	[x s]	[x s]	[x s]
Median time when questioned	[x s]	[x s]	[x s]
Proportion questioned	[x %]	[x %]	[x %]
Proportion waved through without visible card	[x %]	[x %]	[x %]
Max queue length observed	[n]	[n]	[n]
Visitor register entries observed and median time	[n], [x s]	[n], [x s]	[n], [x s]

11.2 Qualitative Findings

Interview and open-text responses coded and clustered. Each theme must be supported by at least one real, anonymised quote with participant code (e.g., G2 = guard 2; S14 = student response 14).

Theme code	Theme (user-voice label)	Sources	Representative quote
T1	[INSERT THEME]	[G1, G3, S7...]	"[INSERT REAL PARTICIPANT QUOTE]"
T2	[INSERT THEME]		"[INSERT REAL PARTICIPANT QUOTE]"
T3	[INSERT THEME]		"[INSERT REAL PARTICIPANT QUOTE]"
...			

11.3 Affinity Themes

Photograph or export of the affinity map: [INSERT IMAGE / "see Appendix E"]. Top-level clusters and the number of codes in each: [INSERT].

11.4 Pain Points

Each hypothesis from Section 8 is confirmed, refuted, or modified here.

Hypothesis	Verdict	Evidence
H1 Card retrieval delays queue	[CONFIRMED / REFUTED / MODIFIED]	[INSERT OBSERVED FINDING, e.g., median retrieval time; Q11]
H2 Expiry date not read	[...]	[INSERT]
H3 Facial familiarity replaces card check	[...]	[INSERT]
H4 Forgotten ID common, inconsistent handling	[...]	[INSERT]
H5 Lost cards not blocked; slow replacement	[...]	[INSERT]
H6 Visitor register slow and leaks phone numbers	[...]	[INSERT]
H7 Peak pressure leads to waving through	[...]	[INSERT]
H8 No record for incident investigation	[...]	[INSERT]
H9 Students uneasy about data use	[...]	[INSERT]
New pain points not hypothesised		[INSERT]

11.5 Security Concerns

Concerns raised by participants (not by the team). [DATA REQUIRED]

Concern	Raised by	Frequency / strength	Links to requirement
[INSERT]	Students / Guards / Admin	[INSERT]	SEC-xx

11.6 Privacy Concerns

[DATA REQUIRED]

Concern	Raised by	Frequency / strength	Links to requirement
[INSERT]			PRIV-xx

11.7 Usability Concerns

[DATA REQUIRED]

Concern	Raised by	Frequency / strength	Links to requirement
[INSERT]			USE-xx

11.8 Accessibility Concerns

[DATA REQUIRED] (Q18, observation)

Need	Raised by	Links to requirement
[INSERT]		USE-xx / NFR-xx

11.9 Design Opportunities

Derived from confirmed pain points and themes. [DATA REQUIRED]

Opportunity	Supporting finding	Addressed in
[INSERT]	T-x / H-x	Section / Screen

11.10 How findings will be used

Once fieldwork data replaces the placeholders above, the team will (1) update the "User evidence" column of every requirement in Sections 19–23, (2) update the Design Decision Matrix (Section 34), (3) revise the personas (Section 16) to reflect actual distributions, and (4) re-run the traceability check in Section 37 so that every requirement cites either a primary finding, a secondary source, or a labelled assumption. Until then, all requirements are grounded in secondary research and labelled assumptions.

12. Secondary Research

All statements in this section are [SECONDARY] and cite the numbered references in Section 42. Where the team draws an inference from a source rather than repeating it, the inference is marked "(inference)".

12.1 Authentication and Authorization

Definitions. NIST SP 800-63-4 [1] defines authentication as the process of verifying that a claimant controls an authenticator bound to a subscriber's identity, and treats authorization (what the authenticated subscriber may do) as a separate function performed by the relying party after authentication. The same separation appears in classic protection-system design: Saltzer and Schroeder [14] describe authentication as establishing the principal and access control as deciding, per request, whether that principal may perform an action.

Authenticator types and assurance. SP 800-63B-4 [1] classifies authenticators by factor (something you know, have, are) and by whether they are single-factor or multi-factor, and defines Authentication Assurance Levels. Relevant to this project: a possession-based authenticator (a card or phone credential) provides single-factor authentication unless it is protected by a second factor (a PIN or biometric unlocking the phone). A "hardware cryptographic authenticator" that performs challenge–response is rated more highly than an authenticator that merely emits a static secret, because a static secret can be captured and replayed [1].

Facility access specifically. NIST SP 800-116 Rev 1 [2] applies these ideas to physical access control for the US federal PIV card. Its key contributions for our design: (a) it distinguishes reading a card identifier (weak, cloneable) from cryptographic challenge–response with the card (strong); (b) it recommends the authentication mechanism be chosen per area according to risk, with higher-risk areas requiring stronger mechanisms; and (c) it insists the physical access control system check the credential's current revocation status, not just its expiry date. Implication (inference): a campus perimeter is a moderate-risk area where a cryptographic possession factor plus a human photo check is proportionate; interior high-risk areas would need more.

Comparative evaluation of schemes. Bonneau et al. [33] evaluate authentication schemes on 25 usability, deployability and security properties and show that no scheme dominates; every choice trades some property for another. We adopt the same posture in Section 13: the technology comparison reports trade-offs, not a winner.

12.2 QR-code authentication

QR codes are a two-dimensional optical symbology standardised in ISO/IEC 18004 [25]. They encode data; they do not perform computation. Security therefore depends entirely on the data encoded and how the reader validates it.

Krombholz et al. [21] survey QR-code attacks and note that (a) a QR code is trivially copied by photographing it, (b) users cannot read the content and therefore cannot detect substitution, and (c) attackers can overlay malicious codes on legitimate ones. For an access credential this means a static QR code (one that never changes) is equivalent to a printed password: anyone who photographs it can replay it indefinitely.

The standard mitigation (inference from [1], [37], [40]) is to make the code dynamic and signed: the phone generates a fresh code every 30–60 seconds containing a credential identifier, a timestamp or counter, and a digital signature or MAC computed with a key held in the phone's secure storage. The reader verifies the signature, checks the timestamp window, and rejects any code it has already seen. This converts QR from "static secret" to "short-lived signed assertion", which resists replay after the window closes but still cannot resist a real-time relay (an attacker who screenshots and forwards the code within the window). RFC 6238 TOTP [37] is the standard model for time-based codes; RFC 7519 JWT [40] and RFC 8032 EdDSA [38] provide standard formats and signature schemes.

Usability properties (inference from [21], [12]): QR requires the user to unlock a phone, open an app, and orient the screen to a camera; this is slower and more failure-prone (glare, cracked screens, dead battery) than a tap, but it requires no special phone hardware and works on any smartphone with a screen.

12.3 RFID authentication

"RFID" covers several incompatible technologies. The distinction matters more than the label.

Low-frequency (125 kHz) proximity cards (e.g., HID Prox, EM4100 family) transmit a fixed identifier when powered by the reader field. They have no cryptography. Cloning requires only a low-cost reader/writer; the identifier is the credential. Anderson [31] and Verdult [32] treat this class as providing identification, not authentication.

High-frequency (13.56 MHz, ISO/IEC 14443) cards [23] range from memory cards to smart cards. The most-deployed memory card, MIFARE Classic, uses the proprietary CRYPTO1 cipher, which was reverse-engineered and broken in 2008 by two independent groups [4, 5]; keys can be recovered and cards cloned in seconds with commodity hardware. HID's iCLASS legacy product was similarly broken in 2012 [6]. Even a card with a sound cipher can leak keys through side channels if the hardware is not protected: Oswald and Paar recovered the 3DES key from MIFARE DESFire MF3ICD40 by power analysis [7]. Modern products (MIFARE DESFire EV2/EV3, MIFARE Plus EV2) implement AES-128 mutual authentication with standard primitives and are certified under Common Criteria [41]; we cite the data sheets only for the primitives used, not as proof of security.

Lessons for design (inference): the card must perform a cryptographic challenge–response with a per-card key; the reader must never accept a bare UID; and the design must assume some deployed cards will eventually be broken, so revocation and key rotation must be operationally cheap (Section 26).

Relay attacks. Any contactless protocol that does not measure distance is vulnerable to relay: the attacker holds one device near the victim's card and another near the reader and forwards messages. Hancke and Kuhn [18] proposed distance-bounding protocols as a countermeasure; Francillon et al. [19] demonstrated practical relays against car keyless-entry systems; Francis et al. [20] demonstrated relays using two NFC phones. Commercial access-control cards do not implement distance bounding. The practical mitigation in a staffed gate is the human: the guard sees whether the person tapped a card. Relay is therefore a residual risk, addressed by the photo check and by anomaly detection rather than by cryptography (Section 24).

12.4 NFC authentication

NFC (ISO/IEC 18092 [24]) is a superset of ISO/IEC 14443 [23] that lets a phone act as a reader, as a card (card emulation), or peer-to-peer. For access control the relevant mode is card emulation: the phone presents a credential to a reader exactly as a smart card would.

The security advantage of a phone over a card (inference from [1]) is that the phone can require a second factor before releasing the credential: the phone must be unlocked (PIN or biometric), so a stolen phone is not a usable credential until the thief also has the unlock secret. Keys can be stored in hardware-backed storage (Secure Element or Trusted Execution Environment). The disadvantages are dependence on battery, OS, and platform policy; not all phones expose card emulation to third-party apps; and a subset of students will not have a compatible phone (A3, [DATA REQUIRED]).

Existing deployments: Apple states that since 2018 students at several US universities can hold their student ID in Apple Wallet and use it for building access, with campus card systems provided by partners [35]. We cite this only as evidence that phone-based NFC campus credentials are a deployed pattern; Apple's press releases make no verifiable security claims and we make none on their behalf.

NFC shares the relay-attack exposure of any contactless protocol [20].

12.5 Existing campus systems

Reliable public documentation of specific Indian university gate systems is sparse; we do not claim any Indian institution uses any particular technology. What can be said from published sources:

- Card-based campus systems in North America and Europe typically combine a photo ID with a 13.56 MHz contactless chip used for doors, libraries, meals and printing; the same card serves many purposes (inference from the multi-application design of ISO/IEC 14443 products [41] and the Apple/Blackboard announcements [35]).
- Mobile credentials via Apple Wallet and Google Wallet are offered at named US universities [35].
- The hotel-lock breaches below are the best-documented evidence of what goes wrong in large contactless-credential deployments and are directly transferable to campus cards using the same chip families.

12.6 Hotel and physical access-control systems

Three widely reported cases:

Case	Year	Technology	Root cause	Lesson
Onity HT locks [36]	2012	Battery-powered lock with DC port	Programming port exposed the lock's memory and key without authentication; a hand-built device opened the lock	Physical ports and debug interfaces on readers are attack surfaces; readers must be treated as potentially compromised (SEC-18)
Vision by VingCard (Assa Abloy) [8]	2018	RFID (MIFARE Classic-based) keycards	Predictable key-derivation let researchers compute a property-wide master key from any single discarded card, even an expired one	Expired credentials still leak secrets; the credential system must not derive site keys from data readable on cards; retirement must include key rotation (Section 26)
Unsaflok, dormakaba Saflok [9]	2024	MIFARE Classic keycards, System 6000	Weak key derivation and card encryption; one read card allowed forging a pair of cards that open any door on the property	The same MIFARE Classic weakness known since 2008 [4, 5] remained in millions of doors 16 years later; migration is slow, so revocation and monitoring must compensate

Common to all three: the systems authenticated the card (does it hold the right bytes?) rather than authenticating the holder, and none had a revocation check that could stop a forged card. This is the failure pattern our authentication/authorization separation is meant to prevent.

12.7 Usable security and human factors

- Users are not the enemy. Adams and Sasse [10] showed that users bypass security mechanisms when those mechanisms conflict with their tasks and when they do not understand the rationale; blaming users is unproductive. For our gate this predicts that guards will wave people through when the check is slow, and students will share credentials when replacement is slow.
- Rational rejection. Herley [11] argues that users reject security advice when its cost to them exceeds the benefit they receive; the cost of security is borne by many users constantly while the benefit accrues to the institution rarely. Design consequence: the authenticated path must cost the student less effort than today, not more.
- Compliance budget. Beaument, Sasse and Wonham [17] show that people have a finite budget of effort for security compliance; spending it on low-value checks leaves none for high-value ones. Design consequence: add friction (a second factor, a manual check) only when risk indicators justify it.
- Why Johnny can't encrypt. Whitten and Tygar [12] demonstrated that security software fails when its interface does not match users' mental models and when errors are silent or cryptic. Design consequence: the guard's screen must show the decision and the reason, in plain language, not a status code.
- Secure interaction design. Yee [13] proposes principles including path of least resistance (the easiest path should be the secure one), visibility (the user should see the security-relevant state), revocability, expected ability, and clarity. These are adopted as design principles in Section 33.
- Human in the loop. Cranor [16] models the human as a component that receives a communication, attends to it, comprehends it, and acts; failures occur at each stage. For the gate, the guard is the human in the loop; the screen is the communication; comprehension must be near-instant.
- Heuristic evaluation. Nielsen's ten heuristics [15] remain the standard checklist for expert evaluation of interfaces and are used in Section 36 alongside the usable-security principles above.
- Historical overview. Garfinkel and Lipford [34] and Sasse et al. [42] synthesise these themes and argue that security and usability are complementary when designed together, not opposing goals to be traded.

12.8 Privacy and data minimisation

- Legal frame. India's Digital Personal Data Protection Act, 2023 [22] requires that personal data be processed only for a lawful purpose, with consent or under specified legitimate uses; obliges data fiduciaries to implement reasonable safeguards, to erase personal data when the purpose is served, and to give data principals the right to access a summary of their personal data being processed. An institution operating an entry-log system would be a data fiduciary; students and visitors would be data principals.
- Privacy framework. ISO/IEC 29100 [26] enumerates privacy principles including consent and choice, purpose legitimacy and specification, collection limitation, data minimisation, use/retention/disclosure limitation, accuracy, openness/transparency, individual participation and access, and accountability.
- Privacy by Design. Cavoukian [27] frames privacy as proactive, default, embedded in design, full-functionality (positive-sum), end-to-end secure, visible/transparent, and user-centric. The "positive-sum" claim is directly relevant: the guard's screen can show less personal data and still support a better decision than today's card.

- Design consequences (inference): the gate decision needs a photo, a display name, a role and a decision; it does not need roll number, phone, address or hostel. Logs need a pseudonymous credential identifier, gate, time and decision; re-identification should require a separate, audited administrative action. Retention should be fixed and short.

12.9 Security threats and engineering principles

- Design principles. Saltzer and Schroeder's principles [14] (economy of mechanism, fail-safe defaults, complete mediation, open design, separation of privilege, least privilege, least common mechanism, psychological acceptability) are adopted as security design principles in Section 33. "Open design" is the source of requirement SEC-20 (no security through obscurity). "Complete mediation" is the source of checking revocation on every access, not just at issuance.
- Threat modelling method. Shostack [30] describes STRIDE (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) applied per data-flow-diagram element and per trust boundary. Section 24 applies STRIDE to the DFD in Section 29.
- Application-layer controls. OWASP ASVS [29] provides verifiable requirements for authentication, session management, access control, cryptography-at-rest, and logging that Phase 2 will use as an implementation checklist; the OWASP Logging Cheat Sheet [29] specifies what must and must not be logged (never secrets, tokens or full credentials).
- Key management. NIST SP 800-57 [3] covers key generation, storage, rotation, and destruction; applied to per-card keys, signing keys, and the offline revocation-list signing key in Section 27.
- Transport security. TLS 1.3 [39] with mutual authentication (client certificates on readers) is the standard for reader-to-server communication.

13. Technology Comparison: QR vs RFID vs NFC

All entries are [SECONDARY] or (inference). "RFID" is split into the two classes that matter, because lumping them together produces misleading conclusions. Ratings: ● strong / favourable, ◐ moderate / conditional, ○ weak / unfavourable.

Criterion	Static QR (printed or fixed image)	Dynamic signed QR (app-generated)	LF RFID 125 kHz (fixed UID)	HF RFID / smart card, ISO 14443 with AES challenge–response	NFC phone credential (card emulation)
Authentication strength	○ Static secret; equivalent to a printed password [21]	● Signed, time-bound assertion; single-factor unless app requires unlock [37, 40]	○ Identification only; UID is the credential [31, 32]	● Cryptographic possession proof with per-card key [2, 41]	● Cryptographic possession proof; phone unlock adds second factor [1]
Credential cloning	○ Photograph it	● Key is in phone; clone requires extracting key from device	○ Seconds with cheap writer [32]	● Depends on chip: Classic/iCLASS broken [4–6]; DESFire EV3/Plus EV2 no public break [41]; side channels possible [7]	● Hardware-backed keys resist extraction; malware on rooted device is a risk
Replay risk	○ Indefinite replay	● Replay limited to validity window (30–60 s); real-time relay still possible	○ Indefinite replay	● Challenge–response defeats replay; relay possible [18–20]	● Same as smart card; relay possible [20]
Physical security of credential	○ Visible to bystanders on card/screen	● On screen briefly; shoulder-surf within window	○ Card readable at distance up to ~10 cm, sometimes more with large antennas	● Card readable at ~4–10 cm; skimming yields nothing useful without key	● Credential inactive until phone unlocked
Cost (per credential)	● Near zero (print)	● Near zero if student owns phone	● Low	● Moderate (secure smart card blank + personalisation)	● Near zero if phone owned; ○ excludes students without compatible phone
Cost (reader)	● Camera on tablet/phone	● Camera	● Low	● Moderate; SAM or secure key storage in reader raises cost	● Same reader as smart card
Speed at gate	● Unlock, open app, aim; glare-sensitive	● Same as static	● Tap, <1 s	● Tap, <1 s including crypto	● Tap; may need unlock first (~1–3 s)
Usability	● Familiar; requires two hands and attention	● Familiar; requires attention	● No attention required	● No attention required; card must be retrieved (H1)	● Phone usually already in hand; ○ battery dependence
Accessibility	○ Requires vision to aim; fine motor control	○ Same	● Works through wallet/bag; no vision needed	● Same; tactile/audio reader feedback possible	● Phone accessibility features apply; still requires holding device
Privacy	○ Static code is a persistent identifier readable by anyone	● Content rotates; identifier can be pseudonymous	○ Fixed UID is trackable by any reader in range	● Random UID mode available on modern chips [41]; protocol can avoid leaking identity before authentication	● Platform-dependent UID randomisation; app can enforce pseudonymity
Offline capability	● Reader can verify locally if it has a list	● Signature verification is fully offline; revocation list needed	● Local list	● Local key + signed revocation list	● Same
Reliability	● Camera, lighting, screen condition	● Same plus app and battery	● Very reliable	● Very reliable	● Phone OS updates, battery, app state
Scalability	●	●	●	●	●
Ease of implementation (Phase 2)	● Trivial	● Standard libraries (Ed25519, TOTP)	● Trivial	● Needs card SDK, key personalisation, SAM handling	○ Platform card-emulation constraints; Android HCE feasible, iOS restricted
Security limitations	Copy = compromise	Relay; phone malware; time sync	Copy = compromise	Relay; chip-family break; key management	Relay; device compromise; platform lock-in
User acceptance	[DATA REQUIRED] Q16	[DATA REQUIRED] Q16	[DATA REQUIRED] Q16	[DATA REQUIRED] Q16	[DATA REQUIRED] Q16, Q17

13.1 Analysis

Two of the five options fail the security requirements outright and are excluded as a sole credential: static QR and LF 125 kHz RFID both expose a static secret that is the credential, so a single capture equals permanent compromise. This is not a matter of degree; it is the same failure that the hotel-lock cases [8, 9] and MIFARE Classic [4, 5] exhibit.

The remaining three are all viable and have complementary weaknesses:

- AES smart card: strongest against cloning and replay, most reliable, most accessible, fastest, and works for every student regardless of phone. Weaknesses: card must be carried and retrieved (the very friction H1 hypothesises), it is single-factor, and a lost card is a usable credential until revoked.

- NFC phone credential: adds a second factor (phone unlock), students already carry phones, and lost-device risk is lower. Weaknesses: excludes students without a compatible phone (A3), depends on battery and OS, and iOS card emulation is not generally available to third-party apps, which constrains Phase 2.
- Dynamic signed QR: works on any smartphone including those without NFC, is cheap to implement, and is fully verifiable offline. Weaknesses: slower and more error-prone at the gate, replayable within its window, and least accessible.

13.2 Provisional direction

Hybrid, with the smart card as the universal baseline.

1. Primary credential: an ISO/IEC 14443 smart card with AES challenge–response (DESFire EV3 / Plus EV2 class [41]) issued to every student. This guarantees universality (no phone required), speed and accessibility, and meets SEC-01/04/14 by design.
2. Optional phone credential: students who opt in may enrol a phone credential that is either NFC card emulation (where the platform allows) or a dynamic signed QR generated by the app. Both are bound to the same identity and subject to the same authorization and revocation. The phone path exists to reduce H1 friction and to give a fallback when the card is forgotten (Section 32: forgotten-ID workflow uses the phone credential, not a bypass).
3. Visitor credential: a time-bound, single-purpose signed QR code issued on host approval, displayed on the visitor's phone or printed at the gate. Visitors do not receive smart cards.
4. Human check retained: on every authenticated tap the guard's screen shows the photo on file for the authenticated credential; the guard confirms the face. This is the mitigation for relay and for borrowed credentials, which cryptography cannot address (Section 24).

Why not phone-only? Because A3 is unverified and because excluding students without a compatible phone violates the accessibility objective. Why not card-only? Because it does not address the forgotten-card case without an insecure bypass, and because it is single-factor. Why not QR as primary? Because it is the slowest and least accessible at the gate and is replayable within its window.

This direction is provisional. It will be revisited when Q16 (preference), Q17 (phone capability), Q18 (accessibility) and observation timings are available. The decision is recorded as D1 in Section 34 with the evidence column marked **[DATA REQUIRED]**.

14. Existing System Comparison

For each system class, the questions required by the project brief are answered from cited sources. Where a property is not publicly documented, the cell says "not documented" rather than guessing.

Property	Printed photo ID (current campus)	MIFARE Classic campus/transit card [4, 5]	Hotel keycard (VingCard Vision / Saflok) [8, 9]	US university mobile ID in Apple Wallet [35]	PIV card in federal facility access [2]
Technology	Print + laminate	13.56 MHz, CRYPTO1	13.56 MHz MIFARE Classic	NFC card emulation, Secure Element	ISO 14443 smart card, PKI certificates
What is authenticated	Card appearance vs guard's expectation; face vs printed photo	Card sector keys (broken)	Card data / derived key (broken)	Device-held credential; phone unlock	Card private key via challenge-response; optional PIN, biometric
What is authorized	Implicit: any current-looking card	Whatever the reader is configured for; typically UID/sector data mapped to permissions	Room + validity window encoded on card	Doors/services configured by the campus card system	Area-specific rules per SP 800-116; revocation checked
Information stored	On card face: photo, name, roll no., programme, validity	UID + sector data; often a student number	Room number, dates, sometimes guest data on card	Identity token; personal data on campus server; not documented in detail	Certificates, CHUID, photo, fingerprints (on card, PIN-protected)
What the user does	Show card	Tap	Tap / insert	Hold phone near reader (Express Mode: no unlock)	Insert or tap; enter PIN for higher assurance
What security staff sees	Card and face	Usually nothing; door opens or not	Nothing; lock opens	Not documented; typically door opens	Depends on PACS; may show photo
Issuance	ID cell at admission	Card office encodes	Front desk encodes at check-in	Student enrolls via campus app after login	Identity proofing per SP 800-63A; card personalisation
Revocation	Replacement issued; old card not blocked	Depends on backend; Classic UID can be blocklisted but forged cards may spoof	New card overrides old at lock (sequence number); forged cards bypass	Remote revoke via wallet and campus system	Certificate revocation lists / status checks
Security limitations	Forgery, borrowing, no revocation, no audit	Full key recovery and cloning [4, 5]	Master key derivation from one card [8]; forged card pair opens property [9]	Relay; device compromise; not independently documented	Relay; PIN shoulder-surfing; complexity
Privacy considerations	Roll number and programme visible to anyone	Fixed UID trackable	Guest data on card in some deployments	Platform (Apple) sees usage metadata? not documented	Card contains biometrics; PIN-protected
Usability considerations	Fast glance; must retrieve card	Fast tap	Fast tap	No unlock needed with Express Mode; requires compatible device	PIN entry slows; card must be carried

Take-aways for our design

1. Every documented failure involved authenticating data on the card rather than proving possession of a key the card never reveals. → SEC-01, SEC-04, D1.
2. None of the broken systems checked revocation status at the point of entry in a way a forged card could not bypass. → SEC-02, FR-03, offline signed revocation list (Section 27).
3. Successful modern deployments (PIV, mobile ID) pair a cryptographic credential with a policy engine and revocation, and, where risk warrants, a human or second factor. → Architecture in Section 28.
4. Showing the guard the photo from the server for the authenticated credential, rather than the photo printed on the card, breaks the forgery path: an attacker cannot change the server's photo by altering the card. → PRIV-03, screen 5.

15. Research Gap

The published literature and deployed systems reviewed above cover each concern in isolation:

- Cryptographic strength of contactless credentials is well studied [4–7, 41].
- Relay attacks are well characterised, with countermeasures that are not commercially deployed [18–20].
- Facility-access guidance exists for high-assurance government settings with dedicated budgets and mandatory PIV cards [2].
- Usable-security principles are well established but are mostly studied for end-user software such as e-mail, passwords and browsers [10–13, 17, 33].
- Privacy frameworks and law define principles but not how to apply them to a movement log at a gate [22, 26, 27].

What the review did not find is published design work that treats the following together, as one problem:

1. Two humans in the loop with different needs. The credential holder (student) and the operator (guard) both have usability constraints; the guard's interface is a security control in its own right, not just a display. Most usable-security work studies one user.
2. Authorization as a first-class, separately-communicated decision. Deployed systems collapse "card valid" and "entry allowed" into one signal (door opens). Our review found no design guidance on how to communicate the distinction to a non-technical operator so that a revoked student and a forged card produce different, actionable responses.
3. Fail-secure degradation under infrastructure failure in a low-resource setting. SP 800-116 assumes government-grade infrastructure. The question of how a campus gate should behave during a network or power outage without either opening the gate or stranding hundreds of students is not addressed in the sources reviewed.
4. Privacy-preserving audit of a movement log. The trade-off between an audit trail useful for incident response and a dataset that reveals every student's daily pattern is noted in the privacy literature in general terms but not resolved for access control specifically.
5. Campus-specific constraints: mixed device ownership, contract security staff with varying training, high peak loads at predictable times, and a population that is technically sophisticated and privacy-aware.

Gap statement. Existing access-control research and practice secure the credential but treat the operator, the authorization decision, failure behaviour and privacy as afterthoughts. This project studies the combined design problem of authentication, authorization, guard usability, fail-secure degradation, and privacy-preserving audit in a campus setting, and derives requirements for it from primary research with both students and security staff. The contribution of Phase 1 is a traceable requirements and design baseline for that combined problem; the contribution of Phase 2 will be an implementation that can be tested against it.

This gap statement is supported by the absence of matching results in the sources reviewed; it is not a claim that no such work exists anywhere. A broader systematic search is listed as a limitation in Section 39.

16. Personas

These personas are synthesised, not real participants. They are constructed from the team's understanding of the campus, the hypotheses in Section 8, and the secondary research in Section 12. They are design tools, not findings. Every attribute marked [ASSUMPTION] must be checked against primary data; attributes marked [DATA REQUIRED] cannot be filled in until fieldwork is done. Once data is available, the personas will be revised to reflect actual distributions (e.g., real proportions of hostellers, phone ownership, forgotten-ID frequency).

Persona 1 — "Aarav", regular student

Context	Third-year B.Tech, hosteller. Enters and leaves campus 2–4 times daily (classes, gym, food outside). Carries a smartphone with NFC [ASSUMPTION]. Keeps ID card in wallet. [ASSUMPTION]
Goals	Get through the gate without breaking stride. Not be stopped or questioned. Not be late to an 8:30 class because of a queue.
Frustrations	Fishing the card out of a wallet while carrying a laptop bag and a coffee. Being questioned by a new guard when the regular one waves him through. Queues at 8:25.
Security concerns	Moderate. Has seen friends borrow each other's cards for the mess; assumes outsiders could do the same at the gate. Would like the gate to be harder to fool but not at his expense.
Privacy concerns	Does not want the college to know his daily movement pattern "for no reason". Would accept logging if it is only used for security and he can see his own records. [ASSUMPTION; validate Q14a, Q14b, Q15b]
Usability needs	Sub-two-second interaction. No app to open. Works when the phone is dead. Clear feedback that he's through so he doesn't hesitate.
Accessibility needs	None specific.
Design implications	Tap-and-go primary path (USE-01); phone credential as convenience (D1); pseudonymous log with self-service view (PRIV-08).

Persona 2 — "Meher", student who often forgets or has lost her ID

Context	First-year M.Tech, day scholar, commutes by metro. Has lost her card once already; replacement took [DATA REQUIRED] days, during which she "explained herself" to guards daily. Frequently leaves the card in a different bag. Has an Android phone; unsure whether it has NFC. [ASSUMPTION]
Goals	Not be turned away or humiliated at the gate. Get a replacement quickly. Have a fallback that does not depend on a guard's mood.
Frustrations	Inconsistent handling: one guard lets her in after a question, another refuses. Feeling that she is a suspect. Having to wait for a friend to vouch for her.
Security concerns	Worried that whoever found her lost card could walk in as her. Nobody told her whether the old card was blocked.
Privacy concerns	Uncomfortable that explaining herself at the gate meant saying her name, roll number and department aloud in front of a queue.
Usability needs	A fallback path that is defined, quick, and dignified: e.g., a phone credential or a one-time code, not an interrogation. Immediate blocking of a lost card from her own phone. Clear status of her replacement.
Accessibility needs	None specific.
Design implications	Forgotten-ID workflow via enrolled phone credential (Section 32, screen 12); self-service lost-card report and instant revocation (FR-09, screen 18); guard sees "credential revoked" not "student suspicious" (USE-03).

Persona 3 — "Ramesh", security guard

Context	Contract security staff, 8-hour shifts at the main pedestrian gate, sometimes covering the vehicle gate alone. Several years' experience [DATA REQUIRED]. Comfortable with a feature phone and WhatsApp; has used a fingerprint attendance machine; has not used a tablet-based system [ASSUMPTION; validate B Q10]. Primary language Hindi.
Goals	Keep the queue moving at 8:30 without letting in anyone he shouldn't. Not get blamed if something goes wrong. Know what to do when something unusual happens.
Frustrations	Students waving cards from three metres away. Not being able to read the small expiry date. Having no way to know whether a card was reported lost. Visitors who argue. Being told to check carefully and also told to clear the queue.
Security concerns	Knows regulars by face and worries that a stranger with a good card would get past him at peak. Has seen cards that "looked off" but had no way to confirm.
Privacy concerns	Does not want to be responsible for students' phone numbers or addresses; has been asked by outsiders for a student's details and would prefer not to have them. [ASSUMPTION; validate B Q12]
Usability needs	One glance, one decision. A big green/red result with the photo and a one-line reason in Hindi and English. A clear script for "what next" on every failure. No typing. Works in sunlight and at night.
Accessibility needs	Large text and high contrast (outdoor glare, reading glasses). Audio cue distinct for pass/fail so he can watch the person, not the screen.
Design implications	Guard screen shows photo, first name, role, decision, reason, next step only (PRIV-03, USE-02, USE-03, USE-04); bilingual; audio + colour + icon (USE-08); defined fallback scripts (FR-13, FR-14).

Persona 4 — "Dr. Fernandes", visitor

Context	External examiner visiting for a PhD defence. Arrives by taxi 20 minutes before the defence, has never visited before, host is a faculty member. Has a smartphone.
Goals	Get in quickly and reach the right building. Not be treated as a suspect. Not hand over more personal information than necessary.
Frustrations	Writing name, phone, address and purpose in a register that the previous ten visitors' details are visible in. Being asked to deposit a government ID. Waiting while the guard phones the host, who is in a meeting.
Security concerns	Low personal concern, but expects a reputable institution to have a process.
Privacy concerns	Does not want her phone number visible to the next visitor or retained indefinitely.
Usability needs	Pre-approval by the host so the gate step is a single scan. A pass that says where she may go and until when.
Accessibility needs	May be carrying luggage; may not read Hindi.
Design implications	Host-initiated visitor pre-approval (FR-10, screens 13–15); time- and gate-bound signed QR pass (SEC-16); visitor data retained only for the visit + short window (PRIV-09); no public register.

17. User Journeys

17.1 Current state: student entry

Stage	Student action	Student thought	Guard action / workload	Pain point	Security risk	Privacy issue
1. Approach	Walks toward gate, possibly in a group	"Where's my card?"	Watches approaching flow	Card retrieval begins late; slows queue (H1)	—	—
2. Retrieve	Opens bag / wallet / lifts lanyard	"Hurry"	—	Two hands needed; drop risk	—	—
3. Present	Shows card, often at distance	"He knows me anyway"	Glances at card colour, maybe photo	Distance defeats photo check (H3)	Borrowed/forged card passes	Roll no. and programme visible to bystanders
4. Verify	Waits (usually <2 s)	"Why is he looking longer?"	Decides genuine/not; expiry rarely read (H2)	Inconsistent rigour across guards	Expired/revoked cards pass	—
5. Decide	—	—	Nod / stop / question	Questioning is public and feels accusatory	False accept under peak pressure (H7); false reject of legitimate student	Student answers identity questions aloud
6. Enter	Walks in	"Done"	Next person	—	No record for incidents (H8)	—
Exception: no card	Explains; names hostel/dept; waits for friend	"I'm being treated as a suspect"	Judgement call; may call supervisor	No defined procedure (H4); delay for everyone behind	Social engineering path: a confident stranger can "explain" too	Personal details spoken publicly

Summary of current-state issues: the process is fast only when it is not really checking anything; it becomes slow, public and inconsistent exactly when it matters. Guard workload is cognitive (judgement) and social (confrontation), not mechanical.

17.2 Future state: student entry with the proposed system

Stage	User action	User thought	System / guard response	Friction	Residual security risk	Residual privacy risk	Opportunity
1. Approach	Walks to reader; card in wallet or phone in hand	"Tap"	Reader idle screen: "Tap card or phone" (screen 1)	Learn where reader is (first time)	—	—	Reader placement from observation data
2. Tap	Holds wallet/phone to reader (<1 s)	—	Reader performs challenge–response; "Checking..." (screen 3, <1 s)	Phone may need unlock (1–3 s)	Relay attack (Section 24)	Reader sees credential ID only	Audio/haptic confirmation
3. Authenticate	—	—	Server verifies key → authenticated as credential C; fetches photo, display name, role	—	Cloned key if chip broken	Photo displayed to guard (minimised)	Photo from server, not card, defeats forgery
4. Authorize	—	—	Policy: status active? gate allowed? time window? → authorized	—	Stale revocation list if offline (bounded)	—	Separate message for auth vs authz failure
5. Result	Glances at screen/hears tone	"Green, go"	Guard screen: photo + "Aarav · Student · ENTRY ALLOWED" (screen 5); guard confirms face; student screen/LED green; tone	Guard must actually look at photo	Guard fatigue → skips photo check	Name visible to guard	Photo-first layout; periodic "confirm face" nudges
6. Enter	Walks in	"Done"	Event logged: pseudonymous credential ID, gate, time, decision (no name)	—	Log tampering (mitigated: append-only, hashed)	Movement log exists; retention-limited, self-viewable	Transparency builds trust (PRIV-08)
Exception: forgot card	Opens app, taps phone or shows dynamic QR	"Good, I have a backup"	Same flow via phone credential; log records method	Requires enrolment beforehand	Phone compromise	—	No bypass, no interrogation
Exception: revoked	Taps; red	"What? Why?"	Guard screen: "Credential REVOKED — direct to Security Office" (screen 8); student screen: "Not accepted — see Security Office"	Student must go to office	—	Guard not told why revoked	Clear, dignified next step

17.3 Visitor journey (future)

Host submits visitor request (name, purpose, date/time window, gates) → Admin/host approval → Visitor receives signed QR pass by e-mail/SMS → At gate: scans QR → authenticated as visitor pass V; authorized for gate G, window T → Guard sees "VISITOR · Dr. Fernandes · Host: [name] · Valid until 17:00" → Entry logged → Pass expires automatically → Visitor record deleted after retention window.

18. User Tasks

Task scenarios used for the prototype walkthrough (Section 35), the heuristic evaluation (Section 36) and, in Phase 2, for task-based usability testing. Each task lists the actor, the precondition, the steps in the future-state system, the success criterion, and the screens involved.

ID	Task	Actor	Precondition	Steps (future system)	Success criterion	Screens
T1	Student enters campus	Student	Active card or enrolled phone	Approach → tap → wait for green → enter	Authenticated, authorized, logged; ≤2 s from tap to result; no guard intervention	1, 2, 3, 4, 5
T2	Student presents expired credential	Student, Guard	Credential past validity	Tap → red "EXPIRED" → guard reads next-step → student directed to ID cell / offered phone credential renewal	Entry denied; guard and student both understand reason and next step; no bypass	1, 2, 3, 7
T3	Student presents revoked credential	Student, Guard	Credential revoked (lost, disciplinary, withdrawn)	Tap → red "REVOKED" → guard directs to Security Office; event flagged	Entry denied; guard not shown reason for revocation; event logged as flagged	1, 2, 3, 8
T4	Student loses credential	Student	Enrolled in app or has portal access	Open app → "Report lost card" → confirm → card revoked immediately → replacement request created; phone credential continues to work	Card unusable within seconds; student retains access via phone; replacement tracked	18 (student view)
T5	Guard verifies a student	Guard	Student tapped; result shown	Look at photo → compare face → confirm (implicit: let pass) or tap "Mismatch"	Guard can decide in one glance; mismatch path available	5, 16
T6	Guard handles failed authentication	Guard	Unknown / invalid / suspicious credential	Screen shows "NOT RECOGNISED" or "SUSPICIOUS" with next step → guard follows script: no entry; direct to Security Office; option "Call supervisor"	No bypass; guard knows exactly what to do; event logged	6, 9, 12
T7	Guard handles visitor	Guard, Visitor	Visitor has pass or not	With pass: scan → "VISITOR · valid" → confirm. Without: guard opens "Visitor without approval" → host lookup → host approves from phone → pass issued → scan	Pre-approved visitor: ≤10 s. Unapproved: no entry until host approves; no paper register; visitor's phone number never shown to guard	13, 14, 15, 16
T8	Administrator issues credential	Admin	Student record exists in roster; admin authenticated with MFA	Search roster → verify identity documents per policy → personalise card / send phone enrolment link → set validity → confirm; action logged	Credential bound to correct identity; expiry set; issuance logged with admin ID	17
T9	Administrator revokes credential	Admin	Credential active	Search → select credential → choose reason (lost/stolen/disciplinary/left) → confirm (two-step) → revoked; pushed to gates within seconds; offline list updated	Revoked credential denied at all gates within defined propagation time; action logged	17, 18
T10	Administrator reviews entry logs	Admin (auditor role)	Authorised auditor with logged reason	Open logs → filter by gate/time/decision → view pseudonymous events → to re-identify, enter case reference → identity shown; re-identification itself logged	Routine review sees no names; re-identification requires justification and is auditable	19, 20

Additional tasks used in the prototype but not numbered in the brief: T11 Guard handles reader failure (screen 10); T12 Guard handles network outage (screen 11); T13 Student views own entry records and privacy settings (screen 20); T14 Admin configures gate authorization policy (screen 20).

19. Functional Requirements

Priority: M = Must (Phase 2 minimum), S = Should, C = Could. Evidence column: [P] primary (cite Q/interview once data exists), [S] secondary (cite ref), [A] labelled assumption. Until fieldwork completes, every [P] entry reads [DATA REQUIRED].

ID	Requirement	Rationale	Evidence	Priority	Screens
FR-01	A student can present a credential at a gate reader by tapping a smart card or an enrolled phone (NFC), or by showing a dynamic QR code from the app.	Universal baseline (card) plus convenience/fallback (phone) per D1.	[S] 13; [P] Q16, Q17 [DATA REQUIRED]	M	1, 2
FR-02	The system authenticates the credential by cryptographic challenge-response (card/NFC) or by verifying the signature and freshness of a dynamic QR token.	Prove possession of a key never transmitted; reject static identifiers.	[S] 1, 2, 4, 5	M	3
FR-03	The system checks credential validity: not expired, not revoked, not suspended, and (for visitor passes) within the issued time window.	Complete mediation; hotel-lock failures [8, 9] were failures of exactly this check.	[S] 2, 14	M	3, 7, 8, 15
FR-04	The system checks authorization: the authenticated principal's role and status permit entry at this gate at this time under the current policy.	Authorization is a distinct decision from authentication.	[S] 1, 14	M	3, 4, 5
FR-05	The system produces one of a fixed set of decisions: ALLOW; DENY—not recognised; DENY—expired; DENY—revoked; DENY—not authorized here/now; DENY—suspicious; and communicates it to guard and user.	Fixed vocabulary enables clear, consistent UI and logs.	[S] 12, 13	M	4–9
FR-06	The system records every access decision as an event containing: pseudonymous credential ID, gate ID, timestamp, method (card/NFC/QR/manual), decision code, and (for manual decisions) the guard's ID.	Auditability with minimisation.	[S] 22, 29	M	19
FR-07	An administrator can issue a credential to an identity in the roster, binding a card key or phone enrolment to that identity, and setting a validity period.	Credential lifecycle stage 1–2.	[S] 1 (800-63A), 2	M	17
FR-08	An administrator can revoke a credential with a recorded reason; revocation propagates to all gates within a defined time (target ≤30 s online; next sync offline).	Lifecycle stage 6; SEC-02.	[S] 2	M	17, 18
FR-09	A student can report their own card lost or stolen from the app or web portal, which immediately revokes that card while leaving any enrolled phone credential active.	Fast self-service revocation removes the window in which a lost card works; addresses H5.	[A]; [P] Q9, Q10 [DATA REQUIRED]	M	18
FR-10	A host (faculty/staff) can request a visitor pass specifying visitor name, purpose, date, time window and permitted gate(s); an approver (or auto-approval per policy) issues a signed, time-bound QR pass delivered to the visitor.	Replaces paper register; pre-approval moves work off the gate.	[A]; [P] B Q9 [DATA REQUIRED]	M	13, 14, 15
FR-11	Visitor passes expire automatically at the end of the window and cannot be extended without a new approval.	SEC-16.	[S] 2	M	15
FR-12	A guard can see the authentication and authorization result for the person at the gate, including the photo on file for the authenticated credential, display name, role, decision and reason, and can record a face-mismatch.	Human check defeats relay, borrowing and forgery of the printed card.	[S] 2, 13, 16	M	5, 16
FR-13	On any DENY, the system displays a defined next-step script to the guard and a minimal, non-accusatory message to the user; the guard cannot override a DENY into an ALLOW at the gate.	Fail-secure; consistent handling; no insecure bypass.	[S] 10, 13, 14	M	6–9, 12
FR-14	If the reader, network or database is unavailable, the reader continues to authenticate credentials locally using cached keys and a signed offline revocation list not older than a configured maximum age; if the list is older than that, or the reader itself fails, the system enters Manual Verification Mode with a defined procedure.	Availability without opening the gate.	[S] 2, 14	M	10, 11, 12
FR-15	An authorised auditor can review entry logs filtered by gate, time and decision; identities are pseudonymous by default and re-identification requires a recorded justification.	Auditability with privacy.	[S] 22, 26, 29	M	19
FR-16	A student can view their own entry events and the current status of each of their credentials.	Transparency; DPDP right of access [22].	[S] 22; [P] Q14b [DATA REQUIRED]	S	20
FR-17	The system detects repeated failed attempts (same credential ID, same gate, or same reader in a short window) and raises the decision to DENY—suspicious with an alert to the supervisor.	SEC-13.	[S] 29, 30	S	9, 16
FR-18	An administrator can define and update gate authorization policy (which roles may use which gates at which times) and the change is logged and versioned.	Authorization as data, not code; auditable policy.	[S] 14	S	20
FR-19	Manual Verification Mode records each manual decision with the guard's ID, the credential (if any) presented, and the verification steps taken, and flags all such events for later review.	Fallback remains auditable.	[S] 29	M	12

ID	Requirement	Rationale	Evidence	Priority	Screens
FR-20	Emergency egress is never blocked by the system; emergency ingress for first responders follows a supervisor-authorised procedure that is logged.	Life-safety supersedes access control; but ingress remains controlled.	[S] 31	M	12

20. Security Requirements

Each requirement lists: rationale, the user need it serves, the threats it addresses (IDs from Section 24), priority, the prototype feature that embodies it, and how it will be evaluated in Phase 2.

ID	Requirement	Rationale	User need	Threats	Pri	Prototype feature	Phase 2 evaluation
SEC-01	Only credentials that pass cryptographic authentication (challenge–response with a per-credential key, or valid signature on a fresh token) are accepted. Bare identifiers (UID, static QR) are never accepted.	Static identifiers are copyable; every documented breach [4–9] involved accepting data rather than proving key possession.	Students: confidence that a photo of their card cannot be used. Guards: fewer judgement calls.	TH-01 theft, TH-02 clone, TH-03 replay, TH-06 fake	M	Screen 3 "Verifying credential" → screen 6 "NOT RECOGNISED" for any unauthenticated read	Present cloned UID, static QR, replayed token → all DENY. Unit tests on verifier.
SEC-02	Revoked credentials must not grant access at any gate, online or offline, after the propagation deadline.	Complete mediation [14]; hotel breaches [8, 9] lacked this.	Meher: lost card must stop working. Guards: know a card is blocked.	TH-08 revoked reuse, TH-01	M	Screen 8 "REVOKED"; screen 18 revoke flow; offline list in screen 11	Revoke → tap within 30 s online and after sync offline → DENY.
SEC-03	Expired credentials must not grant access; expiry is enforced by the server/reader, not by a printed date.	H2: guards do not read dates.	Guards: no date reading. Admin: automatic enforcement.	TH-07 expired reuse	M	Screen 7 "EXPIRED"	Set expiry in past → DENY. Boundary tests at expiry instant.
SEC-04	Authentication must resist replay: card/NFC via server-generated nonce in challenge–response; QR via time-bound signed token with server-side replay cache; visitor pass via single/limited-use counter.	Replay is the cheapest attack on any transmitted credential.	Students: recording a tap must be useless.	TH-03 replay	M	Screen 3 (nonce exchange not visible to user; described in spec); screen 9 for detected replay	Capture and replay reader traffic and QR → DENY; second use of single-use pass → DENY.
SEC-05	All reader↔server and app↔server communication is protected with TLS 1.3 [39] with mutual authentication (reader client certificates); no plaintext or downgraded channels.	Network attacker and rogue reader.	—	TH-11 interception, TH-12 MITM, TH-16 device	M	Screen 11 shows "secure connection lost" state	TLS config scan; attempt plaintext/downgrade → connection refused.
SEC-06	Secrets (card keys, signing keys, tokens, nonces, session keys) must never appear in logs, UI, error messages, URLs, or analytics. Logs store only pseudonymous IDs and decision codes.	OWASP logging guidance [29].	Privacy; insider misuse.	TH-13 privacy leak, TH-17 insider	M	Screen 19 shows only pseudonymous IDs and codes	Grep logs and UI for key material in test runs; code review.
SEC-07	Role-based access control with least privilege [14]: Guard (view decision, record manual event, request supervisor); Supervisor (approve manual entries, view gate status); Issuer (issue/revoke credentials); Approver (visitor passes); Auditor (read logs, re-identify with justification); Policy Admin (edit policies). No role has all permissions. Separation of duties: Issuer ≠ Auditor.	Insider abuse, privilege escalation.	Guards: not responsible for data they don't need.	TH-09 escalation, TH-17 insider	M	Screens 16, 17, 19, 20 each show role-limited views	Attempt cross-role actions via API → 403; review of role matrix.
SEC-08	The guard interface displays only: photo on file, display (first) name, role, decision, reason code, next step. Never roll number, phone, address, hostel, e-mail, or revocation reason.	Minimisation; guards should not be a data-exposure vector.	Ramesh: does not want to hold personal data. Meher: dignity on denial.	TH-13, TH-17	M	Screens 5, 7, 8, 9, 16	UI inspection; API response schema test.
SEC-09	Every failure (authentication, authorization, reader, network, database, power) results in DENY or in Manual Verification Mode; no failure state opens the gate or auto-allows.	Fail-safe defaults [14].	—	TH-14 DoS, TH-15 outage, TH-16 device	M	Screens 6, 10, 11, 12	Fault injection: kill network, DB, reader mid-transaction → DENY/manual, never ALLOW.
SEC-10	Every access decision and every administrative action is written to an append-only, integrity-protected log (hash-chained; periodic signed checkpoints) with synchronised timestamps.	Auditability; repudiation.	Admin: investigate incidents. Students: trust that logs cannot be silently edited.	TH-15 log tamper, TH-17	M	Screen 19 log view with integrity status indicator	Modify a log record → verification fails; audit of chain.
SEC-11	Administrative operations (issue, revoke, policy change, re-identify, approve manual entry) require multi-factor authentication of the administrator and, for revoke/policy/re-identify, a two-step confirmation.	High-impact operations need stronger assurance [1].	—	TH-09, TH-17, TH-10 DB	M	Screens 17, 18, 20 show MFA and confirm steps	Attempt admin action with single factor → refused; attempt without confirm → not applied.
SEC-12	All credential lifecycle operations are authenticated, authorised per SEC-07, and logged per SEC-10, including who, when, which credential, and reason.	Lifecycle integrity.	—	TH-17, TH-06	M	Screens 17, 18	Log inspection after each lifecycle test.

ID	Requirement	Rationale	User need	Threats	Pri	Prototype feature	Phase 2 evaluation
SEC-13	Repeated failed attempts (≥ 3 on one credential ID in 5 min, or ≥ 5 unknown credentials at one reader in 5 min; thresholds configurable) escalate to DENY–suspicious, alert the supervisor, and rate-limit the reader.	Detect brute force, cloning trials, probing.	Guards: told when something is off.	TH-02, TH-06, TH-14	S	Screen 9 "SUSPICIOUS"; screen 16 alert	Scripted repeated attempts → escalation observed and logged.
SEC-14	The system stores only the personal data required: identity ID, display name, photo, role, programme/department, credential IDs/keys, validity, status. It does not store phone, address, emergency contact or any field not used by an implemented function.	Minimisation reduces breach impact.	Students: less to leak.	TH-10 DB compromise, TH-13	M	Screen 17 shows only these fields	Schema review; DPIA checklist.
SEC-15	Log integrity per SEC-10; additionally, logs are write-only for all roles except Auditor (read); no role can delete or edit; retention deletion is a scheduled, logged process.	Prevent cover-up of insider actions.	—	TH-15, TH-17	M	Screen 19: no edit/delete controls	Attempt delete via API → refused; verify scheduled purge logs itself.
SEC-16	Visitor passes are bound to a time window, gate set, and host; expire automatically; are single- or limited-use; and cannot be reissued without new approval.	Temporary credentials must not become permanent.	Visitors: clear validity. Guards: no judgement about "is this still OK".	TH-05 malicious visitor, TH-07	M	Screens 14, 15 show window and gate binding	Use pass after window / at wrong gate / twice → DENY.
SEC-17	Lost or stolen credentials are revocable by the holder (self-service, immediate) and by an Issuer; revocation is irreversible for that credential (a new credential is issued instead).	Remove attacker's window; avoid "un-revoke" confusion.	Meher: block card from her phone at once.	TH-01, TH-08	M	Screen 18	Self-revoke → immediate DENY; attempt to reactivate → refused.
SEC-18	Readers are treated as potentially compromised: each holds only its own client certificate and the offline verification material (public keys, signed revocation list), never master keys or the identity database; reader firmware is signed; tamper events are logged; a reader's certificate can be revoked server-side.	Onity [36] and DESFire side-channel [7] show devices leak.	—	TH-16 device compromise, TH-11	M	Screen 10 reader failure/tamper state	Extract reader storage in test → no master key present; revoke reader cert → server refuses it.
SEC-19	Defined secure behaviour during network/database failure: readers verify offline with cached public keys and a signed revocation list $\leq N$ hours old (N configurable, e.g., 4); beyond N , or without cached material, enter Manual Verification Mode (FR-14, FR-19). No unconditional ALLOW.	Availability with bounded staleness.	Students: not stranded. Guards: know what to do.	TH-14, TH-15 outage	M	Screens 11, 12	Fault injection with clock advance → mode transitions as specified.
SEC-20	Security must not depend on secrecy of the design, protocol, or code (open design [14]). Only keys are secret. All cryptography uses standard primitives and vetted libraries (AES-128/256, Ed25519 [38], SHA-256, TLS 1.3 [39]); no custom algorithms.	Course brief; established principle.	—	All	M	N/A (design property)	Design review; dependency audit.

Note on what SEC requirements do not claim. They do not claim the system cannot be attacked. Residual risks (relay, coerced or fatigued guard, compromised phone, future chip break) are recorded in Section 24 with the compensating controls.

21. Privacy Requirements

Grounded in DPDP Act 2023 [22], ISO/IEC 29100 [26] and Privacy by Design [27].

ID	Requirement	Principle	Rationale / user need	Pri	Prototype feature	Phase 2 evaluation
PRIV-01	Data minimisation: collect and store only the fields listed in SEC-14; visitors: name, host, purpose category, window, contact channel (for pass delivery only).	Collection limitation	Reduce breach impact; Ramesh does not want to hold personal data.	M	Screens 13, 17	Schema review
PRIV-02	Purpose limitation: entry data is used only for access decisions, security incident investigation and system integrity. It is not used for attendance, academic monitoring, or behavioural analytics without a separate, documented policy decision and notice.	Purpose specification	Q15b concern [DATA REQUIRED]; trust.	M	Screen 20 privacy notice text	Policy document; API scopes
PRIV-03	Role-based visibility: Guard sees photo, first name, role, decision, next step. Supervisor adds gate status and alert queue. Issuer sees identity fields needed to issue. Auditor sees pseudonymous logs; re-identification per PRIV-06. Student sees own data only.	Use limitation	Q14c [DATA REQUIRED].	M	Screens 5, 16, 17, 19, 20	Role-based UI/API tests
PRIV-04	Pseudonymous logging: access events store a credential pseudonym, not name or roll number; the mapping is held in a separately access-controlled table.	Minimisation; unlinkability	Routine log review reveals no identities.	M	Screen 19	Log inspection
PRIV-05	Retention limits: access events retained 90 days then deleted (configurable; justify any longer period); flagged/incident events retained until case closed + 1 year; visitor records deleted 30 days after visit; revoked credential records retained 1 year for fraud detection then deleted. Deletion is automatic and logged.	Retention limitation	DPDP erasure obligation [22].	M	Screen 20 shows retention policy	Verify scheduled purge
PRIV-06	Re-identification of a pseudonymous log entry requires Auditor role, a recorded case reference and justification, and is itself logged and visible to a second administrator.	Accountability	Prevent casual look-ups of "where was student X".	M	Screen 19 re-identify dialog	Attempt without justification → refused; log check
PRIV-07	Transparency notice: students and visitors are told, at enrolment and on the app/pass, what is collected, why, who can see it, how long it is kept, and how to access or query it.	Openness	Trust (Q15c [DATA REQUIRED]).	M	Screen 20; enrolment text	Content review
PRIV-08	Individual access: a student can view their own entry events and credential status, and request correction of identity data.	Individual participation	Q14b [DATA REQUIRED]; DPDP right of access [22].	S	Screen 20	Functional test
PRIV-09	Visitor data: no public register; visitor's phone/e-mail is used only to deliver the pass and is not shown to the guard; deleted per PRIV-05.	Minimisation	Dr. Fernandes persona; H6.	M	Screens 13–15	UI/API inspection
PRIV-10	Privacy-preserving UI: the guard screen is angled/hooded so bystanders cannot read it; the user-facing indicator shows only colour/icon and a short message, never the name; denial messages do not state the reason to bystanders.	Confidentiality in public space	Meher: dignity; public interrogation today.	M	Screens 4–9 user-facing vs guard-facing split	Field check of placement; UI review
PRIV-11	Secure storage: personal data and key material encrypted at rest (AES-256; keys in HSM/KMS or OS keystore); photo store separately access-controlled.	Security safeguards	DPDP reasonable safeguards [22].	M	—	Config review
PRIV-12	No secondary sharing: entry data is not shared with third parties or other campus systems without a documented legal basis and notice.	Disclosure limitation	Q15b.	M	Screen 20 notice	Policy and API review

21.1 Visibility comparison: what each role sees

Data item	Student (own)	Security guard	Supervisor	Issuer / ID cell	Auditor	Policy admin
Photo on file	✓	✓ (on tap only)	✓ (on tap/alert only)	✓ (when issuing)	On re-identify only	✗
First / display name	✓	✓	✓	✓	On re-identify only	✗
Full name	✓	✗	✗	✓	On re-identify only	✗
Roll number / employee ID	✓	✗	✗	✓	On re-identify only	✗
Programme / department	✓	✗	✗	✓	On re-identify only	✗ (roles only)
Role (student/staff/visitor)	✓	✓	✓	✓	✓	✓ (as policy subject)
Hostel	✓	✗	✗	✗ (not stored)	✗	✗
Phone / e-mail	✓	✗	✗	✗ (not stored for students; visitor contact only for pass delivery)	✗	✗

Data item	Student (own)	Security guard	Supervisor	Issuer / ID cell	Auditor	Policy admin
Home address / emergency contact	✗ (not stored)	✗	✗	✗	✗	✗
Credential status (active/revoked/expired)	✓ (own)	Decision only	Decision only	✓	✓ (pseudonymous)	✗
Revocation reason	✓ (own, generic)	✗	✗	✓	✓	✗
Own entry events	✓	✗	✗	✗	✓ (pseudonymous; re-identify with justification)	✗
Other people's entry events	✗	✗	Gate counts only	✗	✓ (pseudonymous)	Aggregates only
Decision + reason code + next step	✓ (own)	✓	✓	✗	✓	✗
Visitor host name	—	✓	✓	—	✓	✗
Visitor contact	—	✗	✗	Approver only, for delivery	✗	✗
Policy rules	Own applicable summary	✗	Read	✗	Read	✓ Edit

22. Usability Requirements

Grounded in Nielsen [15], Yee [13], Cranor [16], Adams & Sasse [10], Herley [11], WCAG 2.2 [28].

ID	Requirement	Rationale / user need	Evidence	Pri	Prototype feature	Phase 2 evaluation
USE-01	The normal authenticated entry requires one physical action from the student (a tap) and no action from the guard beyond a glance; time from tap to result ≤ 1.5 s (95th percentile) online, ≤ 2 s offline.	Herley [11]: the secure path must cost less than today's glance. H1, H7.	[S] 11, 17; [P] Q11a, observation [DATA REQUIRED]	M	Screens 1–5	Timing measurement at pilot gate
USE-02	A first-time guard, after ≤ 15 minutes of training, can correctly state the meaning and next step for every result screen without technical vocabulary.	Cranor [16]: comprehension stage. Ramesh persona.	[S] 12, 16; [P] B Q13 [DATA REQUIRED]	M	Screens 4–12 use plain bilingual text	Comprehension test with guards
USE-03	Authentication failure ("we don't recognise this credential") and authorization failure ("recognised, but not allowed here/now" — expired, revoked, wrong gate) are visually and verbally distinct on both guard and user displays, with distinct next steps.	Core project distinction; different responses required.	[S] 1, 14	M	Screens 6 vs 7, 8, 9	Guards sort screens into correct categories
USE-04	Every error/deny message states what happened (in role-appropriate detail) and exactly what to do next; no dead ends.	Nielsen #9; Whitten & Tygar [12].	[S] 12, 15	M	All DENY screens have "Next step" block	Heuristic + task test T2, T3, T6
USE-05	The guard interface never requires the guard to read more than the photo, one name, one status word and one line of instruction to make the routine decision.	Ramesh: one glance. SEC-08.	[S] 13, 16; [P] B Q11 [DATA REQUIRED]	M	Screen 5 layout	Eye-tracking optional; timed decision test
USE-06	System status is always visible on the guard screen: online/offline mode, revocation list age, reader health, pending alerts.	Nielsen #1; Yee visibility [13].	[S] 13, 15	M	Screen 16 status bar; screens 10, 11	Heuristic
USE-07	Learnability for students: no enrolment step is needed to use the card; phone enrolment takes ≤ 3 minutes and is optional.	Path of least resistance [13].	[S] 13	M	Enrolment described in spec	Timed enrolment
USE-08	Multimodal feedback for the result: colour (green/amber/red), icon ($\checkmark$ / ! / $\times$), distinct audio tone, and (on phone) haptic; never colour alone.	Accessibility (WCAG 1.4.1 [28]); outdoor glare; guard watches person not screen.	[S] 28	M	Screens 4–9	Accessibility audit
USE-09	Text contrast $\geq 4.5:1$, minimum 18 pt for status words on the guard display, readable in direct sunlight and at night; bilingual (Hindi/English) labels.	WCAG 1.4.3 [28]; observation of light conditions [DATA REQUIRED].	[S] 28; [P] D	M	All screens	Contrast tool; field test
USE-10	Error prevention: destructive admin actions (revoke, policy change) require confirmation showing the exact effect; guard "Mismatch" and "Call supervisor" are large, separated, and reversible until confirmed.	Nielsen #5; reversibility [13].	[S] 13, 15	M	Screens 16, 17, 18, 20	Heuristic; task T9
USE-11	Recognition over recall: guard next-step scripts are on screen, not memorised; admin forms show roster data rather than requiring typed IDs.	Nielsen #6.	[S] 15	S	Screens 6–12, 17	Heuristic
USE-12	Queue management: reader supports back-to-back taps with no reset step; result clears automatically after the person passes or after 5 s; a second reader lane can be added without software change.	H1, H7; peak load.	[P] observation [DATA REQUIRED]	S	Screen 5 auto-clear	Throughput test
USE-13	Trust and transparency: students can see why the system exists, what it records, and their own records (PRIV-07, PRIV-08); the user-facing display shows a short, respectful message on denial.	Q15c [DATA REQUIRED]; Meher dignity.	[P] Q15	S	Screens 4–9 user side; 20	Survey after pilot
USE-14	Accessibility of the physical interaction: reader mounted at a height reachable from a wheelchair (approx. 0.9–1.1 m), tap works through wallets/bags, phone path supports OS screen readers; a non-visual confirmation exists.	Q18 [DATA REQUIRED]; WCAG [28].	[S] 28; [P] Q18	M	Spec notes on screen 1, 2	Accessibility review

23. Non-Functional Requirements

ID	Category	Requirement	Measure / target	Evidence
NFR-01	Performance	End-to-end decision latency at gate	≤ 1.5 s p95 online; ≤ 2 s p95 offline (USE-01)	[S] 11
NFR-02	Performance	Throughput per reader lane	≥ 30 people/minute sustained with back-to-back taps	Observation [DATA REQUIRED]
NFR-03	Reliability	Reader operates correctly across expected outdoor conditions (temperature, humidity, dust, rain shelter) and after power interruption without manual reconfiguration	Vendor spec + field pilot	[A]
NFR-04	Availability	Gate authentication function available $\geq 99.5\%$ of operating hours, counting offline mode as available and Manual Verification Mode as degraded	Uptime log	[A]
NFR-05	Availability	Offline operation with cached verification material for $\leq N$ hours (N default 4) before degrading to manual	Fault injection (SEC-19)	[S] 2
NFR-06	Scalability	Supports the full campus population plus visitors and ≥ 10 gates/readers without architectural change; policy evaluation $O(1)$ per decision	Load test	[A]
NFR-07	Security	All SEC-xx requirements; standard primitives only; dependency vulnerability scan clean at release	OWASP ASVS L2 checklist [29]	[S] 29
NFR-08	Privacy	All PRIV-xx requirements; DPIA completed before any pilot with real student data	DPIA document	[S] 22, 26
NFR-09	Accessibility	Guard and student interfaces meet WCAG 2.2 AA where applicable; physical mounting per USE-14	Audit	[S] 28
NFR-10	Maintainability	Policy, thresholds, retention periods, and N are configuration, not code; components (reader firmware, auth service, policy engine, log service) are separately deployable; $\geq 50\%$ original code (course rule [43])	Code review	[S] 43
NFR-11	Auditability	100% of access decisions and admin actions logged with integrity protection; log verification tool provided	Verification run	[S] 29
NFR-12	Usability	All USE-xx; SUS score ≥ 70 from guards in Phase 2 pilot; task success $\geq 95\%$ for T1, T5, T6	Phase 2 study	[S] 15
NFR-13	Interoperability	Card credential based on ISO/IEC 14443 [23]; QR per ISO/IEC 18004 [25]; tokens per RFC 7519 [40] with Ed25519 [38]	Standards conformance	[S] 23, 25, 38, 40
NFR-14	Time synchronization	All readers and servers synchronised to ≤ 1 s (NTP); clock drift triggers a status warning; TOTP/token windows tolerate ± 1 step	Monitoring	[S] 37

24. Threat Model

Method: STRIDE per element and per trust boundary of the data-flow diagram in Section 29, following Shostack [30]. Likelihood and impact are rated Low / Medium / High by team judgement informed by the secondary research; they are [ASSUMPTION]-grade ratings to be revisited after primary data (e.g., how often guards see suspicious cards, B Q5) and after Phase 2 testing.

24.1 Threat actors

ID	Actor	Capability	Motivation	Access
TA-01	Unauthorised visitor (opportunist)	Social engineering, tailgating, borrowed card	Curiosity, theft, meeting someone, sales	Approaches gate
TA-02	Student using another student's credential	Legitimate-looking holder; knows campus	Convenience (forgot card), helping a friend, letting an outsider in	Has a valid card not their own
TA-03	Attacker with a copied credential	Card reader/writer, Proxmark-class tool, phone with NFC; photo of QR	Persistent access, impersonation	Brief proximity to a victim's card or screen
TA-04	Attacker attempting replay	Sniffing equipment near reader; screenshot of QR	Access without victim's card	Proximity to reader during a legitimate tap
TA-05	Malicious visitor	Valid visitor pass; intent to overstay, roam, or share pass	Theft, harassment, unauthorised presence	Approved for limited window/gate
TA-06	Compromised reader (physical or firmware)	Physical access to reader housing, debug ports; supply-chain tamper	Extract keys, log credentials, force ALLOW	Physical, possibly overnight
TA-07	Compromised user device (phone malware, rooted device)	Malware with app or OS privileges	Steal phone credential, generate tokens remotely	Victim's phone
TA-08	Network attacker	On campus Wi-Fi/LAN or ISP path; MITM, sniffing, DoS	Intercept, modify, replay, deny service	Network between reader and server
TA-09	Database attacker	SQL injection, stolen backup, cloud misconfiguration, credential stuffing on admin	Mass identity data, key material, log manipulation	Remote or via compromised admin
TA-10	Malicious insider (guard, admin, developer)	Legitimate role privileges; knowledge of procedures	Let someone in, look up a person, cover tracks, sell data	Authenticated role account
TA-11	Attacker with physical access to a credential (theft, finding)	Holds the card/phone	Enter as victim before revocation	Until revoked
TA-12	Denial-of-service attacker	Jam RF, flood readers with bad taps, cut power/network, DDoS server	Disrupt campus, force manual mode to exploit it	Near gate or remote

24.2 Assets

ID	Asset	Sensitivity	Where it lives
AS-1	Student identity (name, roll no., programme, photo)	Personal data	Identity store; photo store
AS-2	Credentials (cards, phone enrolments, visitor passes)	Access-enabling	Card chips; phone secure storage; credential table
AS-3	Authentication keys and secrets (per-card AES keys, app signing keys, token signing key, TLS private keys, revocation-list signing key)	Critical secret	HSM/KMS; card chips; phone keystore; reader (own cert only)
AS-4	Access permissions and credential status	Integrity-critical	Credential/status table; offline revocation list
AS-5	Entry logs	Personal data (movement); integrity-critical	Log store
AS-6	Personal information beyond identity (visitor contact)	Personal data	Visitor table (short-lived)
AS-7	Authorization policies	Integrity-critical	Policy store
AS-8	System availability (gate throughput)	Operational	Readers, network, servers
AS-9	Security devices (readers, guard tablets, servers)	Physical + firmware integrity	Gates; server room/cloud

24.3 Threat table

For every threat: scenario, asset, impact, likelihood/priority, mitigation (requirement IDs), residual risk, usability impact.

ID	Threat (STRIDE)	Attack scenario	Asset	Security impact	Likelihood / Priority	Mitigation	Residual risk	Usability impact of mitigation
TH-01	Credential theft (S)	TA-11 finds or steals a card and taps it at the gate before the owner notices	AS-2, AS-4	Unauthorised entry as victim; victim blamed via log	Likelihood M (cards are lost; H5); Priority High	Self-service instant revocation (SEC-17, FR-09); guard photo check against server photo (FR-12); phone credential requires unlock (D1); short propagation (FR-08)	Window between loss and report; guard fatigue skipping photo	Student must know how to report (USE-13); guard must glance at photo (USE-05)
TH-02	Credential cloning (S)	TA-03 reads a MIFARE-Classic-class card or photographs a static QR and writes a clone	AS-2, AS-3	Persistent unauthorised entry; undetectable if UID-based	Likelihood H for weak tech [4, 5], L for AES challenge-response [41]; Priority High	Cryptographic challenge-response with per-card key, never bare UID (SEC-01); dynamic signed QR only (SEC-04); modern chip family (D1); anomaly detection on impossible sequences, e.g., same credential at two gates within minutes (SEC-13)	Future break of chosen chip family; side-channel key extraction [7] with physical possession	None for user; cost of secure cards
TH-03	Replay (S, T)	TA-04 records reader-card exchange or screenshots a QR and presents it later	AS-2	Unauthorised entry	Likelihood M; Priority High	Server nonce in challenge-response (SEC-04); QR tokens time-bound (30–60 s) and single-use cache (SEC-04); visitor pass counters (SEC-16)	Real-time relay within window (see TH-04b); clock skew abuse bounded by NFR-14	Slight: QR must be shown within a minute of generation
TH-04	Impersonation (S)	(a) TA-02 uses a friend's valid card; (b) TA-03 relays a live card/phone from a victim elsewhere [18–20]	AS-1, AS-2	Wrong person admitted; log attributes entry to victim	(a) Likelihood H (social norm; Q12 [DATA REQUIRED]); (b) Likelihood L (skill/equipment); Priority High	Guard compares face to server photo for the authenticated credential (FR-12, USE-05); "Mismatch" button denies and flags (screen 16); phone credential requires unlock, so lending a phone is costlier; velocity/anomaly rules (SEC-13); Phase 2 option: distance-bounding not available commercially, so relay accepted as residual	Guard fatigue or coercion; relay defeats all crypto and is stopped only by the human check	Photo check adds ~0.5 s of guard attention per person; must be designed as a glance
TH-05	Credential sharing / malicious visitor (S, E)	TA-05 forwards visitor QR to a second person, or overstays, or goes to a different gate	AS-2, AS-4	Unapproved person or area; overstay	Likelihood M; Priority Medium	Pass bound to window + gate set + host (SEC-16); single/limited use; guard sees host name and asks if unsure; overstay produces DENY at exit? (exit not controlled: residual); host notified on use (FR-10)	Forwarding within window before first use; overstay inside campus	Visitor must present pass from their own device; host gets a notification
TH-06	Fake credential (S)	TA-01 presents a home-made card or QR that looks right	AS-2	Entry if visual check is the only control	Likelihood H today, L with crypto; Priority High	SEC-01: a fake cannot pass challenge-response → "NOT RECOGNISED" (screen 6); server-side photo means altering printed photo is useless; guard never asked to judge card authenticity	Fake that also carries a cloned key = TH-02	Removes a cognitive load from guards
TH-07	Expired credential reuse (E)	Graduated student or old visitor pass presented	AS-4	Ex-member enters	Likelihood H today (H2), L with enforcement; Priority Medium	Server/reader enforces expiry (SEC-03); visitor auto-expiry (SEC-16, FR-11); distinct "EXPIRED" message and renewal path (screen 7)	Clock manipulation on offline reader (bounded by NFR-14, signed time in list)	Students must renew before expiry; app reminds them
TH-08	Revoked credential reuse (E)	Suspended/withdrawn student, or holder of a reported-lost card, taps	AS-4	Barred person enters	Likelihood M; Priority High	Revocation checked on every decision (SEC-02); propagation ≤30 s online; signed offline list ≤N h (SEC-19); irreversible revocation (SEC-17); "REVOKED" screen without reason (screen 8, SEC-08)	Offline staleness window up to N hours; mitigated by shortening N at cost of more manual mode	None for legitimate users
TH-09	Unauthorised privilege escalation (E)	Guard account used to revoke/issue; admin session hijacked; API called with wrong role	AS-4, AS-7, AS-2	Arbitrary issue/revoke; policy change	Likelihood M; Priority High	RBAC with least privilege and separation of duties (SEC-07); MFA + two-step confirm for admin ops (SEC-11); all admin actions logged (SEC-12); session timeouts	Compromised MFA device; collusion of two insiders	Admin ops take longer (MFA, confirm)

ID	Threat (STRIDE)	Attack scenario	Asset	Security impact	Likelihood / Priority	Mitigation	Residual risk	Usability impact of mitigation
TH-10	Database compromise (I, T)	TA-09 dumps identity, credential and log tables or edits status	AS-1, AS-3, AS-4, AS-5	Mass privacy breach; forged status; key theft enabling cloning	Likelihood M; Priority High	Minimisation limits blast radius (SEC-14, PRIV-01); keys in HSM/KMS not DB (SEC-18, PRIV-11); encryption at rest (PRIV-11); pseudonymous logs with separate mapping table (PRIV-04); integrity-protected logs (SEC-10); parameterised queries, ASVS L2 (NFR-07)	Attacker with HSM access; insider DBA	None for users
TH-11	Network interception (I)	TA-08 sniffs reader-server or app-server traffic	AS-1, AS-3	Learn identities, tokens, nonces	Likelihood M on shared Wi-Fi; Priority Medium	TLS 1.3 mutual auth (SEC-05); no identity in reader-server request beyond credential pseudonym; tokens short-lived	Traffic analysis (who tapped when)	None
TH-12	Man-in-the-middle / rogue server (T, S)	TA-08 impersonates the server to a reader, returning ALLOW	AS-4, AS-8	Reader opens on attacker's command	Likelihood L-M; Priority High	Mutual TLS with pinned server cert on reader (SEC-05); decisions signed by server key and verified by reader; reader never trusts unauthenticated ALLOW (SEC-09)	Compromise of server signing key	None
TH-13	Privacy leakage (I)	Guard screen read by bystanders; roll number displayed; logs browsed casually; visitor register visible	AS-1, AS-5, AS-6	Exposure of identity, movement, contacts	Likelihood H today (H6, public questioning); Priority High	SEC-08/PRIV-03 minimal guard view; PRIV-10 physical screen placement and split user/guard displays; PRIV-04/06 pseudonymous logs with justified re-identification; PRIV-09 no public register; PRIV-05 retention	Guard verbally reveals name; shoulder-surfing of guard tablet	Guard sees less, decides on photo + first name only
TH-14	Denial of service (D)	TA-12 jams RF, floods readers with invalid taps, cuts power/network, or DDoSes the server, to create chaos or force manual mode	AS-8	Queues; pressure to bypass; manual mode exploited by TA-01	Likelihood M; Priority Medium	Offline verification (SEC-19) so network DoS does not stop gate; rate-limiting and SEC-13 escalation for tap floods; battery backup for readers (NFR-03); Manual Verification Mode is defined, logged and not an open gate (FR-14, FR-19); supervisor alert	Sustained physical jamming forces manual mode for its duration	Manual mode is slower (accepted degradation)
TH-15	Log tampering / loss (T, R)	TA-10 deletes an entry to hide a let-in; outage loses events	AS-5	Repudiation; failed investigation	Likelihood M (insider), M (outage); Priority High	Append-only hash-chained logs with signed checkpoints (SEC-10, SEC-15); reader buffers events locally during outage and syncs (FR-14); no delete/edit for any role; write-once storage	Attacker who controls the checkpoint signing key and all replicas	None
TH-16	Device compromise (reader, guard tablet, phone) (T, I, E)	TA-06 opens reader, dumps firmware/keys [36]; installs skimmer; TA-07 malware exports phone credential	AS-3, AS-2, AS-9	Key theft → cloning; forced ALLOW; credential exfiltration	Likelihood M (readers are outdoors, unattended at night); Priority High	Reader holds no master keys (SEC-18); per-reader client cert revocable; signed firmware; tamper switch logged; reader cannot decide ALLOW without server or valid offline material; phone keys in hardware keystore, app refuses to run on rooted device (Phase 2), remote revoke of phone credential (SEC-17)	Sophisticated hardware attacks on secure elements; zero-day on phone OS	None for users
TH-17	Insider abuse (I, E, R)	Guard lets friend through in manual mode; admin looks up a student's movements; issuer creates a credential for a non-member	AS-1, AS-4, AS-5	Unauthorised entry; stalking; ghost identities	Likelihood M; Priority High	Manual decisions logged with guard ID and flagged for review (FR-19); guard cannot override DENY to ALLOW (FR-13); re-identification requires justification, is logged, and is visible to a second admin (PRIV-06); issuance requires roster match and is logged (FR-07, SEC-12); separation of duties (SEC-07)	Collusion; supervisor approving bad manual entries	Manual entries require a supervisor step (slower, by design)

24.4 Trust boundaries and attack surfaces (summary; diagram in Section 29)

Boundary	Between	Crossing data	Controls
B1 Physical	Person/credential ↔ Reader	RF challenge–response; QR image	SEC-01, SEC-04; reader tamper (SEC-18)
B2 Gate LAN	Reader/guard tablet ↔ Campus network	TLS 1.3 mutual (SEC-05)	Cert pinning; signed decisions
B3 Service	Auth service ↔ Policy engine ↔ Stores	Internal API	RBAC service accounts; least privilege
B4 Key custody	Services ↔ HSM/KMS	Key ops only	Keys never leave HSM; audit
B5 Admin	Admin browser ↔ Admin API	MFA sessions	SEC-11, SEC-07
B6 Student	Phone app ↔ Enrolment/API	TLS; device attestation (Phase 2)	Hardware keystore
B7 Visitor	Host/approver ↔ Visitor pass delivery	Signed QR via e-mail/SMS	SEC-16

24.5 Prioritised summary

High priority (design must address in Phase 2 minimum): TH-01, TH-02, TH-03, TH-04, TH-06, TH-08, TH-09, TH-10, TH-12, TH-13, TH-15, TH-16, TH-17. Medium: TH-05, TH-07, TH-11, TH-14.

Accepted residual risks, stated plainly: (1) real-time relay attacks are not prevented cryptographically and rely on the guard's photo check and anomaly detection; (2) a guard who is coerced, colluding or fatigued can fail the photo check; (3) revoked credentials may work at an offline reader for up to N hours; (4) a future cryptanalytic or side-channel break of the chosen card family would require re-issuance, which the lifecycle design makes possible but not free; (5) the system does not control exit and cannot detect overstay by visitors.

25. Attack Scenarios

Each scenario walks through Attack → Impact → Detection → Prevention → Recovery against the proposed design, and names the requirements involved. These are analytical scenarios, not observed incidents.

Scenario 1 — Student loses ID

Attack. Meher leaves her card on the metro. A stranger finds it and, that evening, taps it at the gate. **Impact** (current system). Card is visually valid; stranger enters; no record. **Detection** (proposed). If Meher has already reported it (app → "Report lost", FR-09), the tap returns DENY–REVOKED (screen 8) and the event is flagged; supervisor alerted. If she has not yet reported it, the tap authenticates (the key is genuine); the guard sees Meher's photo (FR-12) and a stranger's face → "Mismatch" → DENY–SUSPICIOUS, flagged. **Prevention.** SEC-17 self-service revocation closes the window to minutes; FR-12/USE-05 photo check covers the gap; phone credential means Meher keeps access (no pressure on her to delay reporting). **Recovery.** Revocation is irreversible; Issuer issues a new card (FR-07); Meher's phone credential is unaffected; flagged event reviewed by Auditor.

Scenario 2 — Student gives ID to another person

Attack. Aarav lends his card to a friend from another college for the day. **Impact.** Outsider on campus under Aarav's identity; if anything happens, the log names Aarav's credential. **Detection.** Guard sees Aarav's server photo next to a different face → Mismatch (screen 16) → DENY, flagged with guard ID. If Aarav also taps his phone elsewhere within minutes, SEC-13 velocity rule flags an impossible sequence. **Prevention.** Cannot be prevented cryptographically; deterred by the visible photo check and by clear communication that entries are attributed to the credential holder (PRIV-07). Phone credentials raise the cost of lending (must hand over an unlocked phone). **Recovery.** Flagged event reviewed; institutional policy applies to Aarav; friend denied.

Scenario 3 — Attacker copies credential

Attack. TA-03 stands behind Aarav in the mess queue with a reader in a bag and reads his card. **Impact** (if MIFARE Classic / UID-based). Full clone in seconds [4, 5]; persistent access as Aarav. **Impact** (proposed). The card performs AES challenge–response with a key that never leaves the chip [41]; the sniffed exchange yields a nonce and a response, not the key. A clone with the same UID but no key → DENY–NOT RECOGNISED (screen 6). **Detection.** Repeated unknown credentials at a reader → SEC-13 escalation → SUSPICIOUS + alert. **Prevention.** SEC-01 (never accept UID), D1 (AES card family), SEC-18 (reader holds no key that would help). **Recovery.** If a chip family is later broken, Issuer re-issues that batch; revocation list handles the old cards (Section 26, stage 10).

Scenario 4 — Attacker attempts replay

Attack. TA-04 records the RF exchange during a legitimate tap and plays it back an hour later; or screenshots Meher's dynamic QR and shows it the next morning. **Impact.** None if SEC-04 holds: the recorded response answers yesterday's nonce, not today's; the QR token's timestamp is outside the window and its ID is in the replay cache. **Detection.** Reader logs a response to a stale nonce as a protocol error → DENY–SUSPICIOUS; QR with expired timestamp → DENY–NOT RECOGNISED with internal code "stale token" for the auditor. **Prevention.** Server-generated nonces (SEC-04); 30–60 s token windows with server-side dedupe; NTP (NFR-14). **Recovery.** Nothing to recover; flagged event for review. Real-time relay within the window is the residual (TH-04b).

Scenario 5 — Visitor attempts unauthorised entry

Attack. A person claims to be visiting a professor, has no pass, and pressures the guard; or forwards a friend's visitor QR. **Impact** (current). Guard writes a name in the register and lets them in, or refuses and faces an argument. **Detection** (proposed). No pass → guard opens "Visitor without approval" (screen 13); host is looked up and asked to approve from their phone (screen 14); no approval → no entry, script on screen. Forwarded pass: single-use counter (SEC-16) means the second scan is DENY; host is notified on first use, so the real visitor's arrival exposes the misuse. **Prevention.** FR-10/FR-11/SEC-16; guard has a defined procedure (FR-13) and never enters visitor data by hand. **Recovery.** Denied; host informed; pass revoked if misused.

Scenario 6 — Expired credential is presented

Attack. A graduate returns with last year's card. **Impact** (current). Guard does not read the date (H2); graduate enters. **Detection.** Authentication succeeds (genuine card), authorization fails on validity → DENY–EXPIRED (screen 7); guard sees "Expired — direct to ID cell for renewal if still a member". **Prevention.** SEC-03; validity enforced by server, cached on reader in offline mode. **Recovery.** If the person is still a member (delayed renewal), Issuer renews (lifecycle stage 9); otherwise nothing to recover.

Scenario 7 — Revoked credential is presented

Attack. A student under disciplinary suspension taps their card. **Impact** (current). Nothing on the card indicates suspension; enters. **Detection.** DENY–REVOKED (screen 8); guard sees only "Revoked — direct to Security Office"; the reason is not shown (SEC-08). **Event flagged.** **Prevention.** SEC-02; revocation pushed within 30 s; offline list. **Recovery.** If revocation was in error, a new credential is issued (SEC-17); the old one stays revoked to keep the audit trail unambiguous.

Scenario 8 — Reader/device is compromised

Attack. Overnight, TA-06 opens the reader housing, connects to a debug port, and dumps storage, hoping for master keys [36]; or replaces firmware to log every credential and return ALLOW. **Impact** (proposed). Storage yields the reader's own client certificate, public verification keys and the signed revocation list; no card keys, no identity data (SEC-18). Tamper switch logs an event; server revokes that reader's certificate; reader cannot obtain decisions. A firmware that returns ALLOW locally cannot open a gate that requires a server-signed or offline-verifiable decision (SEC-09, TH-12 control); the guard screen would show "Reader offline / tamper" (screen 10). **Detection.** Tamper event; certificate anomalies; reader failing attestation at boot (Phase 2). **Prevention.** SEC-18 (no secrets on reader), signed firmware, mutual TLS, tamper logging. **Recovery.** Replace reader; rotate its certificate; review logs for the period.

Scenario 9 — Database is compromised

Attack. TA-09 exploits an injection flaw in an admin page and dumps all tables. **Impact** (proposed). Identity table: name, roll number, programme, photo reference: a real breach but bounded by SEC-14 (no phone, address, contacts). Credential table: credential IDs, status, key references: keys themselves are in the HSM (SEC-18, PRIV-11). Logs: pseudonymous IDs (PRIV-04); the mapping table is separately controlled. Attacker cannot mint valid cards without HSM keys; cannot silently edit logs (SEC-10). **Detection.** Integrity checkpoints fail if logs were altered; DB access anomalies; ASVS controls. **Prevention.** NFR-07 (ASVS L2), parameterised queries, least-privilege DB accounts, encryption at rest. **Recovery.** Breach notification per DPDP [22]; rotate service credentials; because per-card keys were not exposed, cards need not be re-issued; if the mapping table was included, treat logs as identified and notify accordingly.

Scenario 10 — Security operator has excessive privileges

Attack. A guard account has been granted Issuer rights "for convenience". The guard issues a card to a friend, or looks up a student's entry history. **Impact.** Ghost credential; stalking. **Detection.** Issuance without roster match is refused (FR-07); if roster match exists, issuance is logged with the guard's ID and reviewable (SEC-12); re-identification of logs requires Auditor role and justification, visible to a second admin (PRIV-06). **Prevention.** SEC-07 role matrix with separation of duties makes "guard + issuer" a policy violation flagged at role assignment; MFA for admin ops (SEC-11). **Recovery.** Revoke the ghost credential; remove excess role; audit that account's actions.

25.1 Scenario coverage matrix

Scenario	Threats exercised	Requirements exercised	Screens
1 Lost ID	TH-01, TH-08	SEC-02, SEC-17, FR-09, FR-12	8, 9, 16, 18
2 Lent ID	TH-04a	FR-12, USE-05, SEC-13	5, 9, 16
3 Clone	TH-02, TH-06	SEC-01, SEC-13, SEC-18	6, 9
4 Replay	TH-03	SEC-04, NFR-14	6, 9
5 Visitor	TH-05	FR-10, FR-11, SEC-16, FR-13	13, 14, 15
6 Expired	TH-07	SEC-03	7
7 Revoked	TH-08	SEC-02, SEC-08, SEC-17	8
8 Reader	TH-16, TH-12	SEC-18, SEC-09, SEC-05	10
9 Database	TH-10, TH-15	SEC-14, PRIV-04, PRIV-11, SEC-10	19
10 Privilege	TH-09, TH-17	SEC-07, SEC-11, SEC-12, PRIV-06	17, 19

26. Credential Lifecycle

Diagram: 05_Workflows/Credential_Lifecycle.png (Appendix J, Figure J-4). Every transition is an authenticated, authorised, logged administrative or self-service action (SEC-12).

#	Stage	Trigger	Who	What happens	State after	Security controls	Usability notes
1	Issuance	Admission / joining; replacement request	Issuer (ID cell)	Identity confirmed against roster and documents (per institutional policy; SP 800-63A [1] as reference). A credential record is created and bound to the identity. For cards: a fresh per-card AES key is generated in the HSM, diversified from a master key with the card's serial, and written to the card in a secure personalisation step [3, 41]. For phones: an enrolment link/QR with a one-time code is issued. Validity period set (default: programme end + grace, configurable).	ISSUED (inactive)	Roster match required (FR-07); MFA for issuer (SEC-11); key never leaves HSM in clear (SEC-18); issuance logged (SEC-12)	Student does nothing for a card; phone enrolment ≤3 min (USE-07)
2	Activation	Card: first tap at any reader; or explicit activation by issuer. Phone: student completes enrolment (app generates key pair in hardware keystore, sends public key with one-time code).	Student / Issuer	Status becomes ACTIVE; for phone, public key stored; card first-tap activation prevents pre-issued cards in transit from being usable	ACTIVE	One-time code single-use, 24 h expiry; activation logged	First-tap activation is invisible to the student
3	Normal use	Every gate presentation	Student, Reader, Services	Authentication (challenge–response / token verify) → validity check → authorization → decision → log	ACTIVE	SEC-01..05, SEC-09, SEC-10	≤1.5 s (USE-01)
4	Temporary suspension	Disciplinary hold, unpaid dues, leave of absence, suspicious activity pending review	Issuer / Policy admin	Status → SUSPENDED; credential authenticates but authorization fails with DENY–REVOKED-class message (guard sees "Not permitted — Security Office"; reason not shown). Reversible: lifting suspension returns to ACTIVE.	SUSPENDED	Two-step confirm (SEC-11); logged with reason (SEC-12); pushed to gates (FR-08)	Student notified via app/e-mail with generic reason and contact
5	Lost / stolen report	Student reports via app/portal or in person	Student (self-service) / Issuer	Immediate revocation of that credential only (card or phone); other credentials of the same identity remain active; replacement request auto-created	REVOKED (that credential)	Self-service requires app login (phone unlock + account auth); irreversible (SEC-17); logged	Meher persona: seconds, from her phone, no queue (T4, screen 18)
6	Revocation	Lost/stolen; disciplinary; withdrawal; compromise of a card batch; key rotation	Student (own) / Issuer	Status → REVOKED permanently; credential ID added to revocation list; list re-signed and pushed to all readers; offline readers pick it up at next sync	REVOKED	Irreversible (SEC-17); ≤30 s online propagation (FR-08); signed list (SEC-19); logged	Guard sees "REVOKED — direct to Security Office" only (screen 8)
7	Replacement	After revocation, if the identity remains a member	Issuer	New credential issued (stage 1) with new key; old remains REVOKED; identity record unchanged	New: ISSUED → ACTIVE	Same as issuance	Replacement SLA is an institutional decision; app shows request status
8	Expiration	Validity end date reached	System (automatic)	Status → EXPIRED; authenticates but authorization fails with DENY–EXPIRED; distinct from revoked so the guard's next step is "renew at ID cell", not "Security Office"	EXPIRED	SEC-03; enforced server-side and in offline cache	App reminds 30/7/1 days before (USE-13)
9	Renewal	Programme extension, role change, continuing membership	Issuer	Validity extended on the same credential (no re-personalisation) if key and chip family are still approved; else replacement	ACTIVE	Roster check; logged	No student action for card
10	Retirement / deletion	Member leaves; credential revoked or expired beyond retention; chip family deprecated	System / Issuer	Credential record retained 1 year after revocation/expiry for fraud correlation (PRIV-05), then deleted; key material destroyed in HSM [3]; card physically collected or instructed to be destroyed; identity record retained per institutional records policy, not by this system	DELETED	Deletion logged; keys zeroised; chip-family deprecation triggers batch re-issuance (lesson from [8, 9])	Exit process includes card return

Key rotation. The master diversification key is rotated on a schedule (e.g., annually) or on suspected compromise; new cards use the new master; old cards continue to work until replaced because the HSM retains prior masters for verification only (SP 800-57 [3]). The revocation-list signing key and the token signing key are rotated on a schedule with overlap so readers hold both old and new public keys during transition.

27. Security Architecture

Phase 1 defines the model; Phase 2 implements it with standard libraries only (SEC-20). Diagram: `System_Architecture.png` (Figure J-13) shows components; this section explains the controls.

27.1 Authentication

Path	Mechanism	Standard	Phase 2 implementation note
Smart card	Reader ↔ card mutual authentication with per-card AES-128 key (three-pass challenge–response as in DESFire EV3 / Plus EV2 [41]); reader forwards proof to server or verifies locally with SAM/derived key	ISO/IEC 14443 [23]; AES	Use vendor SDK or libfreefare-class library; never read/accept UID alone (SEC-01). If a SAM is unavailable, the reader forwards the card's response to the server, which holds the diversification key in HSM.
Phone NFC (Android HCE)	Phone emulates a card; app holds an Ed25519 private key in hardware keystore; reader sends nonce; app signs (nonce readerID timestamp)	Ed25519 [38]; HCE	Android only in Phase 2; iOS card emulation not available to third-party apps without entitlements.
Dynamic QR	App displays a signed token {credential pseudonym, issued-at, expiry (30–60 s), nonce, gate hint} signed with the same Ed25519 key; reader camera decodes and verifies with the stored public key; server-side replay cache on token ID	JWT/CWT-style compact token [40]; TOTP concept [37]	Works offline at reader if public keys cached.
Visitor pass	Server-signed token {pass ID, host ID, window, gate set, use-count limit}; single/limited-use enforced server-side; offline readers accept once and reconcile	Ed25519 [38]	Delivered as QR image; printable at gate kiosk.
Administrator	Username + password (or SSO) + second factor (TOTP app or FIDO2 key); step-up confirm for high-impact ops	NIST 800-63B AAL2 [1]	Use institutional SSO if available.
Reader (as a client)	Mutual TLS with per-reader client certificate issued by the campus PKI; server certificate pinned on reader	TLS 1.3 [39]	Reader private key in secure element/TPM where hardware permits.

27.2 Authorization

Policy engine evaluates, for each authenticated principal P at gate G at time t:

```

status(P.credential) == ACTIVE                                -- else DENY-REVOKED / DENY-EXPIRED
AND role(P) in policy(G).allowed_roles
AND t within policy(G).allowed_windows[role(P)]
AND (P is visitor) => G in pass.gate_set AND t in pass.window AND pass.uses < limit
AND no active alert on P.credential (SEC-13)                  -- else DENY-SUSPICIOUS
=> ALLOW ; else DENY-NOT-AUTHORIZED

```

Policies are data (FR-18), versioned and logged. Default policy (secure default): a role with no explicit rule is denied. Authorization failure messages are distinct from authentication failure (USE-03).

27.3 Secure communication

All channels TLS 1.3 with mutual authentication (SEC-05). Decisions returned to readers are signed by the decision service so a rogue server or MITM cannot inject ALLOW (TH-12). Reader→server messages carry credential pseudonym, gate ID, nonce, response/token, timestamp; never name or photo. Server→reader/guard-tablet responses carry decision code, display name, photo URL with short-lived signed access, next-step code.

27.4 Key and secret management (concept, per NIST SP 800-57 [3])

Key	Purpose	Custody	Rotation	Never present on
Card master diversification key	Derive per-card AES keys	HSM only	Annual or on compromise; old masters retained for verify	Readers, DB, app
Per-card AES key	Card challenge–response	Card chip (write-once); derivable in HSM	Per card lifecycle	Readers (unless SAM), DB in clear
Phone credential key pair	Sign nonces/tokens	Private: phone hardware keystore; public: credential table	Per enrolment; revoke on device loss	Server (private)
Token / visitor pass signing key	Sign QR tokens and passes	HSM	Quarterly with overlap	Readers hold public only
Revocation-list signing key	Sign offline lists	HSM	Annual with overlap	Readers hold public only
Decision signing key	Sign ALLOW/DENY to readers	HSM/KMS	Quarterly	Readers hold public only

Key	Purpose	Custody	Rotation	Never present on
Reader client certs	Mutual TLS	Reader secure element	Annual; revoke on tamper	—
Log checkpoint signing key	Sign hash-chain checkpoints	HSM	Annual	—
DB encryption keys	At-rest encryption	KMS	Per KMS policy	App servers in clear

27.5 Least privilege and role-based access (SEC-07)

Six roles (Guard, Supervisor, Issuer, Approver, Auditor, Policy Admin) with the permission matrix in Section 21.1. Enforced at the API layer (not only in the UI). Separation of duties: Issuer $\cap$ Auditor = $\emptyset$; Policy Admin $\cap$ Guard = $\emptyset$. Service accounts for internal components have the minimum DB grants (auth service: read credential status; log service: append only; retention job: delete by age only).

27.6 Data minimisation and secure defaults

Schema contains only SEC-14 fields. Defaults: new gate policy denies all; new reader is disabled until certificate issued and policy assigned; logging on; retention 90 days; re-identification requires justification; guard display shows minimal set; offline max age $N = 4$ h; SEC-13 thresholds on.

27.7 Failure handling (summary; detail in Section 32)

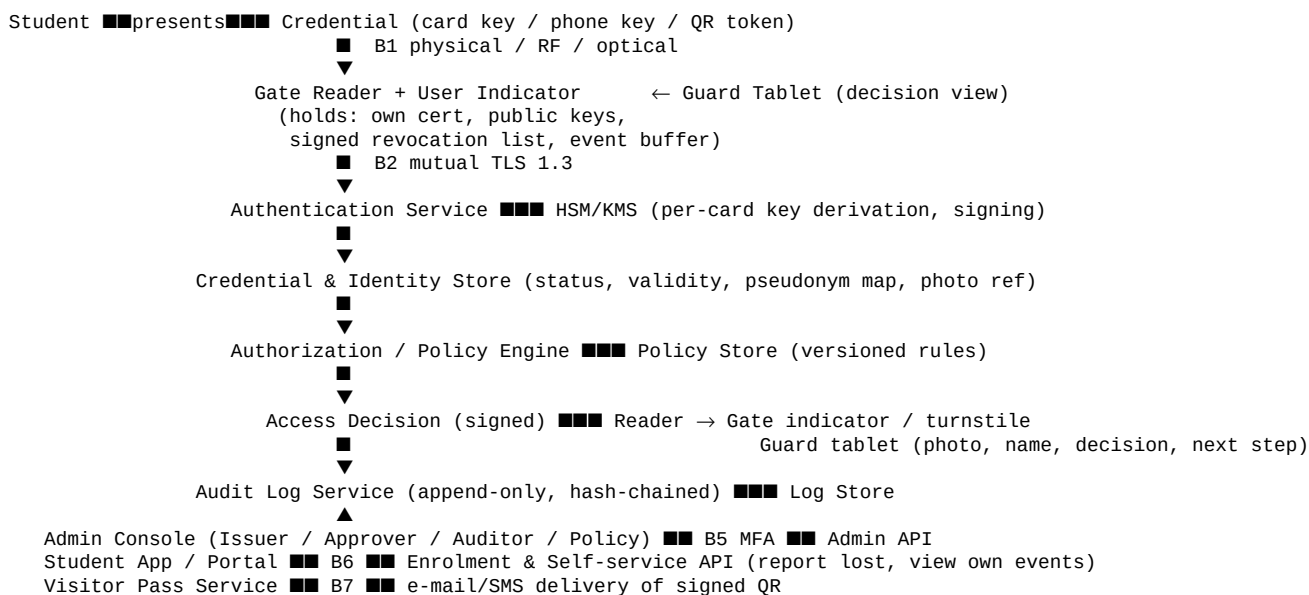
Ordered degradation: Online $\rightarrow$ Offline-verified (cached public keys + signed revocation list $\leq N$ h) $\rightarrow$ Manual Verification Mode (defined procedure, supervisor involvement, everything logged and flagged) $\rightarrow$ Emergency (egress always free; ingress by supervisor authorisation, logged). No state auto-allows.

27.8 Logging, monitoring, auditability

- Events: every decision (FR-06), every admin action (SEC-12), every mode change, tamper, certificate event, re-identification.
- Format: structured, pseudonymous, no secrets (SEC-06; OWASP [29]).
- Integrity: each record includes hash of previous; hourly checkpoint signed by HSM key; readers buffer locally and sync (SEC-10, SEC-15).
- Monitoring: SEC-13 anomaly rules; reader health; revocation-list age; clock drift (NFR-14); alerts to Supervisor (screen 16) and Auditor.
- Audit: Auditor tool verifies chain; re-identification workflow (PRIV-06).

28. System Architecture

Diagram: 05_Workflows/System_Architecture.png (Figure J-13). Conceptual components and the flow of a decision:



Sensitive data locations: identity fields and photo (Identity Store, photo store); keys (HSM; card chips; phone keystores); logs (Log Store); visitor contact (Visitor table, 30-day life).

Attack surfaces: reader housing and RF interface (B1); gate LAN (B2); service APIs (B3); admin console (B5); student app (B6); pass delivery channel (B7); HSM interface (B4).

Administrative access: only through Admin API behind MFA; no direct DB access for humans in production; all actions logged.

Security controls by component

Component	Controls
Reader	No master keys; signed firmware; tamper switch; mutual TLS; local verification only with signed material; event buffer encrypted; rate limiting
Guard tablet	Role-limited UI; no local storage of personal data beyond current decision; auto-clear; screen privacy hood
Auth service	Stateless verification; HSM for key ops; nonce store; replay cache
Identity/credential store	Encrypted at rest; least-privilege service accounts; pseudonym mapping in separate schema
Policy engine	Deny-by-default; versioned; changes logged
Log service	Append-only API; hash chain; signed checkpoints; retention job
Admin console	MFA; RBAC; step-up confirm; session timeout; CSRF/XSS protections per ASVS
Student app	Hardware keystore; root detection (Phase 2); TLS pinning; minimal local data

Privacy controls by component: minimal fields (store), pseudonymous logs (log service), role-filtered responses (API), retention job (log/visitor stores), transparency screens (app), justified re-identification (auditor tool).

29. Data Flow Diagram

Diagram: 05_Workflows/Data_Flow_Diagram.png (Figure J-10). Level-1 DFD with trust boundaries (dashed) and data stores.

External entities: Student, Guard, Visitor, Host, Administrator. Processes: P1 Present & Read Credential; P2 Authenticate; P3 Check Validity; P4 Authorize; P5 Decide & Signal; P6 Log Event; P7 Manage Credentials; P8 Manage Visitors; P9 Review Logs. Data stores: D1 Credential/Identity Store; D2 Policy Store; D3 Audit Log; D4 Visitor Passes; D5 Key Store (HSM); D6 Photo Store.

Flow	From → To	Data	Sensitivity	In transit protection	At rest
F1	Student → P1	Card response / signed token / QR image	Credential proof (not the key)	RF proximity; optical	—
F2	P1 → P2	{pseudonym, gate, nonce, response, method, ts}	Pseudonymous	mTLS 1.3	Reader buffer (encrypted) if offline
F3	P2 ↔ D5	Key derivation / signature verify request	Critical	Internal mTLS; HSM API	HSM
F4	P2 → P3 → P4	{identity ref, credential status, validity, role}	Personal (internal)	Internal	D1 encrypted
F5	P4 ↔ D2	Policy lookup	Integrity-critical	Internal	D2 versioned
F6	P5 → Reader / Guard tablet	{decision code, next-step code, display name, photo URL (signed, 60 s), role}	Personal (minimised)	mTLS 1.3	Not stored on tablet
F7	P5 → Student indicator	Colour/icon/short message	Non-personal	Local	—
F8	P5 → P6 → D3	{pseudonym, gate, ts, method, decision, guard ID if manual}	Personal (movement, pseudonymous)	Internal	Hash-chained, 90 d
F9	Admin → P7 → D1, D5	Issue/revoke/renew with reason	Personal + critical	mTLS + MFA session	D1, D5
F10	Host → P8 → D4 → Visitor	Pass request; signed QR	Personal (visitor)	mTLS; e-mail/SMS (channel risk noted)	D4, 30 d
F11	Auditor → P9 → D3 (+ D1 map on justified re-identify)	Query; results	Personal	mTLS + MFA	—
F12	Student → self-service → D1, D3 (own only)	Report lost; view own events	Personal (own)	TLS + app auth	—

Trust boundaries: B1 physical (Student/credential ↔ reader); B2 gate LAN (reader/tablet ↔ services); B3 service mesh; B4 HSM; B5 admin; B6 student app; B7 visitor delivery. Attack surfaces: every flow crossing a boundary (F1, F2, F6, F9, F10, F11, F12) plus the physical reader. Administrative flows: F9, F11; both MFA, both logged.

30. Privacy Data Flow

Diagram: 05_Workflows/Privacy_Data_Flow.png (Figure J-11). For each data item: why collected, who can access, where stored, retention, deletion.

Data item	Collected from	Why (purpose)	Who can access	Where stored	Retained	Deleted when / how
Full name, roll/employee no., programme/department	Roster at issuance	Bind credential to a member; issuer verification	Issuer; Auditor on justified re-identify; student (own)	D1 (encrypted)	While member + credential retention	Member leaves → after 1-year revoked-credential retention; automated, logged
Display (first) name	Derived from roster	Guard's confirmation of identity in a human-readable way	Guard (on tap), Supervisor, Issuer, student	D1	As above	As above
Photo	Roster / issuance capture	Human face check (the control against borrowing and relay)	Guard (on tap only, 60 s signed URL), Issuer, student	D6 (separate store)	As above	As above
Role	Roster	Authorization	All roles (as decision input)	D1	As above	As above
Credential ID / pseudonym	Generated at issuance	Authenticate; pseudonymous logging	System; Issuer; Auditor	D1 (mapping in separate schema)	Credential lifecycle + 1 y	Automated
Per-card key / phone public key	Generated at issuance/enrolment	Authentication	HSM only / system	D5 / D1	Credential lifecycle	Zeroised on deletion
Validity, status, revocation reason	Issuer actions	Validity/authorization; audit of lifecycle	Issuer; Auditor; student (own, generic reason); not guard	D1	Credential lifecycle + 1 y	Automated
Access events (pseudonym, gate, time, method, decision)	Each presentation	Access decision audit; incident investigation; anomaly detection	Auditor (pseudonymous); Supervisor (gate counts); student (own)	D3 (hash-chained)	90 days; flagged events until case closed + 1 y	Scheduled purge, itself logged
Manual-mode decision records (+ guard ID)	Manual Verification Mode	Accountability for fallback decisions	Supervisor, Auditor	D3	As flagged events	As above
Re-identification records (who, when, why, which entry)	Auditor action	Accountability for look-ups	Second administrator; Auditor	D3	1 y	Automated
Visitor name, host, purpose category, window, gate set	Host request	Issue and check pass; guard confirmation	Approver; Guard (name + host only); Auditor	D4	Visit + 30 days	Automated
Visitor contact (e-mail/phone)	Host request	Deliver pass only	Approver/system for delivery only; not guard	D4	Until pass delivered + visit window	Automated at visit end
Guard/admin identity	Institutional accounts	Attribution of actions	Supervisor, Auditor	Institutional IdP + D3	Employment + audit retention	Per institutional policy

Not collected at all: phone numbers of students, home addresses, emergency contacts, hostel, vehicle numbers (unless a separate vehicle-gate design is added later with its own analysis), biometric templates, exit events (exit is not controlled in this design).

Data minimisation applied: the guard decision needs a face and a status; everything else has been removed from the guard path. The log needs to answer "which credential passed which gate when, and what was decided"; it does not need a name, so it does not hold one.

31. Workflows

Full diagrams are in Appendix J (`05_workflows/*.png`). Textual specifications follow; each is the source for the corresponding diagram and prototype screens.

31.1 Overall system (Figure J-1)

Student/Visitor → Present credential → Reader → Authenticate → Validity → Authorize → Decision → {Gate indicator, Guard tablet} → Log. Side flows: Admin lifecycle → Store; Host → Visitor pass; Student self-service → Store/Log; Offline sync of signed lists to readers.

31.2 Student authentication (Figure J-2)

1. Reader idle (screen 1).
2. Tap/scan (screen 2).
3. Reader: card → nonce challenge, get response; phone/QR → obtain signed token.
4. "Verifying" (screen 3, ≤ 1 s).
5. Online: send F2 to Auth Service; offline: verify locally.
6. Authenticated? No → DENY–NOT RECOGNISED (screen 6) → log. Yes → 7.
7. Validity: expired → screen 7; revoked/suspended → screen 8; alert flag → screen 9.
8. Authorize: role/gate/time → not allowed → DENY–NOT AUTHORIZED (screen 6 variant "Not permitted at this gate/time") ; allowed → 9.
9. ALLOW: user indicator green + tone (screen 4); guard tablet photo + name + ALLOW (screen 5).
10. Guard glances; Mismatch → DENY–SUSPICIOUS, flagged.
11. Log event.
12. Auto-clear after pass/5 s (USE-12).

31.3 Authentication vs authorization (Figure J-3)

Two-lane diagram: Lane A "Who is this credential bound to?" (crypto → identity ref) and Lane B "Is this principal allowed here now?" (status, role, gate, time, alerts). Failure in A → "NOT RECOGNISED" (no identity known; guard cannot help; direct to Security Office). Failure in B → identity is known; message names the authorization reason (expired / revoked / not this gate / suspicious) and the specific next step.

31.4 Credential lifecycle (Figure J-4)

State machine per Section 26: ISSUED → ACTIVE ↔ SUSPENDED; ACTIVE → EXPIRED → (renew) ACTIVE; ACTIVE/SUSPENDED/EXPIRED → REVOKED (irreversible) → REPLACED (new credential) ; REVOKED/EXPIRED → DELETED after retention.

31.5 Visitor access (Figure J-5)

Host request → Approver (or auto-policy) → Signed pass issued → Delivered → Gate: scan → verify signature, window, gate set, use count → guard sees "VISITOR · name · Host" → ALLOW → host notified → pass consumed/expired → record purged at +30 d. Branch: no pass at gate → guard "Visitor without approval" → host lookup → host approves on phone (or declines) → pass issued at kiosk / to visitor phone → scan. No approval → no entry; script shown.

31.6 Lost ID (Figure J-6)

Student notices loss → App "Report lost/stolen" → confirm → card REVOKED immediately → list pushed → replacement request opened → student continues with phone credential → Issuer issues new card → student collects (identity check) → new card ACTIVE on first tap. Branch: attacker taps lost card before/after report (Scenario 1).

31.7 Authentication failure (Figure J-7 in Appendix; file `Failure_Workflow.png`)

Any DENY → user indicator red + short message; guard tablet: decision + reason class + next step; guard options: [Direct to Security Office] (default), [Call supervisor], [Mismatch] (on ALLOW only). No [Allow anyway]. Event logged; repeated failures → SEC-13 escalation.

31.8 Network / device failure (Figure J-8)

Reader heartbeat lost → Offline-verified mode (status bar amber, list age shown) → continue while list age $\leq N$ → if list age $> N$ or reader hardware fault → Manual Verification Mode (screen 12): guard tablet (if online) or paper form records: credential type presented, visual photo check result, supervisor approval ID; all flagged; when connectivity returns, buffered events sync and supervisor reviews manual entries.

31.9 Threat model (Figure J-9)

Attack tree: root "Unauthorised entry" → branches: possess valid credential (steal, borrow, relay), forge credential (clone weak tech, fake), exploit lifecycle (expired, revoked, ghost issuance), exploit infrastructure (rogue server, reader compromise, DoS→manual), exploit human (coerce/collude guard, social-engineer visitor path). Leaves annotated with controlling requirement IDs.

31.10 Data flow (Figure J-10) and 31.11 Privacy data flow (Figure J-11)

As specified in Sections 29 and 30.

31.12 Admin credential management (Figure J-12)

Admin login (MFA) → role check → Issue: roster search → identity verification → key personalisation → validity → confirm → log. Revoke: search → select → reason → two-step confirm → propagate → log. Renew/Suspend/Lift: similar with confirm. Every path ends in the audit log.

32. Failure Handling and Edge Cases

Principle: no failure path opens the gate. Fallbacks preserve authentication (a human check against server data, not the card) and preserve auditability (every manual decision is attributed and flagged). Convenience is provided by redundant credentials (card + phone), not by bypasses.

Case	Detection	System behaviour	Guard behaviour (script on screen)	Student/visitor experience	What is logged	Requirement
Lost ID	Student report; or tap after revocation	Immediate revocation of that card; phone credential unaffected	If lost card tapped: "REVOKED — direct to Security Office"; do not admit	Reports from phone in seconds; enters with phone credential; collects replacement later	Revocation (who/when); any tap of revoked card (flagged)	FR-09, SEC-17
Forgotten ID	Student has no card	Student uses enrolled phone credential (NFC or dynamic QR): same authentication strength	Nothing different; result screen identical	~3 s (unlock + open app) instead of 1 s	Method = phone	FR-01, D1
Forgotten ID and no phone credential	Student has neither	System offers no bypass. Options: (a) student goes to Security Office where an Issuer-role staff member verifies identity against roster + photo and issues a one-day temporary credential (a signed QR pass bound to the student's identity, valid until midnight, logged); (b) student waits for a friend to bring the card (not a system function)	"NOT RECOGNISED / no credential — direct to Security Office for a temporary pass. Do not admit."	Detour to office; dignified, defined, same for everyone	Temporary pass issuance (Issuer ID, student ID, expiry)	FR-13, SEC-16 (reused for temp pass)
Expired ID	Validity check	DENY—EXPIRED; authentication succeeded so identity is known	"EXPIRED — renew at ID cell. Do not admit." Option: [Call supervisor] if student claims active status	Told exactly what to do; app shows renewal status	Event, decision code	SEC-03, screen 7
Revoked ID	Status check	DENY—REVOKED	"REVOKED — direct to Security Office. Do not admit." Reason not shown	Generic message; office explains privately	Flagged event	SEC-02, SEC-08, screen 8
Fake ID	Fails cryptographic authentication	DENY—NOT RECOGNISED	"NOT RECOGNISED — this is not a valid campus credential. Do not admit. If person insists, [Call supervisor]."	Cannot argue with a visual judgement because none was made	Event; SEC-13 counter incremented	SEC-01, screen 6
Another person's ID	Genuine credential; face ≠ photo	ALLOW returned; guard presses [Mismatch] → DENY—SUSPICIOUS	Compare face to photo every time; Mismatch button	Denied; told to visit Security Office	Flagged event with guard ID	FR-12, USE-05, screen 16
Reader failure (hardware, tamper)	Heartbeat/self-test fails; tamper switch	Reader disabled; lane closed; if second lane exists, redirect; else Manual Verification Mode	Screen 10: "Reader offline — use lane 2" or "Manual mode — follow procedure"	Redirected or manual check	Reader fault event; manual decisions flagged	SEC-18, FR-14, screen 10
QR failure (glare, cracked screen, expired token)	Camera cannot decode / token stale	Prompt to regenerate token / tilt screen; after 2 failures suggest card or NFC	Screen 2 hint	Regenerate; or tap card	Attempts logged	USE-04
RFID/NFC failure (card damaged, phone NFC off)	No response / protocol error	Prompt to retry / use QR fallback	Screen 2 hint	Retry or switch method	Attempts logged	USE-04
Network outage	Heartbeat lost	Offline-verified mode: local crypto verification with cached public keys; revocation list age displayed; continue while ≤ N h	Screen 11 status amber: "Offline — list 1 h 20 m old. Normal checks continue."	No visible change	Events buffered, synced later with offline flag	SEC-19, FR-14, screen 11
Database outage (network up)	Auth service returns unavailable	Same as offline-verified mode at the reader	Same	Same	Same	SEC-19

Case	Detection	System behaviour	Guard behaviour (script on screen)	Student/visitor experience	What is logged	Requirement
Prolonged outage (> N h) or no cached material	List age exceeds N	Manual Verification Mode: guard tablet (or paper form) records credential shown, photo check outcome (against printed card photo, weakest control, acknowledged), supervisor approval for each admission or per-batch for peak; entries flagged	Screen 12: step list; [Request supervisor approval]	Slower; supervisor present	Every manual decision: guard ID, supervisor ID, time, credential type	FR-14, FR-19, screen 12
Device / power failure at gate	Tablet/reader dead	Battery backup (NFR-03) for a defined period; then Manual Verification Mode with paper form (pre-printed, serial-numbered) transcribed later	Paper procedure card at every gate	Manual	Transcribed and flagged	FR-14, FR-19
Visitor without approval	No pass	Guard initiates host lookup; host approves/declines on phone; pass issued to visitor phone or printed	Screen 13 → 14 → 15	Waits for host; if declined, not admitted	Request, approval, pass	FR-10, SEC-16
Emergency entry (ambulance, fire, police)	Supervisor or declaration	Egress barriers always free (life safety). Ingress: supervisor authorises via tablet [Emergency ingress] with reason; gate held open for the duration; every entry during emergency logged as "emergency mode"; mode ends by supervisor action and is reviewed	Screen 12 emergency variant	—	Emergency start/end, supervisor ID, reason	FR-20
Suspicious repeated attempts	SEC-13 threshold	DENY–SUSPICIOUS for the credential/reader; supervisor alert; reader rate-limit	Screen 9: "Suspicious activity — do not admit; supervisor alerted"	Denied; told to contact Security Office	Flagged events; alert	SEC-13, screen 9
Guard tries to override DENY	UI has no such control	Not possible at the gate; supervisor-approved manual entry is the only path and is flagged	—	—	Attempt would appear only as a manual entry with supervisor ID	FR-13, TH-17

Explicitly rejected "convenient" fallbacks: "Allow anyway" button for guards; accepting a photo of a QR code; accepting bare card UID when the server is unreachable; auto-open on power failure; guard entering a student's roll number to look them up (would recreate the interrogation and leak data). Each of these would undo one of SEC-01, SEC-09, SEC-08 or FR-13.

33. Design Principles

Adopted from Saltzer & Schroeder [14], Yee [13], Nielsen [15], Cavoukian [27] and the usable-security literature [10, 11, 17]. Each principle names where it is applied.

#	Principle	Source	Applied in
DP-1	Authenticate the key, not the artefact. Accept only proof of possession of a secret the credential never reveals.	[2, 14] complete mediation; [4–9]	SEC-01, SEC-04, D1
DP-2	Authentication and authorization are separate decisions with separate messages.	[1, 14]	FR-04, FR-05, USE-03, screens 6 vs 7–9
DP-3	Fail secure, degrade gracefully. Every failure ends in DENY or a defined, audited manual mode; never in an open gate.	[14] fail-safe defaults	SEC-09, SEC-19, FR-14, Section 32
DP-4	Path of least resistance is the secure path. The authenticated tap must be faster than today's glance. Convenience comes from redundant credentials, not bypasses.	[13] Yee; [11] Herley; [17] compliance budget	USE-01, D1 (phone credential), rejected fallbacks in Sec 32
DP-5	Least privilege and separation of duties for every human and service role.	[14]	SEC-07, Section 21.1
DP-6	Minimise: collect, show and keep only what the decision needs.	[22, 26, 27]	SEC-08, SEC-14, PRIV-01..05, PRIV-10
DP-7	Make security state visible to the operator. Online/offline, list age, alerts, decision and reason are always on screen.	[13] visibility; [15] #1	USE-06, screen 16 status bar
DP-8	Plain language, one glance, one next step. Guard messages are bilingual, non-technical, and always end with an action.	[12, 16]; [15] #9	USE-02, USE-04, USE-05
DP-9	Reversibility where safe, irreversibility where necessary. Admin actions confirm before applying; revocation is irreversible by design.	[13] revocability; [15] #3, #5	USE-10, SEC-17
DP-10	Open design. Only keys are secret; standard primitives and libraries only.	[14] open design	SEC-20
DP-11	Accountability without surveillance. Everything is logged; logs are pseudonymous; re-identification is justified and itself logged.	[22, 26]	SEC-10, PRIV-04, PRIV-06
DP-12	Accessible by default. Multimodal feedback; reachable hardware; no colour-only signals.	[28]	USE-08, USE-09, USE-14
DP-13	Dignity on denial. A denied person is told what to do next, privately, without being interrogated in front of a queue.	Meher persona; [10]	PRIV-10, USE-13, user-facing screens 6–9

34. Design Decisions

Decision matrix. "User evidence" cites primary data where it exists; until fieldwork is complete those cells read [DATA REQUIRED] and the decision rests on the other columns plus labelled assumptions.

ID	Decision	Options considered	User evidence	Security implication	Privacy implication	Usability implication	Feasibility	Final direction (provisional)
D1	Primary credential technology	(a) Static QR; (b) LF RFID; (c) AES smart card; (d) NFC phone only; (e) Dynamic QR only; (f) Hybrid card + optional phone (NFC/dynamic QR)	Q16 preference, Q17 phone capability, Q18 accessibility, observation timing [DATA REQUIRED]	(a),(b) fail SEC-01 (copyable). (c) strongest single option; single-factor. (d) two-factor via unlock but excludes non-phone users. (e) replay within window; slow. (f) baseline strength of (c), convenience of (d)/(e)	(b) fixed UID trackable; (c) random-UID chips available; (d)/(e) pseudonymous tokens	(c) fastest, most accessible, but card retrieval (H1); (d) phone in hand; (e) slowest	(c) moderate cost; (d) iOS restriction; (e) trivial; (f) most Phase 2 work	(f) Hybrid: AES smart card for everyone; optional phone credential (Android NFC or dynamic QR); visitor signed QR. Revisit after Q16/Q17.
D2	Manual fallback when infrastructure fails	(a) Guard visual check + admit ("allow anyway"); (b) Gate closed until restored; (c) Offline verified mode with bounded staleness, then supervised manual mode with logging	B Q10, observation of current fallbacks [DATA REQUIRED]	(a) recreates today's weakness and invites DoS→bypass (TH-14). (b) DoS = campus closed. (c) bounded risk, full accountability	(c) manual records hold guard/supervisor IDs; acceptable	(a) fastest; (b) unacceptable; (c) slower only in rare prolonged outage	(c) needs local storage and sync; moderate	(c) Offline-verified ≤ N h → supervised Manual Verification Mode; no "allow anyway" control exists.
D3	Information shown to guard	(a) Full record (name, roll, dept, hostel, phone); (b) Photo + full name + roll no.; (c) Photo + first name + role + decision + next step; (d) Decision only, no photo	B Q11/Q12, Q14c [DATA REQUIRED]	(d) removes the human check against borrowing/relay (TH-04). (a)/(b) make guard a data-exposure vector (TH-13)	(a) worst; (c) minimal set that still supports the decision; (d) best privacy but weakens security	(c) one glance; (a) clutter slows decision	All feasible	(c). Photo from server, not card. Roll no. never shown (guard has no use for it).
D4	Visitor authentication	(a) Paper register; (b) Guard enters visitor details on tablet; (c) Host pre-approval → signed time/gate-bound QR pass; (d) Visitor self-registration kiosk without host	B Q9, observation H6 [DATA REQUIRED]	(a)/(b) no authentication of the visitor's claim; (d) anyone can self-approve; (c) authenticates the approval, binds it to window and gate	(a) exposes previous visitors' data; (b) guard holds contact data; (c) guard sees name + host only, contact used for delivery only	(c) ≤10 s at gate if pre-approved; unapproved path needs host response	(c) needs host app/portal and notification; moderate	(c), with gate-initiated host approval for walk-ins. No paper register.
D5	Logging	(a) No logs (privacy-maximal); (b) Full identified logs; (c) Pseudonymous logs, separate mapping, justified re-identification, fixed retention	Q14a, Q14b, Q15b [DATA REQUIRED]	(a) no incident response, no anomaly detection (TH-15). (b) surveillance dataset; breach impact high (TH-10, TH-13). (c) both goals	(c) minimises movement-data exposure; DPDP alignment [22]	(c) auditor workflow slightly slower (justification step)	(c) moderate	(c) with 90-day retention, hash-chained integrity, student self-view.
D6	Credential revocation	(a) Issuer-only, office hours; (b) Self-service immediate + issuer; (c) Self-service with 24 h "undo"	Q9, Q10 [DATA REQUIRED]	(a) leaves lost card live for hours/days (TH-01). (c) undo creates ambiguity and a social-engineering path. (b) closes window fastest and is unambiguous	(b) student controls own credential	(b) seconds from phone; replacement still needed	(b) easy	(b) Self-service immediate, irreversible; replacement issued instead of un-revoke.
D7	Failure handling behaviour	(a) Fail-open on any error (availability first); (b) Fail-closed with no fallback; (c) Ordered degradation: online → offline-verified → manual supervised → emergency egress-only	B Q10 [DATA REQUIRED]	(a) any fault = free entry (TH-14, TH-16). (b) availability failure. (c) each stage keeps a defined level of authentication and full logging	(c) manual records contain more human attribution; acceptable	(c) only prolonged outage is slow	(c) moderate	(c) with N = 4 h default (configurable), emergency egress never blocked.
D8	Authentication vs authorization messaging	(a) Single "Denied"; (b) Technical codes; (c) Two classes with plain-language reason and role-specific detail	B Q13 training, Q19 expectations [DATA REQUIRED]	(c) lets guard respond correctly (revoked ≠ fake ≠ expired); prevents guards "helping" a NOT RECOGNISED case	(c) reason for revocation withheld from guard	(c) requires ≤15 min training (USE-02)	Easy	(c)
D9	Handling forgotten card without phone credential	(a) Guard admits on verbal identity; (b) Refuse until card produced; (c) Security Office issues one-day signed temporary pass after roster + photo verification	Q7, Q19 [DATA REQUIRED]	(a) social-engineering path (TH-04). (b) strands legitimate students; pressure to bypass. (c) authentication moves to a trained issuer with server data; pass is bounded	(c) no public interrogation	(c) detour but defined and dignified	(c) reuses visitor-pass machinery	(c)

ID	Decision	Options considered	User evidence	Security implication	Privacy implication	Usability implication	Feasibility	Final direction (provisional)
D10	Phone credential platform	(a) Android HCE + iOS QR; (b) QR-only on both; (c) Native wallet passes (Apple/Google)	Q17 [DATA REQUIRED]	(a) NFC where possible, QR elsewhere; (c) strongest but requires platform partnership	Similar	(a) mixed experience; (c) best	(c) infeasible for a course project; (a) feasible	(a) for Phase 2; (c) noted as future direction

35. Prototype

35.1 Overview

Lo-fi, greyscale wireframes suitable for import into Figma. Three surfaces: Gate user indicator (small display or LED + text facing the person, portrait phone-sized), Guard tablet (landscape 10"), Admin / student web and app (desktop or phone). Files: 06_Prototype/Prototype_Screens.pdf (all 20 screens) and 06_Prototype/screens/S01..S20.png. Figma import instructions in 06_Prototype/Figma_Prototype_Instructions.pdf.

Conventions: status colours are always paired with an icon and a word (USE-08); Hindi labels appear under English on guard/user screens (shown as "[HI]" in wireframes to keep them legible; final copy to be translated); every DENY screen has a "Next step" block; no guard screen has an "Allow" control.

35.2 Screen specifications

S01 — Welcome / Gate Authentication (user indicator, idle)

- Purpose: Tell the approaching person what to do and show the lane is working.
- UI elements: Large icon of card/phone tapping; text "Tap card or phone / [HI]"; small QR camera indicator "or show app QR"; status dot (green = ready, amber = offline mode, grey = lane closed).
- Buttons: none (no touch on user side).
- Information shown: instruction; lane status.
- Deliberately hidden: any previous person's result; system internals.
- User action: approach and tap.
- System response: transitions to S02/S03 on read.
- Security: idle screen reveals nothing; lane-closed state prevents use of a disabled reader (SEC-18).
- Privacy: no data.
- Usability: recognisable affordance; USE-14 reader height note in spec; USE-09 contrast.

S02 — Scan / Tap ID (user indicator, reading)

- Purpose: Confirm the reader has detected a credential and guide correct positioning.
- UI: Animated ring around tap zone; text "Hold still..."; for QR: camera frame with "Align code / tilt to avoid glare"; hint after 2 failures: "Try card or NFC".
- Buttons: none.
- Shown: method detected (card / phone / QR icon).
- Hidden: credential ID.
- User action: hold.
- System response: → S03.
- Security: nonce challenge starts here; nothing accepted without completion (SEC-01).
- Privacy: none.
- Usability: error prevention hints (USE-04); retry without reset (USE-12).

S03 — Authentication in progress (user indicator + guard tablet strip)

- Purpose: Cover the ≤1 s verification with clear status so people don't re-tap.
- UI: Spinner + "Verifying..."; guard tablet shows thin progress strip.
- Buttons: none.
- Shown: progress only.
- Hidden: which step (authn vs authz) is running; identity.
- System response: → S04/S05 or S06–S09.
- Security: timeout → DENY–NOT RECOGNISED, never ALLOW (SEC-09).
- Privacy: none.
- Usability: Nielsen #1; if > 2 s show "Taking longer than usual" (USE-06).

S04 — Authentication success (user indicator)

- Purpose: Tell the person they may proceed.
- UI: Full green background, large ✓, "Welcome — go ahead / [HI]"; short tone; auto-clear on pass or 5 s.
- Shown: result only. Hidden: name (bystanders), any identity data (PRIV-10).
- User action: walk through.
- System response: logs event; guard tablet shows S05 simultaneously.
- Security: ALLOW shown to user only after both authn and authz pass (FR-05).
- Privacy: no name on user side.
- Usability: colour + icon + tone (USE-08).

S05 — Authorization success (guard tablet)

- Purpose: Let the guard confirm the face in one glance.
- UI: Left 40%: photo on file (large). Right: "ALLOWED ✓" (green band, 24 pt), first name, role chip ("Student"), gate + time small; bottom-right large secondary button [Mismatch X]; status bar (online, list age, alerts).
- Buttons: [Mismatch] only. No [Allow].
- Shown: photo, first name, role, decision. Hidden: full name, roll no., programme, hostel, phone, method used, credential ID (SEC-08).
- Guard action: glance; press Mismatch if face differs.
- System response: Mismatch → DENY–SUSPICIOUS, flag with guard ID, user indicator turns red (S09).
- Security: server photo defeats printed-photo forgery; Mismatch is the anti-relay/anti-borrowing control (FR-12, TH-04).
- Privacy: minimal set (PRIV-03); photo URL expires in 60 s; screen auto-clears.
- Usability: photo-first layout; one word status; USE-05; Mismatch is large but requires confirm-tap to avoid accidental denial (USE-10).

S06 — Access denied: not recognised (guard tablet + user indicator)

- Purpose: Authentication failed; nothing is known about this person.
- Guard UI: Red band "NOT RECOGNISED X"; body: "This is not a valid campus credential." Next step: "Do not admit. Direct the person to the Security Office. If they insist: [Call supervisor]". Buttons: [Call supervisor], [Done].
- User UI: Red X, "Not accepted — please visit the Security Office / [HI]". No reason.
- Shown: decision class, next step. Hidden: any identity (none exists), technical error code (available to auditor only).
- Security: fake/cloned/replayed credentials all land here (SEC-01, SEC-04); guard is never asked to judge authenticity; SEC-13 counter increments.
- Privacy: user message gives no bystander information.
- Usability: USE-03 (distinct from authz failures), USE-04 (next step), USE-11 (script on screen).
- Variant S06b — Not authorized here/now: amber band "NOT PERMITTED AT THIS GATE/TIME"; photo + first name shown (identity known); next step: "Direct to [permitted gate] or Security Office."

S07 — Credential expired (guard tablet + user indicator)

- Purpose: Identity known; validity lapsed.
- Guard UI: Amber band "EXPIRED"; photo + first name + role; "Credential validity ended." Next step: "Do not admit. Direct to ID cell for renewal. If the person says they are a current member: [Call supervisor]". Buttons: [Call supervisor], [Done].
- User UI: Amber !, "Credential expired — please renew at the ID cell / [HI]".
- Hidden: exact expiry date on user side (bystanders); roll no.
- Security: SEC-03; authn passed so photo is shown to help the guard direct the right person.
- Privacy: minimal.
- Usability: different colour and next step from S06 and S08 (USE-03).

S08 — Credential revoked (guard tablet + user indicator)

- Purpose: Identity known; credential revoked or suspended.
- Guard UI: Red band "REVOKED"; photo + first name; "This credential has been revoked." Next step: "Do not admit. Direct to Security Office." Buttons: [Call supervisor], [Done]. Event auto-flagged.
- User UI: Red X, "Not accepted — please visit the Security Office / [HI]" (same wording as S06 to bystanders).
- Hidden: reason for revocation (SEC-08); whether it was lost vs disciplinary.
- Security: SEC-02; flag supports Scenario 1/7 investigation.
- Privacy: reason withheld protects the student from stigma.
- Usability: guard needs no judgement; DP-13 dignity.

S09 — Suspicious credential (guard tablet + user indicator)

- Purpose: SEC-13 escalation or guard Mismatch.
- Guard UI: Red band "SUSPICIOUS — SUPERVISOR ALERTED"; if identity known: photo + first name; text: "Repeated failed attempts / face mismatch recorded." Next step: "Do not admit. Keep the person at the gate if safe. Supervisor has been notified." Buttons: [Call supervisor] (pre-dialled), [Done].
- User UI: Red X, "Not accepted — please wait for security staff / [HI]"
- Hidden: which rule triggered; thresholds.
- Security: TH-02, TH-04, TH-06 detection path; reader rate-limited.
- Privacy: minimal.
- Usability: guard is told an alert has already gone out (reduces burden); safety wording.

S10 — Reader failure (guard tablet)

- Purpose: Hardware fault or tamper.
- UI: Grey/amber band "READER OFFLINE — Lane 1"; cause class (self-test failed / tamper detected / no power); Next step: "Direct people to Lane 2" or, if no other lane, "Start Manual Verification Mode" [button, supervisor PIN required]. Status bar shows reader health.
- Hidden: technical diagnostics (auditor).
- Security: reader disabled server-side; tamper logged (SEC-18); manual mode requires supervisor (FR-19).
- Privacy: none.
- Usability: USE-06 visibility; clear alternative.

S11 — Network failure (guard tablet)

- Purpose: Show offline-verified mode and its bounded validity.
- UI: Status bar amber "OFFLINE — verifying locally. Revocation list age: 1 h 20 m (limit 4 h)". Main area unchanged (S05-style results continue). If age > limit: modal "Offline limit reached — Manual Verification Mode required" [Start manual mode — supervisor PIN].
- Hidden: server details.
- Security: SEC-19; countdown makes staleness visible; automatic transition to manual when limit exceeded.
- Privacy: none.
- Usability: guards keep working normally; only the bar changes.

S12 — Manual verification / fallback (guard tablet)

- Purpose: Defined procedure when electronic verification is impossible.
- UI: Header "MANUAL VERIFICATION MODE — all entries are recorded and reviewed"; step list: 1. Ask for card or app screen. 2. Compare face with card photo. 3. Select credential type shown [Card] [Phone] [None]. 4. Photo check result [Matches] [Does not match]. 5. [Request supervisor approval] → supervisor enters PIN on tablet (or approves batch for peak). 6. Result: "Admit" or "Do not admit". Emergency variant: [Emergency ingress] (supervisor-only) with reason field.
- Buttons: as listed; no free-text personal data entry.
- Shown: procedure; supervisor approval state. Hidden: any lookup of student records (deliberately unavailable: DP-6).

- Security: weakest mode, so every decision carries guard + supervisor IDs and is flagged (FR-19, TH-17); no roster lookup prevents data exposure and interrogation; egress always free (FR-20).
- Privacy: no personal data typed; record holds only credential type and outcome.
- Usability: USE-11 recognition; paper fallback mirrors these steps.

S13 — Visitor registration (host web/app; guard tablet variant for walk-ins)

- Purpose: Host requests a pass.
- UI: Form: visitor name; purpose category (dropdown: academic / official / personal / vendor); date; time window; gate(s) (checkboxes); delivery channel (e-mail or phone, used only to send the pass — inline notice). [Submit request].
- Guard variant ("Visitor without approval"): host search by name/department → [Send approval request to host]; waiting state; no visitor data entered by guard except name.
- Hidden: visitor contact on guard variant (PRIV-09).
- Security: request authenticated as the host (SSO); FR-10.
- Privacy: purpose is a category, not free text; contact used for delivery only; retention notice shown.
- Usability: ≤1 min for host; walk-in path needs no typing beyond host name.

S14 — Visitor approval (approver or host phone)

- Purpose: Approve/decline a pass request.
- UI: Card: visitor name, purpose category, window, gates, requester. [Approve] [Decline] [Edit window]. Auto-approval note if policy allows hosts to self-approve for some categories.
- Hidden: visitor contact (not needed to decide).
- Security: MFA session for approver role; decision logged (SEC-12).
- Privacy: minimal.
- Usability: one-tap on phone; walk-in requests appear as push notification.

S15 — Temporary visitor credential (visitor phone / printed slip)

- Purpose: The pass itself.
- UI: QR code (large); "VISITOR PASS"; visitor first name; host name; "Valid: 1 Oct 2026, 14:00–17:00"; "Gate: Main"; "Single entry"; footer: "Show this at the gate. Do not forward. Data deleted 30 days after visit."
- Hidden: pass ID in human-readable form; host contact.
- Security: server-signed token; window, gate set, use-count embedded (SEC-16); QR contains no personal data beyond first name (which is displayed anyway).
- Privacy: retention notice (PRIV-07).
- Usability: works printed or on screen; large QR for outdoor scanning.

S16 — Security guard dashboard (guard tablet, home)

- Purpose: Between taps: lane status, alerts, quick actions.
- UI: Status bar (online/offline, list age, reader health, time); tiles: "Waiting for tap"; alerts list (supervisor-acknowledged state); quick actions [Visitor without approval] [Call supervisor] [Report reader problem]; today's gate count (aggregate number only).
- Hidden: any list of who has entered (guards do not need it; PRIV-03); names in alerts (pseudonym + photo only when the person is at the gate).
- Security: role-limited (SEC-07); no search function.
- Privacy: aggregate counts only.
- Usability: USE-06; large touch targets for outdoor use.

S17 — Admin credential management (issuer console)

- Purpose: Issue, renew, suspend, revoke.
- UI: MFA badge in header; roster search (name/roll); identity card showing only SEC-14 fields (name, roll, programme, photo, role); credential list per identity with status chips (ACTIVE / SUSPENDED / EXPIRED / REVOKED) and validity dates; actions per credential: [Renew] [Suspend] [Revoke]; identity-level: [Issue new card] [Send phone enrolment]. Every action opens a confirm dialog stating exact effect and requiring a reason

(dropdown).

- Hidden: keys (never displayed; only "key present in HSM"); entry logs (different role); other admins' actions (auditor).
- Security: SEC-07, SEC-11, SEC-12; roster match required to issue (FR-07).
- Privacy: no phone/address fields exist to display (PRIV-01).
- Usability: recognition over recall (roster search, not typed IDs) (USE-11); USE-10 confirms.

S18 — Lost ID / revoke credential (student app; issuer variant)

- Purpose: Self-service immediate revocation.
- Student UI: "My credentials": Card1234 [ACTIVE], Phone (this device) [ACTIVE]. Tap card → [Report lost or stolen]. Confirm sheet: "This will permanently disable your card. Your phone credential keeps working. A replacement request will be created. This cannot be undone." [Report and disable] [Cancel]. Result: card [REVOKED], "Replacement requested — status: pending. Collect at ID cell with a photo ID."
- Issuer variant: same action from S17 with reason selector.
- Hidden: nothing sensitive; student sees own data only.
- Security: SEC-17 irreversible; requires app login; logged (SEC-12).
- Privacy: student controls own credential.
- Usability: two taps; consequences stated before action (USE-10); Meher persona T4.

S19 — Entry logs (auditor console)

- Purpose: Review decisions and investigate incidents without casual identification.
- UI: Filters: gate, date/time range, decision code, flagged only, method. Table columns: time, gate, method, decision, credential pseudonym (e.g., "C-7f3a..."), flags, guard ID (manual entries only). Integrity indicator: "Chain verified ✓ (last checkpoint 12:00)". Row action: [Re-identify] → dialog: case reference (required), justification (required), notice "This action is logged and visible to [second admin role]" [Confirm]. After confirm: name and roll appear for that row only, with a red "identified" badge.
- Hidden: names by default (PRIV-04); secrets (SEC-06); no edit/delete controls anywhere (SEC-15).
- Security: SEC-10 chain status; PRIV-06 justified re-identification; Auditor role only.
- Privacy: pseudonymous by default; re-identification is the exception and is itself audited.
- Usability: flagged-only quick filter for daily review; export is pseudonymous.

S20 — Privacy / access-control screen (two variants)

- Student variant (app "Privacy & my data"): sections: "What is collected" (list per Section 30); "Why" (access decisions, security incidents); "Who can see it" (visibility table simplified); "How long" (90 days; flagged until case closed); "My entry records" (own events list, last 90 days); "My credentials"; "Request correction"; link to full notice.
- Policy admin variant ("Gate access policy"): table of gates × roles × time windows; edit opens confirm dialog showing before/after and "applies to N gates"; version history with author and time; default row "Any other role: DENY" (non-editable) to make the secure default visible.
- Hidden: student variant shows no other person's data; policy variant shows no individual identities.
- Security: policy changes MFA + confirm (SEC-11), versioned (FR-18); deny-by-default visible (DP-3).
- Privacy: PRIV-07 transparency, PRIV-08 access; builds trust (USE-13).
- Usability: plain-language notice; policy grid uses recognition (USE-11).

35.3 Screen flow map

```

S01 → S02 → S03 → { S04 (user) + S05 (guard) } → auto-clear → S01
                    → S06 / S06b / S07 / S08 / S09 (user: red/amber message; guard: next step) → [Done] → S16
S05 → [Mismatch] → S09
S16 → [Visitor without approval] → S13 (guard variant) → S14 (host phone) → S15 → S02
S16 → reader fault → S10 ; network loss → S11 ; limit exceeded → S12
Host web → S13 → S14 → S15
Student app → S18 ; → S20 (student)
Issuer console → S17 → (confirm) ; → S18 (issuer variant)
Auditor console → S19
Policy admin → S20 (policy)

```

35.4 Figma import notes

Import `screens/S01..S20.png` as frames at 1440×900 (tablet/desktop) or 390×844 (phone/user indicator); link hotspots as in 35.3; use Figma's prototype "Overlay" for confirm dialogs (S17, S18, S19, S20). Full instructions in `Figma_Prototype_Instructions.pdf`.

36. Heuristic Evaluation

This is an initial heuristic evaluation by the design team, not user testing. No students, guards or administrators have used the prototype. Findings are expert judgements against Nielsen's heuristics [15] and usable-security principles [13, 14, 27]. Each finding has a severity (0 none, 1 cosmetic, 2 minor, 3 major, 4 catastrophic) and a planned fix. User testing with real participants is a Phase 2 activity (Section 40).

Method. Two evaluators walked through tasks T1–T10 (Section 18) on the 20 wireframes independently, recorded violations, then merged and rated them.

36.1 Nielsen's heuristics

Heuristic	Assessment	Findings (severity)	Planned fix
1. Visibility of system status	Strong: status bar on every guard screen (online/offline, list age, reader health); user indicator shows ready/reading/verifying/result.	HE-1 (2): S03 gives no indication of how long is normal; a slow network could make users re-tap.	Add "usually under 2 s" and a 2-s "taking longer" message (already in spec; ensure in wireframe).
2. Match between system and real world	Good: "Not accepted", "Expired", "Revoked", "Security Office", "ID cell" are terms guards and students use. Bilingual labels planned.	HE-2 (2): "Revocation list age" (S11) is technical vocabulary for guards.	Rename to "Last update from server: 1 h 20 m ago (limit 4 h)".
3. User control and freedom	Admin actions have Cancel; Mismatch requires confirm; guard can [Done] out of any result. Deliberate limitation: no "Allow anyway" (security override of this heuristic, justified in Section 38).	HE-3 (1): S09 has no explicit way for the guard to dismiss a false alert other than [Done]; supervisor owns resolution.	Acceptable; add "Supervisor will clear this alert" text.
4. Consistency and standards	Colour/word/icon triad consistent across S04–S09; red = deny, amber = authz-class deny with known identity, green = allow.	HE-4 (3): S06b "Not permitted at this gate/time" is amber, as are Expired (S07) — two different next steps share a colour.	Keep amber for both (both are "identity known, not authorized") but make the status word and next-step block the primary differentiator; add distinct icons (clock vs gate).
5. Error prevention	Confirm dialogs on revoke/policy; Mismatch confirm; QR glare hints; no free-text personal data in manual mode.	HE-5 (2): S13 host form allows any time window; a host could create a week-long pass.	Policy-driven maximum window (e.g., 12 h) enforced in form with explanation.
6. Recognition rather than recall	Next-step scripts on screen; roster search in S17; policy grid in S20.	HE-6 (2): S12 manual mode step list is long for a stressed guard in a queue.	Collapse to 3 large steps with progressive disclosure; provide printed card at gate.
7. Flexibility and efficiency	Back-to-back taps; auto-clear; flagged-only filter in S19; two credential methods.	HE-7 (1): Supervisors may want batch approval in manual mode at peak; spec mentions it, wireframe does not show it.	Add [Approve next 10 min] control for supervisor role only, logged as such.
8. Aesthetic and minimalist design	Guard result screens contain photo, one name, one status word, one line, one button.	HE-8 (1): S16 dashboard tiles risk clutter if alert list grows.	Cap visible alerts at 3 with count badge.
9. Help users recognise, diagnose, recover from errors	Every DENY names the class and next step; user side gives a respectful, non-specific message.	HE-9 (3): S06 user message "Not accepted — visit the Security Office" is identical for fake credential and revoked credential (by design, for bystander privacy), which means a legitimate student with a revoked card gets no private explanation at the gate.	Send a private explanation to the student's app immediately ("Your card was revoked on ... because a loss was reported. Visit ..."). Keeps bystander message generic.
10. Help and documentation	Scripts embedded; training target ≤15 min (USE-02).	HE-10 (2): No on-screen "What do these colours mean?" help for a relief guard.	Add a persistent "?" on S16 opening a one-page legend.

36.2 Usable-security principles

Principle	Assessment	Findings	Planned fix
Visible security state [13]	Online/offline, list age, tamper, alerts all visible; decision shows both authn and authz outcome.	HE-11 (2): The guard cannot tell from S05 which method (card/phone/QR) was used; this could matter if policy later restricts methods for certain gates.	Add small method icon to S05 (not to user side).
Safe defaults [14, 27]	Deny-by-default policy is shown in S20; new readers disabled; minimal guard view; retention on.	None.	—
Security effort proportional to risk [17]	Routine entry = one tap; additional steps only on anomalies, manual mode, admin ops.	HE-12 (2): Mismatch confirm-tap adds a step in the moment the guard most needs speed (a person trying to walk through).	Make first tap immediately turn the user indicator red (stop the person) and log a provisional flag; second tap confirms; single tap auto-confirms after 3 s.

Principle	Assessment	Findings	Planned fix
Reversibility [13]	Admin actions confirm; suspension reversible; revocation deliberately irreversible with replacement path.	HE-13 (2): Student self-revoke (S18) is irreversible with no cooling-off; accidental taps are possible.	Keep irreversible (security), but require typing "DISABLE" or biometric confirm; show consequence text (already present).
Data minimisation [22, 27]	Guard sees photo + first name + role; logs pseudonymous; visitor contact hidden from guard; no phone/address stored.	HE-14 (1): S15 visitor pass shows host full name; first name + department may suffice.	Show host first name + department.
Clear security explanations [12]	Reasons are plain-language; technical codes hidden from guards, available to auditors.	HE-15 (3): S06 ("not a valid campus credential") could be read by a guard as "the student is lying"; risk of confrontation.	Reword: "The reader could not verify this card or code. This can happen with damaged, copied or non-campus credentials. Direct to Security Office."

36.3 Summary

15 findings: 0 catastrophic, 3 major (HE-4, HE-9, HE-15), 9 minor, 3 cosmetic. All three major findings concern communication of denial and will be fixed in the next wireframe iteration before Phase 2 development. The evaluation confirms the prototype's structural decisions (authn/authz separation, minimal guard view, no override) but shows that wording and colour differentiation need refinement, which is exactly what user testing with guards in Phase 2 will validate.

37. Requirement Traceability

Full matrix in 03_Requirements/Requirements_Traceability_Matrix.xlsx (Appendix F). The chain is: Finding → User need → Requirement → Security risk (threat) → Design feature → Prototype screen → Future test. Until fieldwork completes, the "Finding" column cites a hypothesis (H-x), a secondary source [n], or a labelled assumption; each such row must be updated with the primary evidence code (Q-x, G-x, S-x) when data arrives. Representative rows:

Finding (status)	User need	Requirement(s)	Threat(s)	Design feature	Screen(s)	Future test (Phase 2)
H1 Card retrieval delays queue [DATA REQUIRED: Q4, Q11a/b, observation]	Enter without breaking stride	USE-01, FR-01, D1	— (usability)	Tap-and-go card; optional phone credential	S01, S02, S04	Timing at pilot gate, $p95 \leq 1.5$ s; SUS with students
H2 Guards do not read expiry [DATA REQUIRED: B Q4, observation]	Automatic enforcement	SEC-03, FR-03	TH-07	Server-side validity check; EXPIRED screen	S07	Expired card → DENY; guard comprehension test
H3 Face familiarity replaces card check [DATA REQUIRED: B Q3]	Reliable identity check under load	FR-12, USE-05, SEC-08	TH-04, TH-06	Server photo on guard tablet; Mismatch	S05, S16	Lent-card test scenario with consenting participants; Mismatch usage rate
H4 Forgotten ID handled inconsistently [DATA REQUIRED: Q6, Q7, B Q6]	Defined, dignified fallback	FR-01 (phone), FR-13, D9	TH-04 (social engineering)	Phone credential; temp pass via Security Office; no gate bypass	S02, S06, S12	Task T1 with phone; T6 walkthrough with guards
H5 Lost card not blocked; slow replacement [DATA REQUIRED: Q9, Q10, A2]	Block lost card instantly; keep access	FR-09, SEC-17, SEC-02, FR-08	TH-01, TH-08	Self-service revoke; irreversible; phone credential continues	S18, S08	Revoke → tap within 30 s → DENY; T4 task time
H6 Visitor register slow, leaks phone numbers [DATA REQUIRED: B Q9, observation]	Fast, private visitor entry	FR-10, FR-11, SEC-16, PRIV-09	TH-05, TH-13	Host pre-approval; signed QR pass; no register	S13–S15	T7 timing; guard never sees contact (API test)
H7 Peak pressure → waving through [DATA REQUIRED: B Q8, observation]	Speed without weakening check	USE-01, USE-12, SEC-13	TH-04, TH-06	Back-to-back taps; auto-clear; anomaly alerts	S04, S05, S09	Throughput test ≥ 30 /min; alert precision
H8 No record for incidents [DATA REQUIRED: A6]	Auditable decisions	FR-06, SEC-10, FR-15	TH-15	Hash-chained pseudonymous log; auditor tool	S19	Chain verification; tamper test
H9 Students uneasy about data use [DATA REQUIRED: Q14, Q15]	Transparency; purpose limitation; self-view	PRIV-02, PRIV-07, PRIV-08, USE-13	TH-13	Privacy screen; own-records view; retention	S20	Post-pilot trust survey; DPIA
[SECONDARY] MIFARE Classic / hotel locks cloneable [4, 5, 8, 9]	Credential cannot be copied	SEC-01, SEC-04, D1	TH-02, TH-03, TH-06	AES challenge–response; signed dynamic QR; never UID	S03, S06	Clone/replay tests → DENY
[SECONDARY] Relay attacks practical [18–20]	Compensating human check	FR-12, USE-05	TH-04b	Photo + Mismatch	S05	Documented residual; guard training
[SECONDARY] Reader compromise (Only) [36]	Reader holds no secrets	SEC-18, SEC-09	TH-16, TH-12	Public keys only; signed decisions; tamper log	S10	Reader storage extraction test
[SECONDARY] Fail-safe defaults [14]	No failure opens gate	SEC-09, SEC-19, FR-14, D7	TH-14	Offline-verified → manual supervised	S10–S12	Fault injection
[SECONDARY] Insider abuse; least privilege [14, 30]	Roles limited; look-ups justified	SEC-07, SEC-11, PRIV-06	TH-09, TH-17	Six roles; MFA; justified re-identify	S17, S19	Cross-role API tests
[SECONDARY] DPDP purpose/retention [22]	Lawful, minimal, time-bound data	PRIV-01..05, PRIV-12	TH-10, TH-13	Schema; retention job; pseudonyms	S19, S20	Schema review; purge verification
[SECONDARY] Users bypass slow security [10, 11, 17]	Secure path is fastest	USE-01, D4 (no bypass)	TH-04	Tap faster than glance; redundancy not bypass	S01–S05	Timing; observation of guard behaviour at pilot
[SECONDARY] Colour-only signals inaccessible [28]	Multimodal feedback	USE-08, USE-09, USE-14	—	Icon + word + tone; contrast; reader height	S04–S09	Accessibility audit
[SECONDARY] Secrets in logs are a common breach vector; no-delete logs needed for insider accountability [29]	Logs useful but never dangerous	SEC-06, SEC-15, SEC-10	TH-13, TH-15, TH-17	Pseudonymous, secret-free, append-only log; no edit/delete controls	S19	Grep for key material; attempt delete via API
[SECONDARY] Open design: only keys are secret [14]	Verifiable security	SEC-20, NFR-07	All	Standard primitives/libraries only; design published in this report	—	Dependency and design review

Finding (status)	User need	Requirement(s)	Threat(s)	Design feature	Screen(s)	Future test (Phase 2)
H9 / Meher persona: public interrogation at the gate is undignified [DATA REQUIRED: Q14c, Q20]	Denial handled privately	PRIV-03, PRIV-10, USE-13, DP-13	TH-13	Split user/guard displays; generic bystander message; private app explanation	S04–S09, S20	Field check of screen placement; post-pilot survey
[SECONDARY] DPDP erasure obligation [22]	Data not kept longer than needed	PRIV-05	TH-10, TH-13	Retention job (90 d / 30 d / 1 y), logged purge	S20	Verify scheduled purge
Ramesh persona: relief guards need to understand every result without training [DATA REQUIRED: B Q13]	Learnable in ≤15 min; distinct messages; next step always shown	USE-02, USE-03, USE-04, USE-06, USE-11	TH-04, TH-17	Plain bilingual status word + next-step block + status bar on every guard screen	S05–S12, S16	Guard comprehension test (sort screens; state next step)
[SECONDARY] Path of least resistance; reversibility [13]	Optional enrolment; safe admin actions	USE-07, USE-10	TH-09	Card needs no enrolment; phone enrolment ≤3 min; confirm dialogs show exact effect	S17, S18, S20	Timed enrolment; task T9 error rate
[ASSUMPTION] A3 most students have smartphones	Universal access regardless of phone	D1 (card baseline)	—	Card for all; phone optional	S01	Q17 data; enrolment rate at pilot

Coverage check: every SEC-xx, PRIV-xx and USE-xx requirement appears in at least one traceability row in the XLSX; every prototype screen S01–S20 is reached by at least one row; every High-priority threat (Section 24.5) has at least one mitigating requirement with a screen and a test.

38. Security–Usability–Privacy Trade-offs

#	Security wants	Usability wants	Privacy wants	Tension	Design response	What we give up
TO-1	Second factor on every entry (PIN/biometric)	One tap, no attention	Fewer biometric templates	MFA per tap would double gate time and create a biometric database	Card is single-factor but cryptographic; phone path gets a second factor "for free" via unlock; MFA is required only for admin operations and could be policy-enabled for high-risk gates later	Perimeter entry remains single-factor for card users; accepted for a moderate-risk perimeter [2]
TO-2	Guard verifies face carefully on every tap	Guard glances; queue moves	Guard sees as little as possible	Careful comparison slows queue; showing more data doesn't help the face check	Photo-first layout with one name; Mismatch button; periodic training; anomaly alerts carry the load for statistical patterns	Guard fatigue remains the main residual risk for borrowed credentials and relay
TO-3	Show guard full identity to "verify"	Simpler decision with less on screen	Minimal disclosure	More data ≠ better decision; roll number and department do not help match a face	Show photo, first name, role, decision only (D3)	Guard cannot resolve "this looks like a different Aarav" without the office; acceptable
TO-4	Additional verification on anomalies	No extra steps	—	Extra steps for everyone waste the compliance budget [17]	Escalate only on triggers (repeated failures, mismatch, velocity)	Some sophisticated single-attempt attacks are not escalated
TO-5	Fail closed on any infrastructure failure	Gate keeps moving	—	Fully closed gate is a DoS target and strands students	Bounded offline verification (N h) then supervised manual mode; never unattended open	Revoked credential may work offline for up to N h; manual mode is weaker than electronic
TO-6	Detailed denial reason to guard	Guard knows what to say	Student's reason (e.g., disciplinary) is private	Telling the guard why a card is revoked leaks sensitive status	Guard sees class + next step; student gets reason privately in app (HE-9 fix)	Guard may face a student who says "why?"; script directs to office
TO-7	Complete identified audit trail	Fast auditor workflow	Pseudonymous logs; no casual look-ups	Justification step slows investigations	Pseudonymous by default; re-identify with case reference, logged, visible to second admin	Auditors spend ~30 s more per re-identification
TO-8	Long log retention for investigations	—	Short retention	Longer logs = larger surveillance dataset and breach impact	90 days routine; flagged events kept until case closed + 1 y	Incidents discovered after 90 days lose routine context
TO-9	No self-service revocation (issuer verifies loss claim)	Instant, from phone	Student controls own data	Issuer-only leaves the lost card live for hours; self-service could be triggered maliciously by someone with the student's phone	Self-service immediate + irreversible; requires app login (phone unlock); consequence text	A malicious actor with an unlocked phone can revoke the card (nuisance, not intrusion)
TO-10	Reject all visitors without pre-approval	Walk-in visitors admitted quickly	Minimal visitor data	Pre-approval only would refuse legitimate walk-ins	Gate-initiated host approval on host's phone; pass issued on the spot	Walk-in waits for host response; no host response = no entry
TO-11	Strong chip family (higher cost)	—	—	Budget vs assurance	Specify AES challenge–response class; exact product is a procurement decision	Higher per-card cost than Classic-class cards
TO-12	Card emulation on iOS (uniform phone experience)	Same experience on all phones	—	iOS restricts HCE to entitled partners	Android NFC + QR on iOS in Phase 2 (D10)	iPhone users get the slower QR path for the phone credential; card remains universal

The report's position: none of these tensions is resolved by declaring one value the winner. Each response is chosen so that the routine case is fast and private and the exceptional case bears the added security cost, following the compliance-budget argument [17] and Yee's path-of-least-resistance principle [13].

39. Limitations

1. No primary data yet. The most significant limitation of this version: every finding slot in Section 11 is a placeholder. The requirements are grounded in secondary research and labelled assumptions. Several decisions (D1, D3, D4, D9) explicitly depend on Q16/Q17/Q14c/B Q9–Q12 and may change.
2. Personas are synthesised. They are design tools, not evidence, and will be revised after fieldwork.
3. Heuristic evaluation only. No user has used the prototype; the three major findings suggest denial wording needs testing with guards.
4. Access to administration uncertain. If the security office/ID cell cannot be interviewed, lifecycle stages 1, 6 and 7 rest on assumptions about institutional process.
5. Secondary research breadth. Sources were selected for credibility and relevance, not by systematic review; the research gap (Section 15) is defensible against the sources reviewed but is not a claim of global novelty.
6. No Indian-university-specific sources. We found no reliable public documentation of specific Indian campus gate technologies and make no claims about them.
7. Relay attacks not prevented cryptographically. Documented as residual (TH-04b).
8. Exit not controlled. Overstay and occupancy cannot be detected; a future design could add exit readers with the same privacy analysis.
9. Biometrics excluded. A face-matching assistant for guards could reduce fatigue errors but requires a separate ethical, legal and accuracy analysis; deliberately out of scope.
10. Vehicle gates treated conceptually only.
11. Platform constraints for phone credentials (iOS) limit uniformity in Phase 2.
12. Cost and procurement not analysed beyond relative terms.

40. Phase 2 Plan

Phase 2 deadline: 17 November 2026 (executable + user guide). Second poster with live demo: 26 November 2026. Peer testing: 18–25 November. Final recorded presentation: 29 November [43].

40.1 Immediate (before Phase 2 development starts)

- Complete fieldwork (questionnaire, ≥ 3 guard interviews, ≥ 3 observation sessions); replace all placeholders in Section 11; update Sections 16, 34, 37.
- Apply heuristic-evaluation fixes (Section 36) to wireframes; re-evaluate.
- Confirm D1 with Q16/Q17 data; confirm D3 with Q14c and B Q11/Q12.

40.2 Implementation scope (minimum viable, $\geq 50\%$ original code [43])

Component	Phase 2 implementation	Standards / libraries (no custom crypto)
Credential simulation	Since procuring AES smart cards and a SAM may be infeasible, simulate the card with (a) an Android HCE app performing Ed25519 challenge–response and (b) a dynamic signed QR; if a DESFire EV3 dev kit is available, integrate real card authentication for demo	Ed25519 [38]; Android HCE; ZXing for QR
Reader	Android tablet or Raspberry Pi with NFC reader + camera; verifies locally with cached public keys and signed revocation list; mutual TLS to server	TLS 1.3 [39]; standard NFC libraries
Auth + policy service	Web service: nonce issuance, signature verification, status/validity check, policy evaluation, signed decisions	Vetted crypto library (libsodium / platform); JWT [40]
Stores	Relational DB with encrypted-at-rest volume; pseudonym mapping in separate schema; HSM simulated with an isolated key service (documented as simulation)	AES-256; parameterised queries
Audit log	Append-only table with hash chain and periodic signed checkpoints; verifier CLI	SHA-256; Ed25519
Guard tablet UI	Screens S05–S12, S16	Accessibility: contrast, icons, tones
Admin console	S17, S19, S20 with RBAC, MFA (TOTP [37]), confirm dialogs	OWASP ASVS L2 [29]
Student app	Enrolment, dynamic QR, HCE, report lost (S18), privacy view (S20)	Hardware keystore
Visitor flow	S13–S15 with signed passes	Ed25519

40.3 Security testing

- Unit and integration tests for every SEC requirement's "Phase 2 evaluation" column (Section 20).
- Attack scenario replays (Section 25) as test cases: clone (UID copy), replay (captured token), expired, revoked, offline staleness, rogue-server ALLOW injection, cross-role API calls, log tampering.
- Dependency vulnerability scan; ASVS L2 self-assessment; threat model review against implemented DFD.
- Prepare for peer testing (Nov 18–25): expect testers to probe exactly the residuals we documented; the user guide will state them.

40.4 Usability testing

- Task-based study with ≥ 5 guards (T5, T6, T7, T11, T12) and ≥ 10 students (T1, T2, T4, T13): success rate, time, errors, SUS [15].
- Comprehension test for USE-02 (guards classify result screens after 15-minute training).
- Accessibility audit (WCAG 2.2 AA, contrast, screen reader on app).
- Trust/privacy survey post-use (Q14/Q15 repeated).

40.5 Deliverables

Executable (server + reader/guard app + student app + admin console) with seeded demo data; user guide covering all roles and stating residual risks; updated report Sections 11, 16, 34, 36, 37; poster; recorded presentation answering Part A (study design, how studies shaped the tool, design themes) and Part B (security requirements, how addressed, classes of vulnerabilities reported by peers, causes and lessons) [43].

41. Conclusion

Phase 1 set out to replace an assumption ("a card is an identity") with an evidence chain. The chain is in place: a mixed-methods research plan with ready-to-run instruments; a literature and existing-system review that shows why authenticating card data rather than key possession has failed repeatedly in deployed systems; a threat model of twelve actors and seventeen threats with mitigations and honestly stated residuals; a requirements catalogue of 20 functional, 20 security, 12 privacy, 14 usability and 14 non-functional requirements; a credential lifecycle, security and system architecture, data-flow and privacy data-flow designs; workflows for every failure and edge case with no insecure bypass; a twenty-screen prototype in which every screen traces to a requirement; and an initial heuristic evaluation that already points to the wording problems Phase 2 testing must resolve.

The central design commitments are: authenticate the key, not the artefact; keep authentication and authorization as separate decisions with separate messages; show the guard a face and a status and nothing more; fail to a defined, audited manual mode rather than to an open gate; log everything pseudonymously and re-identify only with justification; and make the secure path the fastest one.

What Phase 1 has not done is collect primary data. Every placeholder in this report is a commitment to do so before Phase 2 development begins, and the traceability matrix is built so that each requirement's evidence column can be updated without restructuring the design. The provisional technology direction, a cryptographic smart card for everyone with an optional phone credential and signed visitor passes, is the direction the threat model and secondary research support; the user studies will confirm, adjust, or overturn it.

42. References

Numbering is fixed; all in-text citations use these numbers.

Standards and government sources

- [1] NIST. SP 800-63-4: Digital Identity Guidelines (with 800-63A-4 Identity Proofing, 800-63B-4 Authentication and Authenticator Management, 800-63C-4 Federation). National Institute of Standards and Technology, July 2025. <https://csrc.nist.gov/pubs/sp/800/63/4/final>
- [2] NIST. SP 800-116 Rev. 1: Guidelines for the Use of PIV Credentials in Facility Access. National Institute of Standards and Technology, June 2018. <https://csrc.nist.gov/pubs/sp/800/116/r1/final>
- [3] NIST. SP 800-57 Part 1 Rev. 5: Recommendation for Key Management. National Institute of Standards and Technology, May 2020.
- [4] F. D. Garcia, G. de Koning Gans, R. Muijers, P. van Rossum, R. Verdult, R. Wichers Schreur, B. Jacobs. "Dismantling MIFARE Classic." ESORICS 2008, LNCS 5283, Springer, pp. 97–114.
- [5] K. Nohl, D. Evans, Starbug, H. Plötz. "Reverse-Engineering a Cryptographic RFID Tag." USENIX Security Symposium 2008, pp. 185–193.
- [6] F. D. Garcia, G. de Koning Gans, R. Verdult, M. Meriac. "Dismantling iClass and iClass Elite." ESORICS 2012, LNCS 7459, Springer, pp. 697–715.
- [7] D. Oswald, C. Paar. "Breaking Mifare DESFire MF3ICD40: Power Analysis and Templates in the Real World." CHES 2011, LNCS 6917, Springer, pp. 207–222.
- [8] T. Tuominen, T. Hirvonen. "Ghost in the Locks" (Vision by VingCard vulnerability disclosure). F-Secure, April 2018. Reported in: A. Greenberg, "A One-Minute Attack Let Hackers Spoof Hotel Master Keys," Wired, 25 Apr 2018.
- [9] L. Wouters, I. Carroll, et al. "Unsaflok: Security vulnerabilities in dormakaba Saflok hotel locks." Disclosure site, March 2024. <https://unsaflok.com/>. Reported in Ars Technica, 21 Mar 2024.
- [10] A. Adams, M. A. Sasse. "Users Are Not the Enemy." Communications of the ACM 42(12), 1999, pp. 40–46.
- [11] C. Herley. "So Long, and No Thanks for the Externalities: The Rational Rejection of Security Advice by Users." NSPW 2009, ACM, pp. 133–144.
- [12] A. Whitten, J. D. Tygar. "Why Johnny Can't Encrypt: A Usability Evaluation of PGP 5.0." USENIX Security Symposium 1999.
- [13] K.-P. Yee. "User Interaction Design for Secure Systems." ICICS 2002, LNCS 2513, Springer, pp. 278–290.
- [14] J. H. Saltzer, M. D. Schroeder. "The Protection of Information in Computer Systems." Proceedings of the IEEE 63(9), 1975, pp. 1278–1308.
- [15] J. Nielsen. "Enhancing the Explanatory Power of Usability Heuristics." CHI 1994, ACM, pp. 152–158. Updated as "10 Usability Heuristics for User Interface Design," Nielsen Norman Group.
- [16] L. F. Cranor. "A Framework for Reasoning About the Human in the Loop." UPSEC 2008, USENIX.
- [17] A. Beutement, M. A. Sasse, M. Wonham. "The Compliance Budget: Managing Security Behaviour in Organisations." NSPW 2008, ACM, pp. 47–58.
- [18] G. P. Hancke, M. G. Kuhn. "An RFID Distance Bounding Protocol." SecureComm 2005, IEEE, pp. 67–73.
- [19] A. Francillon, B. Danev, S. Capkun. "Relay Attacks on Passive Keyless Entry and Start Systems in Modern Cars." NDSS 2011, Internet Society.
- [20] L. Francis, G. Hancke, K. Mayes, K. Markantonakis. "Practical NFC Peer-to-Peer Relay Attack Using Mobile Phones." RFIDSec 2010, LNCS 6370, Springer, pp. 35–49.
- [21] K. Krombholz, P. Frühwirth, P. Kieseberg, I. Kapsalis, M. Huber, E. Weippl. "QR Code Security: A Survey of Attacks and Challenges for Usable Security." HAS 2014 (HCI International), LNCS 8533, Springer, pp. 79–90.
- [22] Government of India. The Digital Personal Data Protection Act, 2023 (No. 22 of 2023). Gazette of India, 11 August 2023.
- [23] ISO/IEC 14443-1:2018 to 14443-4:2018. Cards and security devices for personal identification — Contactless proximity objects. International Organization for Standardization.

- [24] ISO/IEC 18092:2023. Information technology — Telecommunications and information exchange between systems — Near Field Communication Interface and Protocol (NFCIP-1).
- [25] ISO/IEC 18004:2024. Information technology — Automatic identification and data capture techniques — QR Code bar code symbology specification.
- [26] ISO/IEC 29100:2024. Information technology — Security techniques — Privacy framework.
- [27] A. Cavoukian. Privacy by Design: The 7 Foundational Principles. Information and Privacy Commissioner of Ontario, 2009 (rev. 2011).
- [28] W3C. Web Content Accessibility Guidelines (WCAG) 2.2. W3C Recommendation, 5 October 2023.
- [29] OWASP Foundation. Application Security Verification Standard (ASVS) 4.0.3, 2021; and OWASP Logging Cheat Sheet.
- [30] A. Shostack. Threat Modeling: Designing for Security. Wiley, 2014.
- [31] R. Anderson. Security Engineering: A Guide to Building Dependable Distributed Systems, 3rd ed. Wiley, 2020. (Ch. 13 "Physical Tamper Resistance", Ch. 16 "Physical Protection".)
- [32] R. Verdult. The (in)security of proprietary cryptography. PhD thesis, Radboud University Nijmegen / KU Leuven, 2015.
- [33] J. Bonneau, C. Herley, P. C. van Oorschot, F. Stajano. "The Quest to Replace Passwords: A Framework for Comparative Evaluation of Web Authentication Schemes." IEEE Symposium on Security and Privacy 2012, pp. 553–567.
- [34] S. Garfinkel, H. R. Lipford. Usable Security: History, Themes, and Challenges. Morgan & Claypool, 2014.
- [35] Apple Inc. "Apple adds support for contactless student ID cards in Wallet." Apple Newsroom, 2 October 2018; and "Apple brings contactless student IDs on iPhone and Apple Watch to more universities," 13 August 2019.
- [36] C. Brocius. "My Arduino can beat up your hotel room lock." Black Hat USA 2012 (Onity HT lock vulnerability).
- [37] D. M'Raihi, S. Machani, M. Pei, J. Rydell. RFC 6238: TOTP: Time-Based One-Time Password Algorithm. IETF, May 2011.
- [38] S. Josefsson, I. Liusvaara. RFC 8032: Edwards-Curve Digital Signature Algorithm (EdDSA). IETF, January 2017.
- [39] E. Rescorla. RFC 8446: The Transport Layer Security (TLS) Protocol Version 1.3. IETF, August 2018.
- [40] M. Jones, J. Bradley, N. Sakimura. RFC 7519: JSON Web Token (JWT). IETF, May 2015.
- [41] NXP Semiconductors. MIFARE DESFire EV3 contactless multi-application IC (product data sheet, AES-128 mutual authentication); MIFARE Plus EV2 product data sheet. NXP, 2020–2022.
- [42] M. A. Sasse, S. Brostoff, D. Weirich. "Transforming the 'Weakest Link' — a Human/Computer Interaction Approach to Usable and Effective Security." BT Technology Journal 19(3), 2001, pp. 122–131.
- [43] IIIT-Delhi. Course Project Guidelines, CSE 347/652 | DES 306/525 Usable Security and Privacy, Monsoon 2026 (Dr. Arun Balaji Buduru). Course handout.

Note on source quality. Sources [8], [9] and [36] are security-conference or vendor disclosures rather than peer-reviewed papers; they are cited for the existence and nature of a publicly demonstrated attack, with the primary disclosure named and a reputable secondary report given. Vendor data sheets [41] are cited only for the cryptographic primitives a product family claims to implement, not for security assurance. Source [35] is cited only for the fact that named universities offer NFC student credentials in Apple Wallet, as stated by Apple; it is not cited as evidence of security properties.

Appendix A. Student Questionnaire

Title for Google Forms: Campus Entry Experience Survey (Usable Security & Privacy course project)

Form description (shown on page 1):

This short survey (6–8 minutes) is part of a student course project in CSE 347/652 | DES 306/525 Usable Security and Privacy at IIIT-Delhi. We are studying how campus entry works today and how it could be made more secure, private and convenient. The survey is anonymous: we do not ask for your name, roll number, e-mail or phone number. Responses are stored on a password-protected team drive, reported only in aggregate, and deleted at the end of the course. Participation is voluntary and you may stop at any time. By clicking "Next" you confirm you are 18 or older and agree to take part. Questions: contact the team at [TEAM CONTACT E-MAIL].

Google Forms settings: Do not collect e-mail addresses. Do not limit to one response (requires sign-in). Shuffle option order OFF (ranking and Likert need fixed order). Show progress bar ON.

Section 1 — Background

#	Question	Type	Options	Required	Purpose
Q1	Which programme are you in?	Multiple choice	UG (B.Tech) / PG (M.Tech / MSc) / PhD / Other	Yes	Segment respondents; check sample balance
Q2	Are you a hosteller or a day scholar?	Multiple choice	Hosteller / Day scholar / Other	Yes	Entry frequency and time-of-day patterns differ
Q3	On a typical weekday, how many times do you pass through a campus entry gate?	Multiple choice	0–1 / 2–3 / 4–5 / More than 5	Yes	Size how often authentication happens per user; informs speed requirement

Section 2 — Current Entry Experience

#	Question	Type	Options	Required	Purpose
Q4	How do you usually carry your college ID card?	Multiple choice	On a lanyard, visible / In wallet or pocket / In bag / I often don't carry it / Other	Yes	Retrieval effort; informs H1 and form-factor decision
Q5	When you enter, how closely does the guard usually look at your ID?	Multiple choice	Does not look; I walk through / Glances at the card from a distance / Looks at the card and my face / Asks me to stop and checks carefully / Varies a lot	Yes	Measures perceived rigour of current check (RQ1, H3, H7)
Q11a	At the busiest time you enter, how long do you typically wait in the queue at the gate?	Multiple choice	No wait / Under 30 seconds / 30 s – 1 min / 1–3 min / More than 3 min	Yes	Quantifies queueing (RQ3)
Q11b	"Retrieving my ID card at the gate is inconvenient."	Likert (5)	Strongly disagree / Disagree / Neutral / Agree / Strongly agree	Yes	Perceived friction of current mechanism

Section 3 — Problems and Failures

#	Question	Type	Options	Required	Purpose
Q6	In the last month, how many times did you arrive at the gate without your ID card?	Multiple choice	0 / 1 / 2–3 / 4 or more	Yes	Frequency of forgotten-ID case (H4)
Q7	The last time you arrived without your ID, what happened?	Checkboxes (multiple)	Guard let me in without asking / Guard recognised me and let me in / I showed another ID or proof / Guard asked questions then let me in / Someone vouched for me / I was refused entry / Never happened to me / Other (specify)	Yes	Documents actual fallback behaviour (RQ2)
Q8	If you were refused entry without your ID, what did you do?	Short answer	—	No	Qualitative detail on the refusal path
Q9	Have you ever lost your college ID card?	Multiple choice	Yes, once / Yes, more than once / No	Yes	Frequency of lost-credential case (H5)
Q10	If yes, roughly how many days did it take to get a replacement, and could you enter campus in the meantime?	Short answer	—	No	Replacement latency and interim access (H5)
Q12	Have you ever seen someone enter the campus using another person's ID, a fake ID, or without any check?	Multiple choice	Yes, more than once / Yes, once / Not sure / No	Yes	Witnessed security failures without asking respondent to self-incriminate (RQ4)

Section 4 — Security Perceptions

#	Question	Type	Options	Required	Purpose
Q13a	"The current ID check reliably stops unauthorised people from entering."	Likert (5)	SD / D / N / A / SA	Yes	Perceived effectiveness (RQ4)
Q13b	"I am concerned that a lost or stolen ID card could be used by someone else to enter."	Likert (5)	SD / D / N / A / SA	Yes	Perceived risk of credential theft
Q13c	Which of the following would you consider a security problem with the current system? (select all)	Checkboxes	Cards can be borrowed / Cards can be faked / Lost cards keep working / Expiry is not checked / Visitors are not checked properly / Guards are too busy to check / None of these / Other	Yes	Maps perceived problems to threat model rows

Section 5 — Privacy and Trust

#	Question	Type	Options	Required	Purpose
Q14a	"I would be comfortable with the college recording the time I enter campus."	Likert (5)	SD / D / N / A / SA	Yes	Acceptance of entry logging (PRIV requirements)
Q14b	"I would want to be able to see my own entry records."	Likert (5)	SD / D / N / A / SA	Yes	Transparency need (PRIV-08)
Q14c	Which of your details would you be comfortable with a gate guard seeing on a screen when you enter? (select all)	Checkboxes	Photo / First name / Full name / Roll number / Programme / Hostel / Phone number / None of these	Yes	Directly informs guard-screen data minimisation (PRIV-03, screen 5)
Q15a	"I would trust an electronic check (card tap / phone) more than the current visual check."	Likert (5)	SD / D / N / A / SA	Yes	Baseline trust in electronic authentication
Q15b	"I am worried that entry data could be used for purposes other than campus security (e.g., attendance, tracking)."	Likert (5)	SD / D / N / A / SA	Yes	Purpose-limitation concern (PRIV-02)
Q15c	What would make you trust an electronic entry system more?	Short answer	—	No	Qualitative trust factors

Section 6 — Preferences, Accessibility and Features

#	Question	Type	Options	Required	Purpose
Q16	Rank these ways of proving who you are at the gate, from most preferred (1) to least (5).	Ranking grid (Google Forms: multiple-choice grid, one column per rank)	Tap a physical smart card / Tap my phone (NFC) / Show a QR code on my phone / Keep the current visual ID check / Other	Yes	Method preference (RQ7); drives decision matrix D1
Q17	Which best describes your phone?	Multiple choice	Smartphone with NFC (tap-to-pay works) / Smartphone, but I don't know if it has NFC / Smartphone without NFC / I do not carry a smartphone regularly	Yes	Feasibility of phone-based credential (A3)
Q18	Do you have any need that affects how you use the gate (e.g., difficulty reaching into a bag, low vision, hearing, using a wheelchair, carrying a child or heavy equipment)? Optional; do not include anything you'd rather not share.	Short answer	—	No	Accessibility requirements (RQ8). Framed to avoid disclosing a diagnosis
Q19	If your ID stopped working at the gate, what would you expect to happen?	Checkboxes	Guard checks my photo and lets me in / I verify with a one-time code on my phone / I go to the security office / I am not allowed in until fixed / Other	Yes	Expectations for failure handling (FR-13, screen 12)
Q20	Is there anything else about entering campus, security, or privacy at the gate that you want to tell us?	Paragraph	—	No	Open qualitative capture

Question numbering note: Q11a/b appear in Section 2 for flow but are numbered to match the analysis tables in Section 11.

Pilot instructions: Run with 3–5 students. Check: completion time under 8 minutes; no question interpreted two ways; ranking grid works on mobile; option lists are exhaustive (watch "Other" frequency).

Appendix B. Security Guard Interview Protocol

Format: Semi-structured, 20–30 minutes, one interviewer and one note-taker. Conducted off-shift or during a quiet period, with permission from the security supervisor. Language: Hindi or English as the participant prefers; the protocol should be translated verbally where needed and the translation noted.

B.1 Introduction (read aloud)

Namaste / Hello. Thank you for speaking with us. We are students in a course on usable security at IIIT-Delhi. We are studying how campus entry works so that any future system is designed around the people who actually operate it. We want to learn from your experience; there are no right or wrong answers, and we are not evaluating you or your work. This will take about 20–30 minutes.

B.2 Consent statement (read aloud; see also Appendix C)

Your participation is voluntary. You can skip any question or stop at any time, and this will have no effect on your job. We will not record your name, employee ID, or which gate you work at in our report. We will take written notes. We will only record audio if you say yes, and we will delete the audio after we write it up. What you tell us will be combined with what other guards tell us and reported as a group, so no one can be identified. Do you agree to take part? [Record: Yes / No]
May we record audio? [Yes / No]

B.3 Core questions

#	Question	Topic	Follow-up probes
Q1	Can you walk me through what you do when a student comes to the gate, from the moment you see them to when they're through?	Current workflow	What do you look at first? How long does it usually take? Does it differ at the vehicle gate?
Q2	How do you decide the ID is genuine?	Verification	What features do you look for? Have you seen cards that looked wrong? What did you do?
Q3	How often do you recognise students by face rather than checking the card?	Verification / workaround	Is that more common at certain times? Do you feel that is reliable?
Q4	Do you check the validity or expiry date on the card?	Expiry	How easy is it to read? What happens if it's expired?
Q5	What do you do if the photo doesn't seem to match the person, or the card looks suspicious?	Suspicious / fake IDs	Who do you call? How long does it take? How often does this happen?
Q6	What happens when a student arrives without an ID card?	Forgotten ID	Is there a set procedure? Does it vary by guard or shift? What do students usually say?
Q7	If a student has lost their card, how would you know if someone else is using it?	Lost / stolen	Is there any list or notice you receive?
Q8	Tell me about the busiest times. What changes in how you check?	Busy periods / delays	How long do queues get? Do you ever have to speed up checks? What would help most at those times?
Q9	How do you handle visitors?	Visitors	What information do you write down? Who checks it? What happens with the register afterwards? What is hardest about visitors?
Q10	Have you used any electronic device or system at a gate here or elsewhere, e.g., a card reader, scanner, or tablet? What was your experience?	Device / network	What went wrong? What happened when the device or network failed? Was there a fallback?
Q11	If a screen showed you information about the person at the gate, what would you need to see to make a confident decision?	Information needed	Photo? Name? Roll number? Department? Hostel? Anything else?
Q12	Is there information about students that you think should not be shown to you, or that you'd be uncomfortable being responsible for?	Privacy	Phone numbers? Addresses? Why?
Q13	What training did you receive for gate duty, and how long did it take to feel confident?	Training	What would a new guard find hardest?
Q14	If you could change one thing about how entry works, what would it be?	Desired features	Why? What would you be worried about with an electronic system?

B.4 Additional questions for security office / ID cell (if accessible)

#	Question
A1	How is a new ID card issued? What documents and approvals are needed, and how long does it take?
A2	What happens when a student reports a lost or stolen card? Is the old card blocked anywhere?
A3	How are cards handled when a student graduates, withdraws, or is suspended?
A4	Who approves visitors, and how is the approval communicated to the gate?
A5	Are there areas or times with restricted access? How is that enforced today?
A6	If there is an incident (theft, intrusion), what records do you have to investigate who was on campus?
A7	Who would have administrative access to an electronic entry system, and what controls would you expect on that access?

B.5 Closing

Thank you. Is there anything you'd like to add or anything you'd prefer we not include? If you think of something later, here is how to reach us: [TEAM CONTACT].

B.6 Notes template (one per interview)

Interview code: G__ Date: ____ Duration: ____ min
 Interviewer: ____ Note-taker: ____
 Shift type (morning/afternoon/night): ____ Gate type (pedestrian/vehicle/both): ____
 Years of experience at this campus (approx.): ____ Audio consent: Y / N

 Q1 Workflow:
 Q2 Genuine check:
 Q3 Face recognition:
 Q4 Expiry:
 Q5 Suspicious ID:
 Q6 Forgotten ID:
 Q7 Lost card:
 Q8 Busy periods:
 Q9 Visitors:
 Q10 Devices/network:
 Q11 Info needed:
 Q12 Info NOT to show:
 Q13 Training:
 Q14 One change / worries:

Verbatim quotes worth keeping (mark with "):
 Observed emotions / emphasis:
 Contradictions with observation or other interviews:
 Follow-up needed:

Appendix C. Participant Information and Consent Statement

Project: Campus Entry Authentication System — Phase 1 User Study Course: CSE 347/652 | DES 306/525 Usable Security and Privacy, IIIT-Delhi, Monsoon 2026 Team contact: [TEAM CONTACT E-MAIL] Course instructor: Dr. Arun Balaji Buduru

What is this study? We are a student team studying how people enter the IIIT-Delhi campus and how the process could be made more secure, more private and easier to use. This is coursework, not an official institutional project.

What will I be asked to do? Depending on the activity: (a) complete an anonymous online questionnaire of about 6–8 minutes; or (b) take part in an interview of about 20–30 minutes; or (c) be present in a public area (the entry gate) where we observe the general process without recording individuals.

What information do you collect? For the questionnaire: only your answers; no name, roll number, e-mail or phone number. For interviews: written notes, and audio only if you separately agree; no name or employee ID. For observation: counts and timings of the process and general notes about the environment; no names, faces, photographs, card details or vehicle numbers.

How is it stored and for how long? On a password-protected drive accessible only to the team, reported only in aggregate, and deleted at the end of the course (December 2026).

Voluntary participation. You do not have to take part. You can skip any question or stop at any time without giving a reason. For staff: taking part or not taking part has no effect on your employment and no individual's performance is assessed or reported.

Risks and benefits. We do not anticipate any risk. There is no direct benefit or payment. The results may help improve campus entry design.

Contact. For questions about the study, contact the team. For concerns about how the study is conducted, contact the course instructor.

Consent (interview: read aloud and record verbally; questionnaire: shown as first page)

I have read / been told the information above. I understand my participation is voluntary and anonymous. I agree to take part. Interview only: I agree to audio recording: Yes / No

Appendix D. Contextual Inquiry (Observation) Protocol

Purpose. Establish ground truth for how entry actually happens: step count, timing, queue behaviour, guard actions, exceptions, and environmental constraints. Interviews tell us what people believe they do; observation shows what happens.

Type. Non-participant, non-interfering observation in a public area. Observers do not speak to people in the queue, do not handle cards, do not photograph or film, and do not ask guards questions during the session (questions go to the interview).

D.1 Pre-conditions

- Written or e-mail permission from the security supervisor; inform the guards on shift before starting.
- Observers wear visible college IDs and stand where the supervisor agrees, out of the flow.
- Stop immediately if asked by security staff or if an incident occurs.

D.2 Sessions

Session	Target window	Rationale
S1	Morning peak (e.g., 08:30–09:15)	Maximum load; queue formation; speed pressure
S2	Off-peak (e.g., 14:30–15:15)	Baseline behaviour without pressure
S3	Evening / hostel return (e.g., 21:30–22:15)	Low light; different guard shift; visitor sign-out
S4 (optional)	Second gate, any window	Compare gates

Two observers per session: Observer A times individuals; Observer B writes field notes and counts queue length every 2 minutes.

D.3 Timing method

- Use a stopwatch app with lap function.
- T0: person reaches the guard's position (front of queue). T1: person passes the gate line or is turned away. Record T1–T0 in seconds.
- Classify each timed person as: U (uncontested: card shown or not, no stop), Q (questioned: guard stops and speaks), N (no card visible), V (visitor), R (refused).
- Time at least 30 consecutive people per session, or the whole session if fewer.
- Record queue length (number waiting behind the person at the guard) at 2-minute intervals.

D.4 Observation checklist (Observer B)

Environment

- ☐ Lighting (adequate / dim / glare)
- ☐ Weather / shelter for guard and queue
- ☐ Noise level
- ☐ Position of guard relative to flow; is there a desk, booth, barrier, turnstile?
- ☐ Power outlet / network equipment visible?
- ☐ Space available for a reader or display; would a queue block it?

Process

- ☐ How does the guard signal "go ahead"? (nod, gesture, verbal, nothing)
- ☐ Where is the card when shown? (in hand, on lanyard, waved from distance, not shown)
- ☐ Does the guard ever look at the expiry date? Turn the card over?
- ☐ Does the guard compare photo to face? For how long?
- ☐ Does behaviour change when the queue grows? At what length?
- ☐ Are groups checked individually or as a group?
- ☐ Vehicle gate: what is checked and from what distance?

Exceptions (record each occurrence with time, type, duration, outcome)

- ☐ No card
- ☐ Guard questions holder
- ☐ Guard calls someone
- ☐ Refusal
- ☐ Visitor registration: steps, what is written, who writes, time taken, where the register sits and who can read it
- ☐ Any apparent workaround (e.g., friend passing card back, guard waving group)

Guard workload

- ☐ Concurrent duties (phone, vehicle barrier, register, radio)
- ☐ Number of guards present
- ☐ Interruptions

D.5 What to record

- Counts, durations, queue lengths, classification codes (U/Q/N/V/R).
- Environmental conditions and physical constraints.
- Descriptions of process and behaviour in general terms ("guard asked holder a question", not what was asked if it contained personal detail).
- Time-stamped exceptions and their outcomes.

D.6 What NOT to record

- Names, roll numbers, faces, photographs, video, audio.
- Card contents, vehicle registration numbers, visitor register contents.
- Identifying details of individual guards (name, badge, appearance).
- Conversations between guard and student beyond their general nature.
- Anything a guard or student asks you not to record.

D.7 Ethical considerations

- The gate is a public space and the observed behaviour is public; however, individuals have not consented, so the protocol collects only non-identifying aggregate data.
- Guards are informed in advance and may decline; observation of a guard who declines does not proceed.
- Observers must not create the impression of auditing or reporting on individual guards. The consent statement (Appendix C) is available to any guard who asks.
- If observers witness a security incident, they do not intervene and do not record identifying details; they note only "incident occurred, observation paused".

D.8 Field note sheet (per session)

Session: S_ Date: ____ Window: ____-____ Gate: ____ Observers: ____ / ____
 Guards present: ____ Weather/light: ____ Concurrent guard duties: ____
 Queue length at 2-min intervals: _____
 Timed persons (code, seconds): U 4, U 3, Q 22, N 15, ...
 Exceptions log:
 hh:mm type duration outcome note
 Process notes:
 Environment notes:
 Workarounds observed:
 Questions for interviews:

Timings are entered into `Data_Collection_Template.xlsx` (Appendix E), sheet "Observation".

Appendix E. Data Collection Template

See `02_User_Studies/Data_Collection_Template.xlsx` (sheets: Questionnaire_Raw, Likert_Summary, Frequencies, Interview_Notes, Observation, Affinity_Themes, Hypothesis_Verdicts). All sheets are empty templates; formulas compute once real data is entered.

Appendix F. Requirements Matrix

See 03_Requirements/Requirements_Traceability_Matrix.xlsx (sheets: Finding→Screen→Test, FR, SEC, PRIV, USE, NFR, Scenario_Coverage, Req→Screen→Test, Coverage_Check). Narrative version in Section 37.

Appendix G. Threat Model

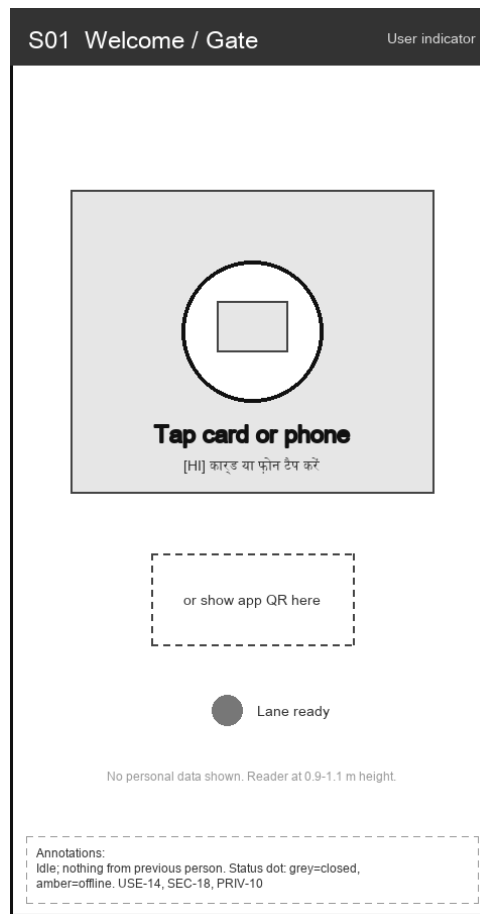
Full table in Section 24.3; attack tree in Appendix J, Figure J-9.

Appendix H. Risk Register

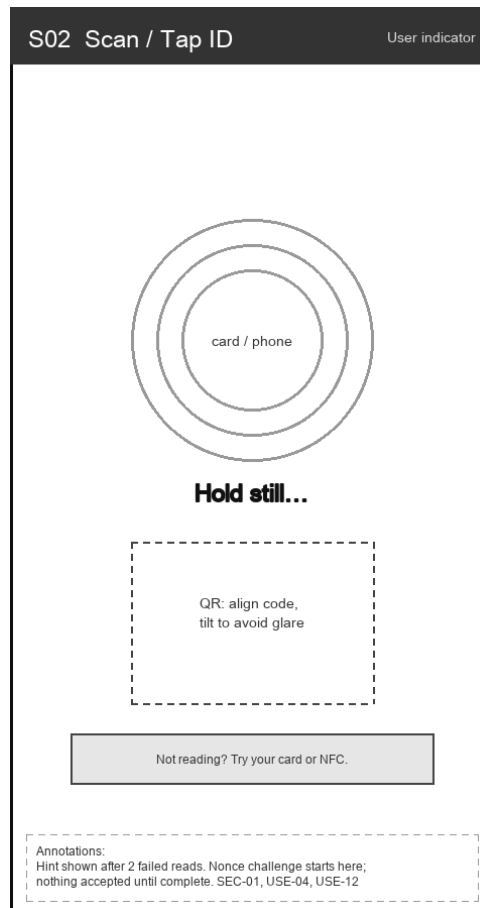
See `04_Threat_Model/Risk_Register.xlsx` (sheets: Risk_Register with Likelihood × Impact scores, Threat_Actors, Assets, Residual_Risks). Ratings are labelled team judgements, to be revisited after primary data and Phase 2 testing.

Appendix I. Prototype Screens

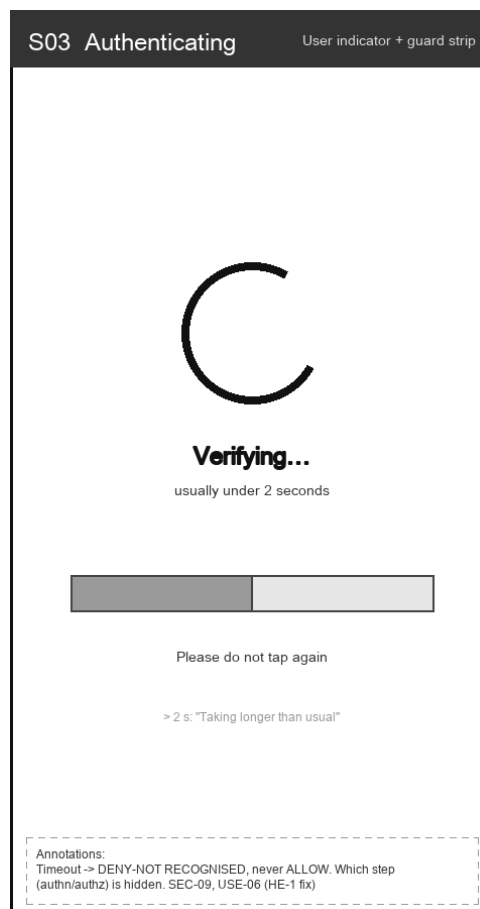
Twenty lo-fi wireframes; per-screen specifications in Section 35.2. Also provided as PNG in `06_Prototype/screens/`.



S01 — Welcome Gate



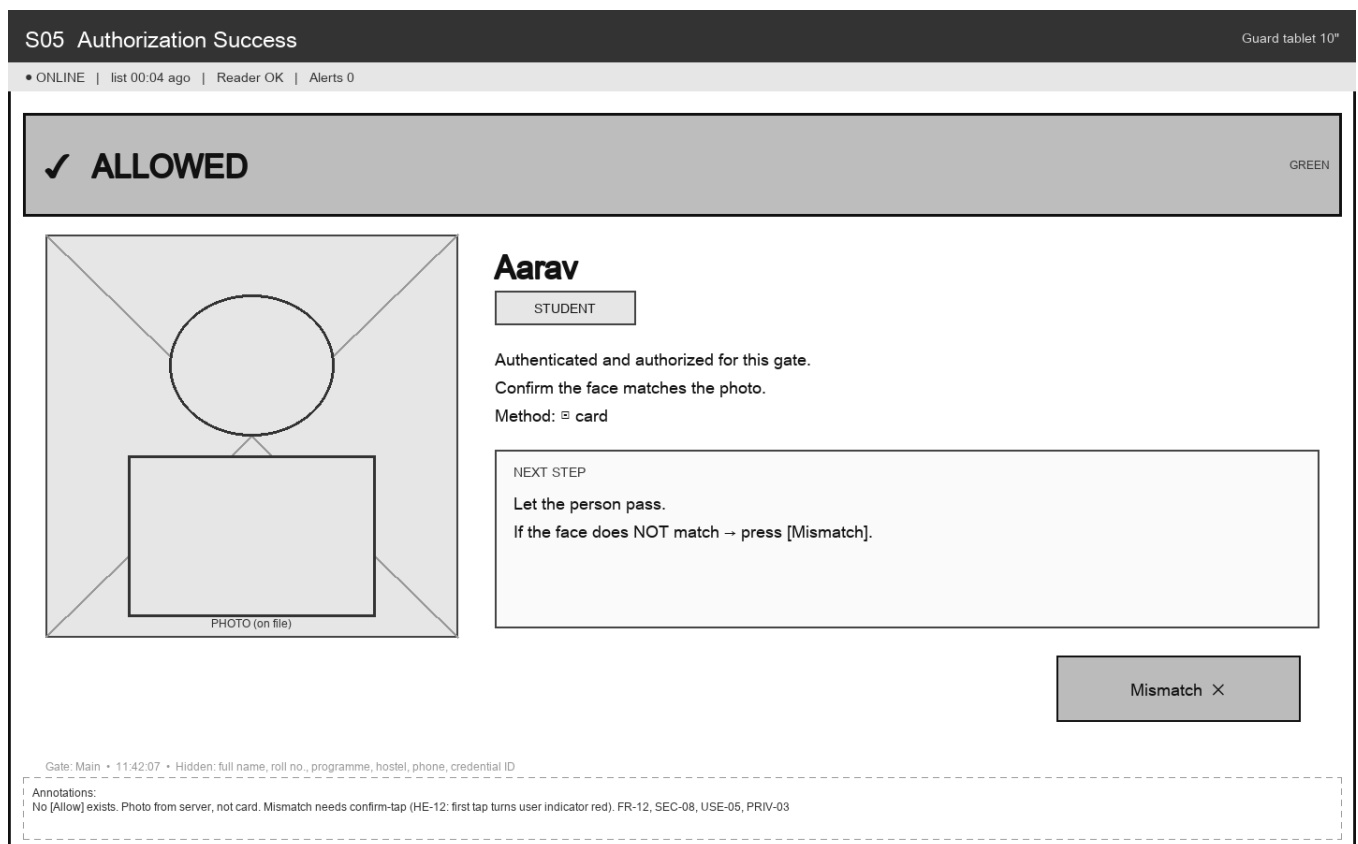
S02 — Scan Tap



S03 — Authenticating



S04 — Auth Success



S05 — Authorization Success

S06 Access Denied — Not Recognised

Guard tablet 10"

• ONLINE | list 00:04 ago | Reader OK | Alerts 0

× NOT RECOGNISED

RED

No identity known
(authentication failed)

The reader could not verify this card or code.
This can happen with damaged, copied or
non-campus credentials.

NEXT STEP

Do not admit.
Direct the person to the Security Office.
If they insist → [Call supervisor].

Call supervisor

Done

Gate: Main • 11:42:07 • Hidden: full name, roll no., programme, hostel, phone, credential ID

Annotations:

Authentication failure: no identity. Guard never judges card authenticity. User side: generic red message. S06b variant (NOT PERMITTED here/how) is AMBER with photo. SEC-01, SEC-04, USE-03, HE-15 wording

S06 — Access Denied Not Recognised

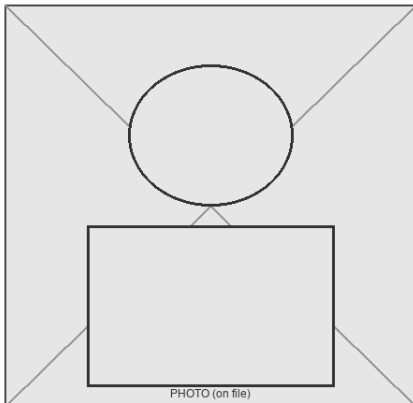
S07 Credential Expired

Guard tablet 10"

• ONLINE | list 00:04 ago | Reader OK | Alerts 0

! EXPIRED

AMBER



Meher

STUDENT

Credential validity has ended.
Identity is known; entry not authorized.

NEXT STEP

Do not admit.
Direct to the ID cell for renewal.
Person says they are a current member → [Call supervisor].

Call supervisor

Done

Gate: Main • 11:42:07 • Hidden: full name, roll no., programme, hostel, phone, credential ID

Annotations:

Authorization failure, identity known. Student gets private explanation in app. User side: 'Credential expired — renew at ID cell'. SEC-03, USE-03

S07 — Credential Expired

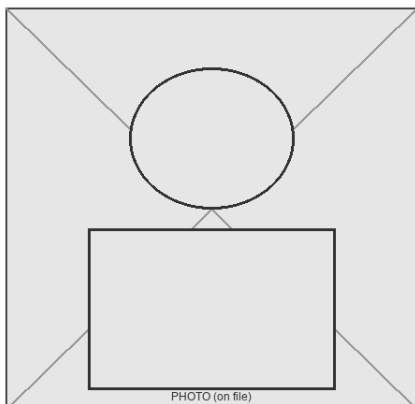
S08 Credential Revoked

Guard tablet 10"

• ONLINE | list 00:04 ago | Reader OK | Alerts 0

× REVOKED

RED



Meher

STUDENT

This credential has been revoked.
(Reason is not shown to gate staff.)

NEXT STEP

Do not admit.
Direct to the Security Office.
Do not discuss the reason.

Call supervisor

Done

► Event flagged for supervisor review

Gate: Main • 11:42:07 • Hidden: full name, roll no., programme, hostel, phone, credential ID

Annotations:
Reason withheld (lost vs disciplinary). Flagged automatically. User side identical to S06 for bystanders. SEC-02, SEC-08, DP-13

S08 — Credential Revoked

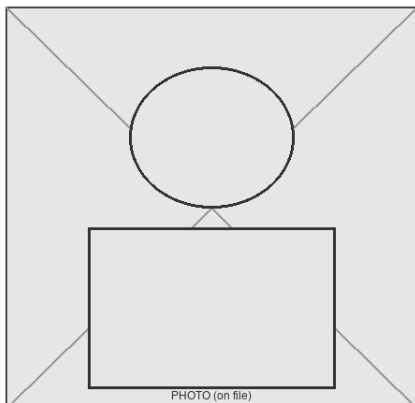
S09 Suspicious Credential

Guard tablet 10"

• ONLINE | list 00:04 ago | Reader OK | Alerts 0

× SUSPICIOUS — SUPERVISOR ALERTED

RED



Aarav

STUDENT

Repeated failed attempts or face mismatch recorded.
Supervisor has already been notified.

NEXT STEP

Do not admit.
Keep the person at the gate if safe to do so.
Wait for supervisor. Supervisor will clear this alert.

Call supervisor

Done

► Event flagged for supervisor review

Gate: Main • 11:42:07 • Hidden: full name, roll no., programme, hostel, phone, credential ID

Annotations:
SEC-13 threshold or [Mismatch]. Reader rate-limited. Photo shown only if identity known. TH-02/04/06

S09 — Suspicious Credential

S10 Reader Failure

Guard tablet

• ONLINE | list 00:04 ago | Reader OK | Alerts 0 | Reader: FAULT

i READER OFFLINE — LANE 1

GREY

Cause: self-test failed / tamper detected / no power

This lane is disabled by the server until checked. The reader holds no secret keys.

NEXT STEP

Direct people to Lane 2 (reader OK).

If no other lane is available → start Manual Verification Mode (supervisor PIN).

Report reader problem

Start Manual Verification Mode (PIN)

Call supervisor

Technical diagnostics are available to the auditor, not here.

Annotations:

Reader disabled server-side; tamper logged; cert revocable. Manual mode requires supervisor. SEC-18, FR-14, FR-19, USE-06

S10 — Reader Failure

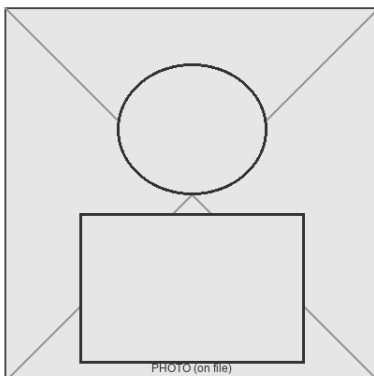
S11 Network Failure (Offline-verified)

Guard tablet

• OFFLINE — verifying locally | Last update from server: 1 h 20 m ago (limit 4 h) | Reader OK | Alerts 0

✓ ALLOWED

GREEN

**Aarav**

STUDENT

Normal checks continue using cached keys and the signed revocation list.

Events are stored on the reader and sent when the connection returns.

IF LIMIT (4 h) IS REACHED

A dialog will require Manual Verification Mode (supervisor PIN).

Until then, work normally.

Mismatch ✕

Annotations:

Bounded staleness visible as plain language (HE-2 ftx). Automatic transition at limit; no auto-ALLOW. SEC-19, FR-14, USE-06

S11 — Network Failure

S12 Manual Verification / Fallback

Guard tablet (or paper form)

• MANUAL VERIFICATION MODE | supervisor: SUP-07 approved start | Reader OK | Alerts 0

All entries in this mode are recorded with your ID and reviewed.

1	Ask for card or app screen	
2	Compare face with the card photo	
3	Credential shown:	CardPhoneNone
4	Photo check:	MatchesDoes not match
5	Supervisor approval:	Request supervisor approval (PIN)Approve next 10 min (SUP)
6	Result:	Admit / Do not admit (set by supervisor)

! No roster lookup. No personal data typed. Egress is never blocked. [Emergency ingress — supervisor only, reason required]

Annotations:

Weakest mode by design: every decision carries guard + supervisor IDs, flagged. HE-6: collapse to 3 big steps in next iteration. FR-14, FR-19, FR-20, TH-17

S12 — Manual Verification

S13 Visitor Registration (host request)

Host web/app • guard-tablet variant inset

Request a visitor pass

Visitor name

Dr. Fernandes

Purpose (category)

▾ Academic / Official / Personal / Vendor

Date

01 Oct 2026

Time window

14:00 — 17:00 (max 12 h, policy)

Gate(s)

☒ Main ☐ East ☐ Vehicle

Send pass to

e-mail or phone — used ONLY to deliver the pass; deleted at visit end

Submit request

Cancel

GUARD VARIANT — Visitor without approval

Host (search by name / department)

Prof. R... — CSE

Visitor first name

Send approval request to host's phone

Waiting for host... (no entry until approved)

Guard never enters or sees visitor contact details.

Annotations:

Purpose is a category, not free text. Max window enforced (HE-5). Guard variant: no typing beyond host name. FR-10, PRIV-09, SEC-16

S13 — Visitor Registration

S14 Visitor Approval Approver / host phone

Approval request

Visitor: Dr. Fernandes

Purpose: Academic

Date: 01 Oct 2026

Window: 14:00 — 17:00

Gate: Main

Requested by: Prof. R... (CSE)

Source: gate walk-in • waiting 0:42

Approve

Decline

Edit window

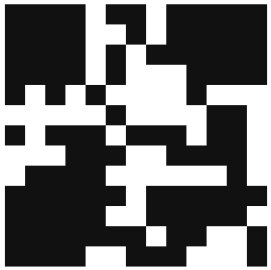
Approving creates a signed, single-entry pass.

Annotations:
MFA session; decision logged. Visitor contact not shown (not needed to decide). SEC-12, PRIV-01

S14 — Visitor Approval

S15 Temporary Visitor Credential / printed slip

VISITOR PASS



Dr. Fernandes

Host: Prof. R... (CSE)

Valid: 01 Oct 2026, 14:00 — 17:00

Gate: Main • Single entry

Show this at the gate. Do not forward.
Data deleted 30 days after your visit.

Annotations:
Server-signed token (window, gate set, use count). No personal data in QR beyond pass ID. HE-14; host first name + dept. SEC-16, PRIV-07

S15 — Temporary Visitor Credential

S16 Security Guard Dashboard

Guard tablet — home

• ONLINE | last update 00:04 ago | Reader OK | Alerts 0 | 11:42 | ?

Waiting for tap...

Result appears here for 5 s, then clears

ALERTS (3 shown, 0 more)

▶ 11:31 Suspicious — C-7f3a... (supervisor ack.)

▶ 10:58 Mismatch recorded — Lane 1 (open)

i 09:12 Reader Lane 2 self-test OK after restart

Visitor without approval

Call supervisor

Report reader problem

? Legend

Today at this gate: entries 1,284 • denied 17 • manual 0 (aggregate only — no list of who entered)

Annotations:

No search; no identity list. Alerts show pseudonym until person is at gate. HE-8 cap, HE-10 legend added. SEC-07, PRIV-03, USE-06

S16 — Guard Dashboard

S17 Admin Credential Management

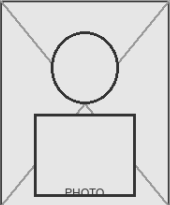
Issuer console

Role: ISSUER • MFA ✓ (TOTP) • session 14:59

Roster search

Meher S... / MT2026...

Search



Meher S...
Roll: MT2026...
Programme: M.Tech CSE
Role: STUDENT

Fields stored: only these.
No phone / address / hostel.

Issue new card

Send phone enrolment

Key material: present in HSM (never displayed)

CREDENTIALS

Card4821

REVOKED

lost — reported 28 Sep 2026

Card9130

ACTIVE

valid to 31 Jul 2028

Renew Suspend Revoke

Phone (Android)

ACTIVE

enrolled 28 Sep 2026

Suspend Revoke

CONFIRM: Revoke Card9130?

Reason: • Lost / Stolen / Disciplinary / Left

Effect: denied at all 6 gates within 30 s. Cannot be undone.

Cancel

Revoke permanently

Annotations:

Roster match required to issue; two-step confirm with exact effect; reason dropdown; all logged. Issuer ≠ Auditor. FR-07, SEC-07, SEC-11, SEC-12, USE-10

S17 — Admin Credential Management

104

S18 Lost ID / Revoke Credential Student app

My credentials

Card9130
Tap to manage

ACTIVE

Phone (this device)

ACTIVE

Report card lost or stolen?

- This will PERMANENTLY disable card9130.
- Your phone credential keeps working.
- A replacement request will be created.
- This cannot be undone.

Type DISABLE to confirm:

DISABLE

Report and disable

Cancel

Annotations:
Self-service, immediate, irreversible (HE-13: typed confirm).
After: card REVOKED, Replacement requested — collect at ID cell
with photo ID*. FR-09, SEC-17, USE-10.

S18 — Lost ID Revoke

S19 Entry Logs Auditor console

Role: AUDITOR • MFA ✓ • Chain verified ✓ (last checkpoint 12:00)

Filters: Gate • Main From • 01 Oct 00:00 To • 01 Oct 12:00 Decision • All Method • All ☒ Flagged only

Time	Gate	Method	Decision	Credential (pseudonym)	Flags	Guard ID
11:31:02	Main	card	DENY-SUSPICIOUS	C-7f3a9c...	▶ velocity	— Re-identify
10:58:41	Main	card	DENY-SUSPICIOUS	C-21be0d...	▶ mismatch	G-14 Re-identify
09:40:17	Main	manual	ALLOW (manual)	— (type: card)	▶ manual	G-14 / SUP-07 Re-identify
08:52:09	East	QR	DENY-REVOKED	C-9a0f31...	▶ revoked	— Re-identify
08:51:55	Main	NFC	ALLOW	C-0cd7e2...		— Re-identify

No edit or delete controls exist on this screen. Export is pseudonymous.

RE-IDENTIFY C-7f3a9c...

Case reference (required)

SEC-2026-0142

Justification (required)

! This action is logged and visible to the second administrator.

Cancel Confirm

Annotations:
Pseudonymous by default; re-identification justified + logged + visible to second admin; chain integrity indicator. SEC-10, SEC-15, PRIV-04, PRIV-06, FR-15

S19 — Entry Logs

S20 Privacy / Access-Control

Student app (left) · Policy admin (right)

STUDENT — Privacy & my data

What is collected

name, roll no., programme, photo, role, credential status, entry events (pseudonymous)

Why

access decisions; security incidents; system integrity. NOT attendance or tracking.

Who can see it

Guard: photo + first name + role, only when you tap. Auditor: pseudonymous; re-identify only with a case ref.

How long

entry events 90 days; flagged events until case closed + 1 year

My entry records (last 90 days)

01 Oct 08:51 Main NFC ALLOW • 30 Sep 21:14 Main card ALLOW • ...

My credentials

Card ---9130 ACTIVE • Phone ACTIVE • [Request correction] [Full notice]

POLICY ADMIN — Gate access policy (v12, edited by PA-02, 29 Sep)

Gate	Students	Staff	Visitors (pass)	Contractors
Main	06:00–23:00	24 h	pass window	08:00–18:00
East	06:00–22:00	24 h	pass window	DENY
Vehicle	DENY	24 h	pass window	08:00–18:00
Any other role	DENY	DENY	DENY	DENY

Last row is the secure default and cannot be edited.

CONFIRM policy change

Gate: East • Role: Students

Before: 06:00–22:00 After: 06:00–23:00

Applies to 2 readers. MFA step-up required.

Change is versioned and logged (v13).

Cancel

Apply (MFA)

Annotations:

Transparency + own-data access (DPDP). Deny-by-default made visible. Policy edits: MFA, before/after, versioned. PRIV-07, PRIV-08, FR-18, SEC-11, DP-3

S20 — Privacy Access Control

Appendix J. Workflow Diagrams

Thirteen diagrams; also provided as PNG and SVG in [05_workflows/](#).

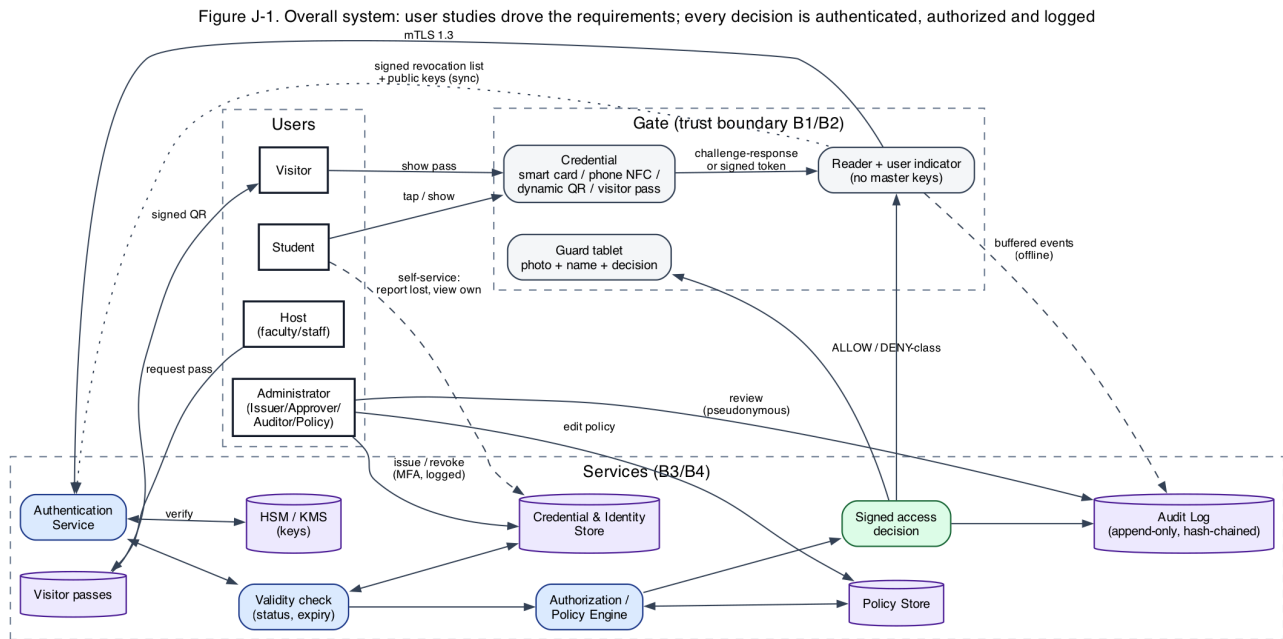


Figure J-1. Overall system

Figure J-2. Student authentication workflow (screens S01-S09, S16)

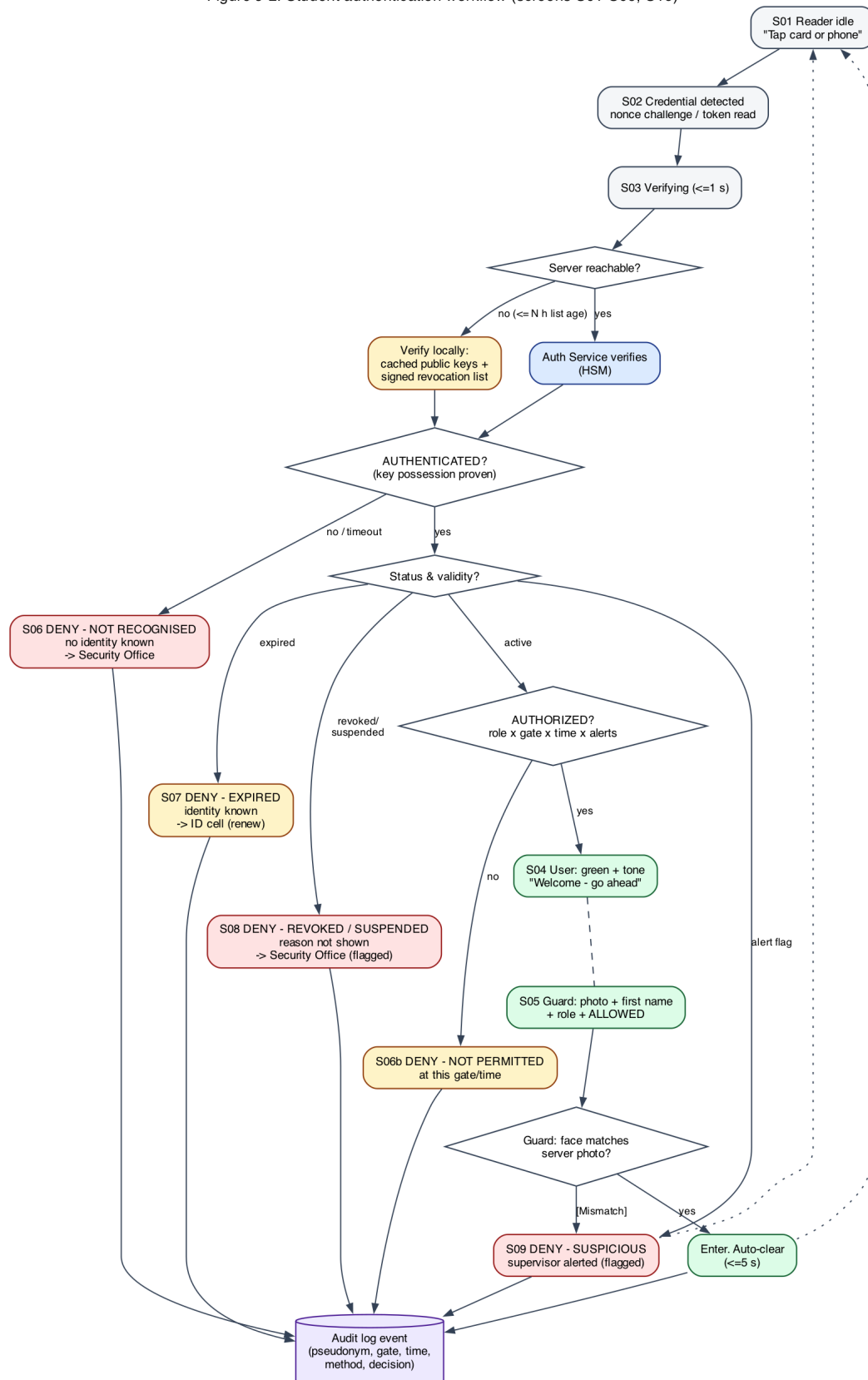


Figure J-2. Student authentication workflow

Figure J-3. Authentication ("Who are you?") is decided before and separately from Authorization ("Are you allowed here, now?")

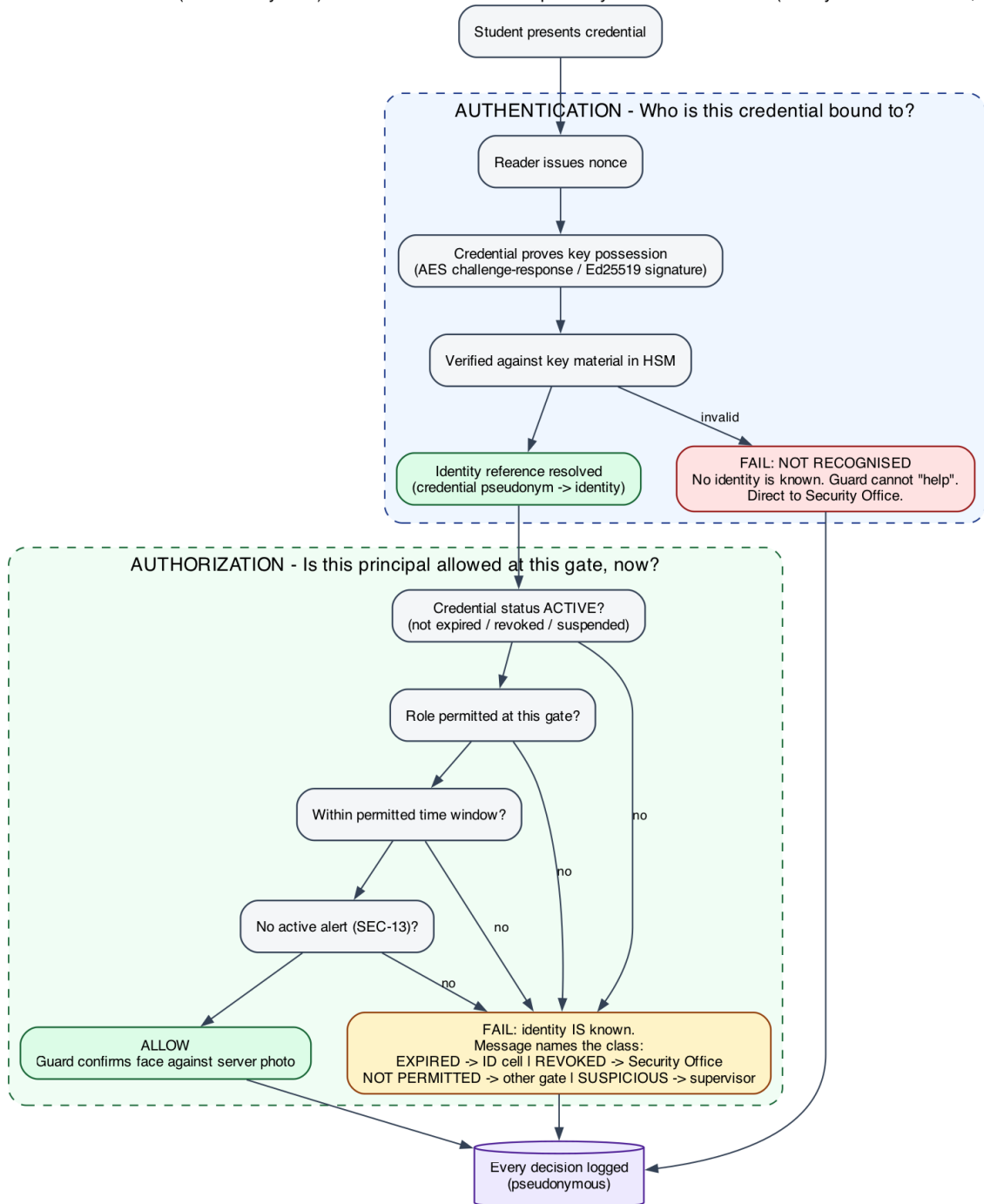


Figure J-3. Authentication vs authorization

Figure J-4. Credential lifecycle state machine (every transition is authenticated, authorized and logged - SEC-12)

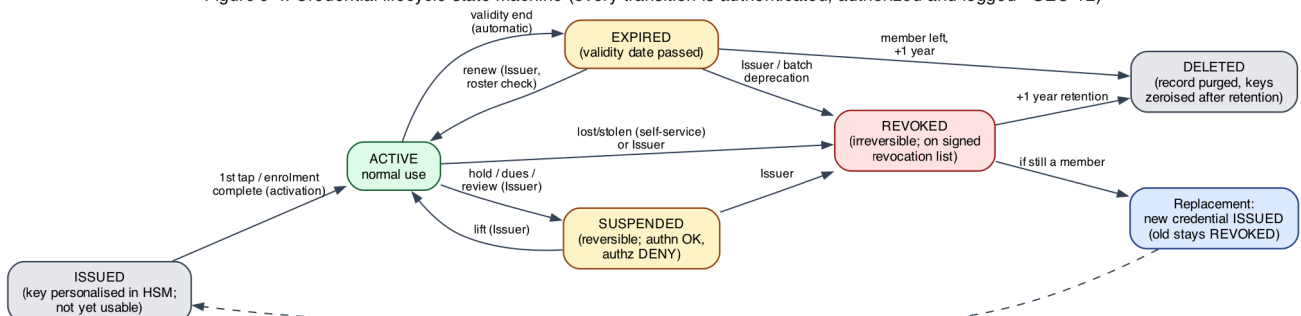


Figure J-4. Credential lifecycle

Figure J-5. Visitor access: host pre-approval or gate-initiated approval; time- and gate-bound signed pass; no paper register

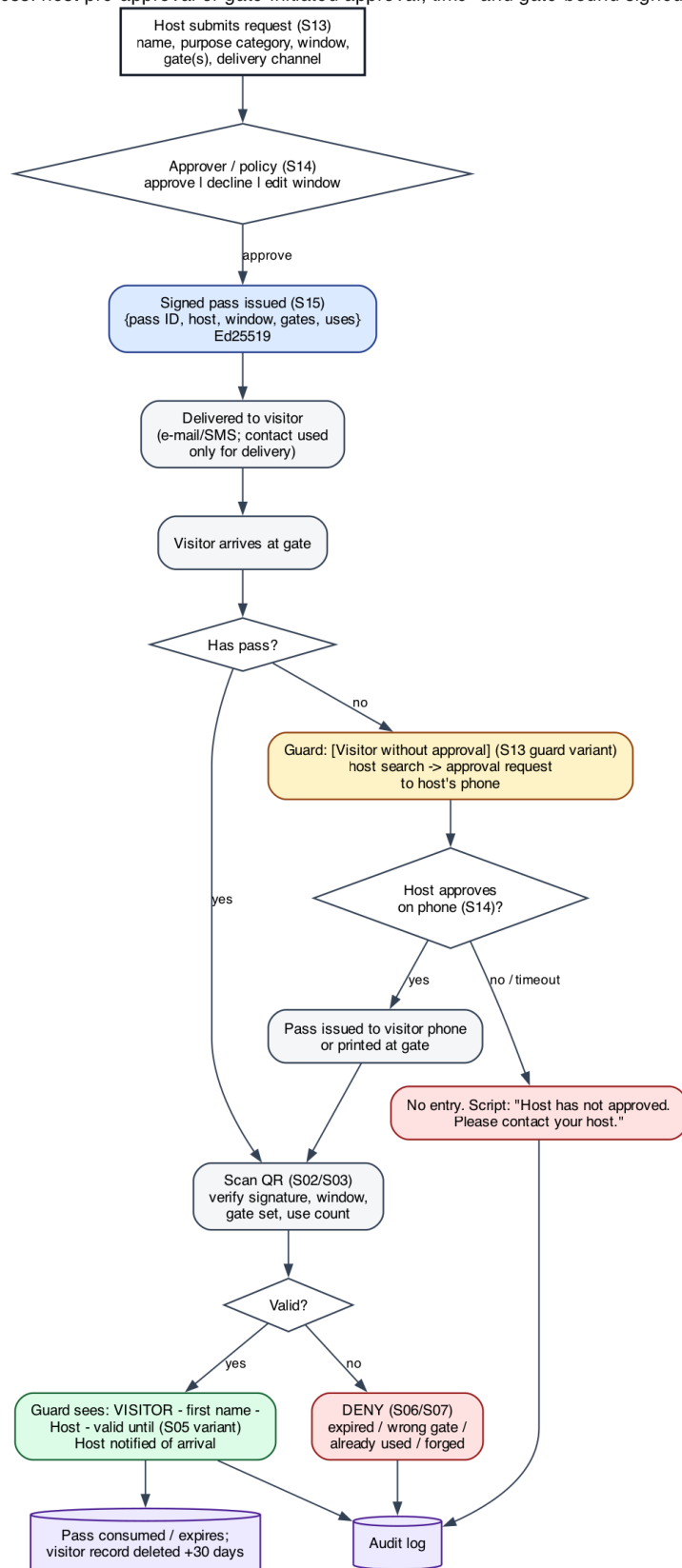


Figure J-5. Visitor access

Figure J-6. Lost or stolen credential: self-service immediate, irreversible revocation; access continues via phone credential

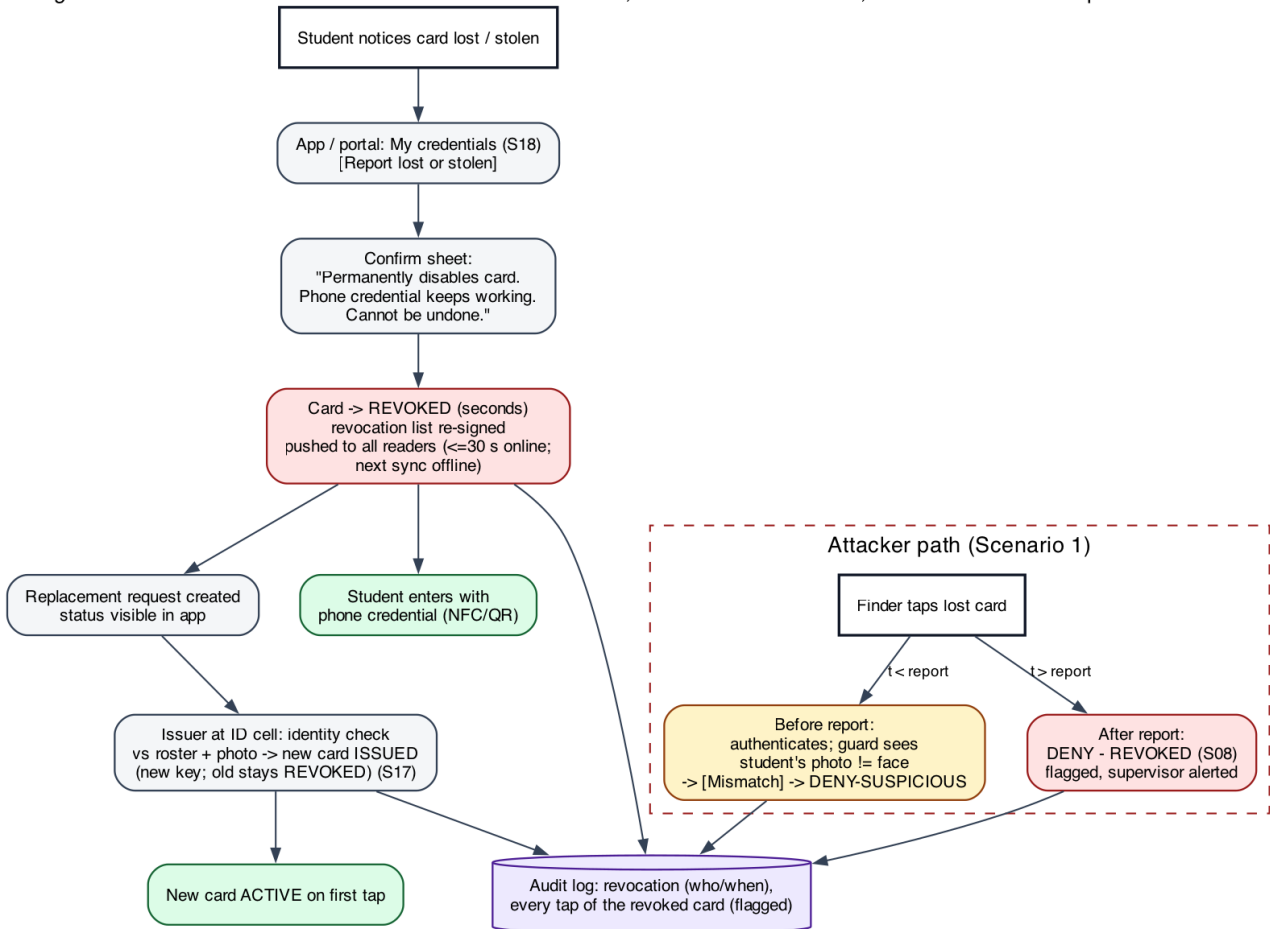


Figure J-6. Lost ID

Figure J-7. Authentication / authorization failure handling: no guard override exists; every DENY has a scripted next step

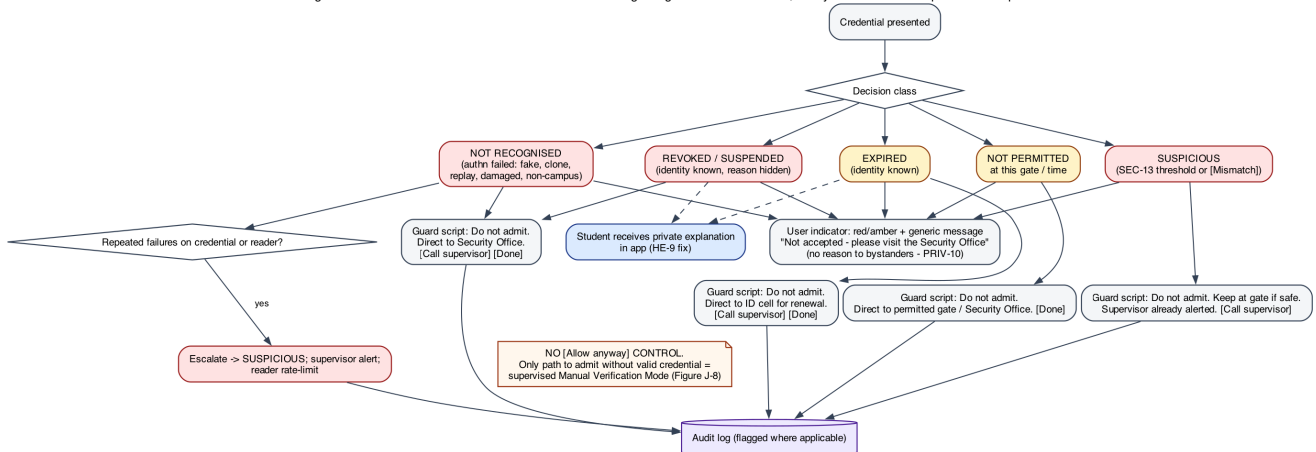


Figure J-7. Authentication failure handling

Figure J-8. Network / device failure: ordered degradation - online -> offline-verified (bounded) -> supervised manual -> emergency egress-only. No state auto-allows.

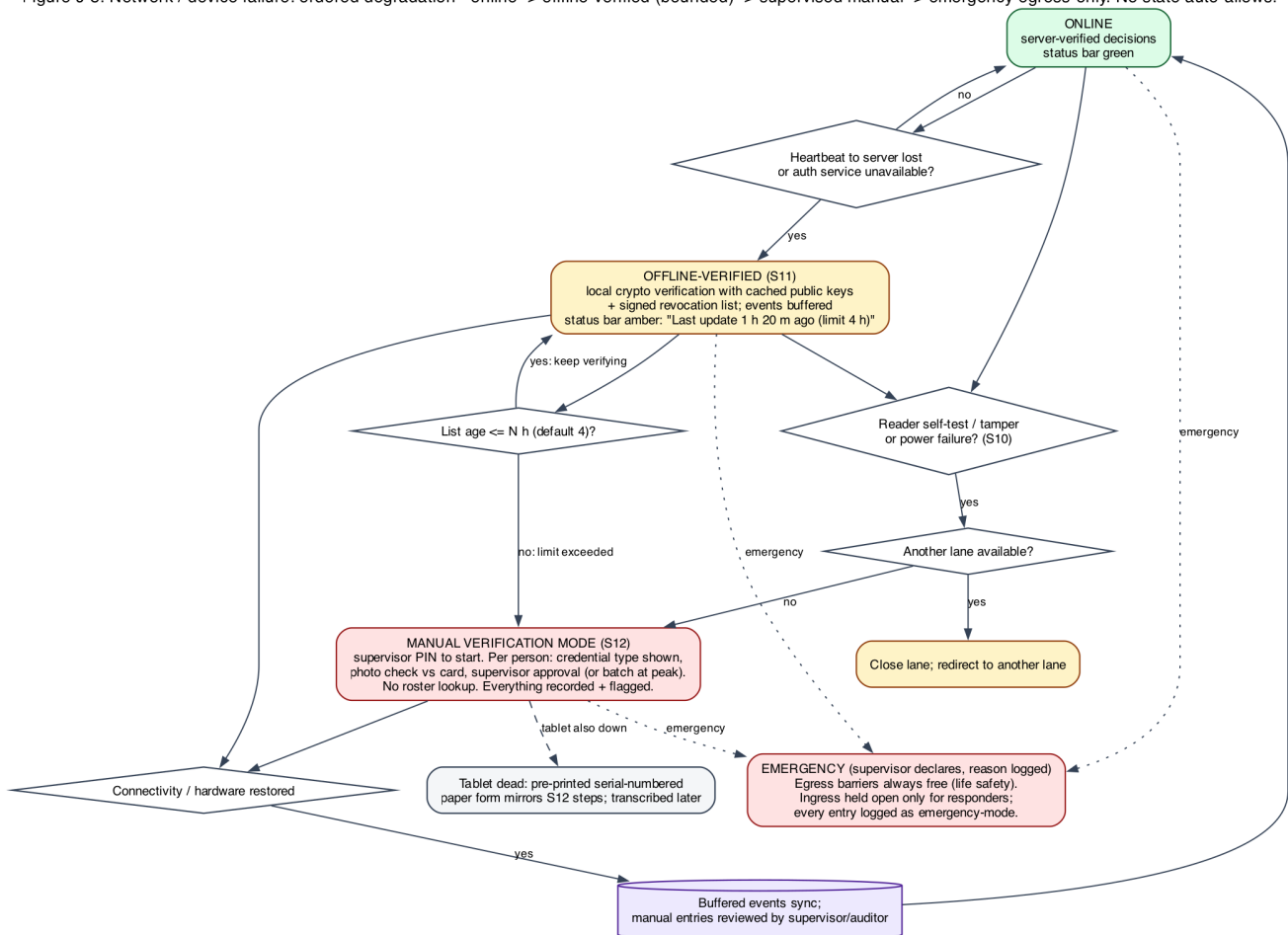


Figure J-8. Network / device failure

Figure J-9. Threat model as an attack tree. Root: unauthorised entry. Leaves show the controlling requirement(s).

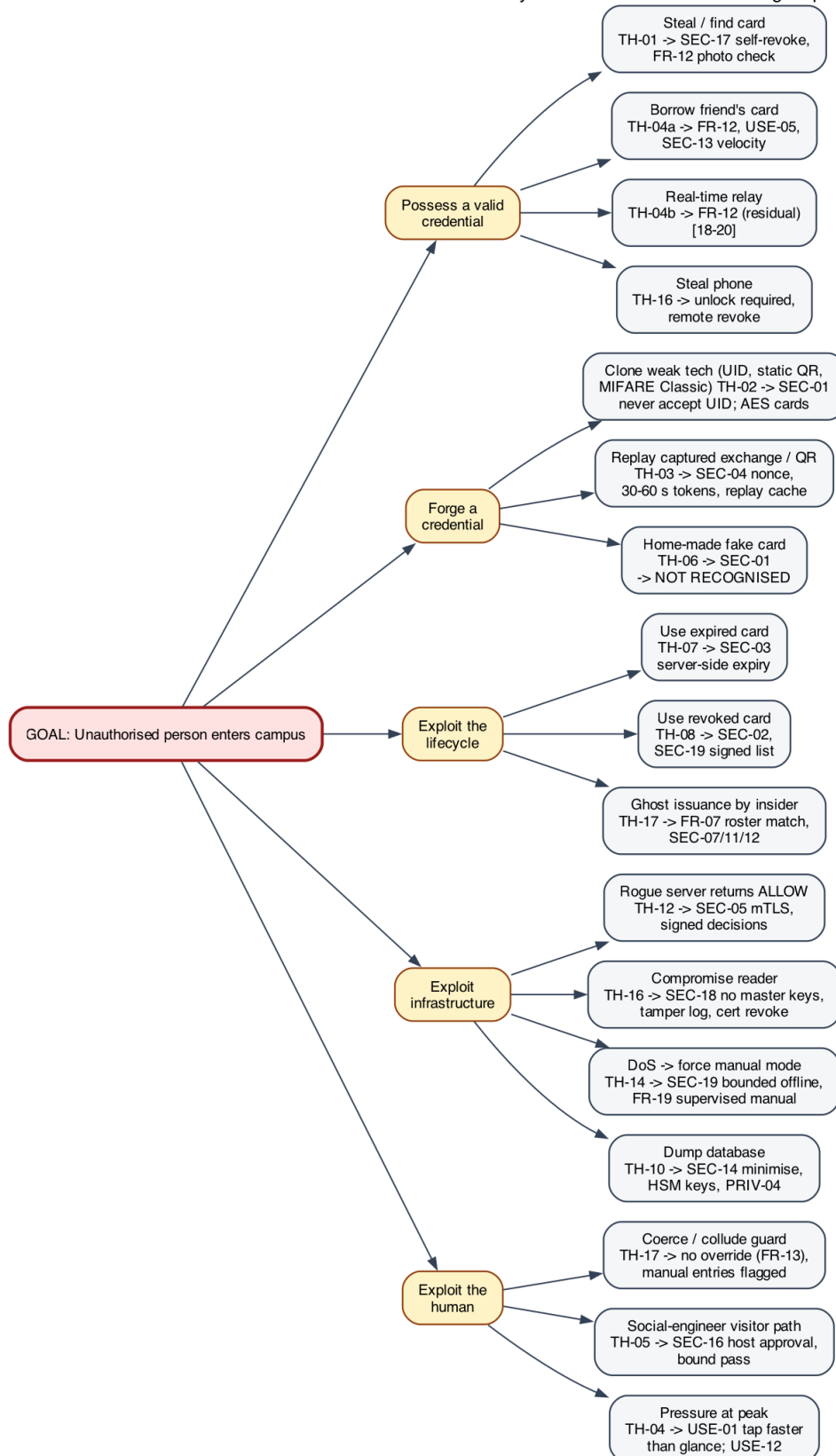


Figure J-9. Threat model attack tree

Figure J-10. Level-1 data flow diagram with trust boundaries (dashed), stores and sensitive flows (F1-F12)

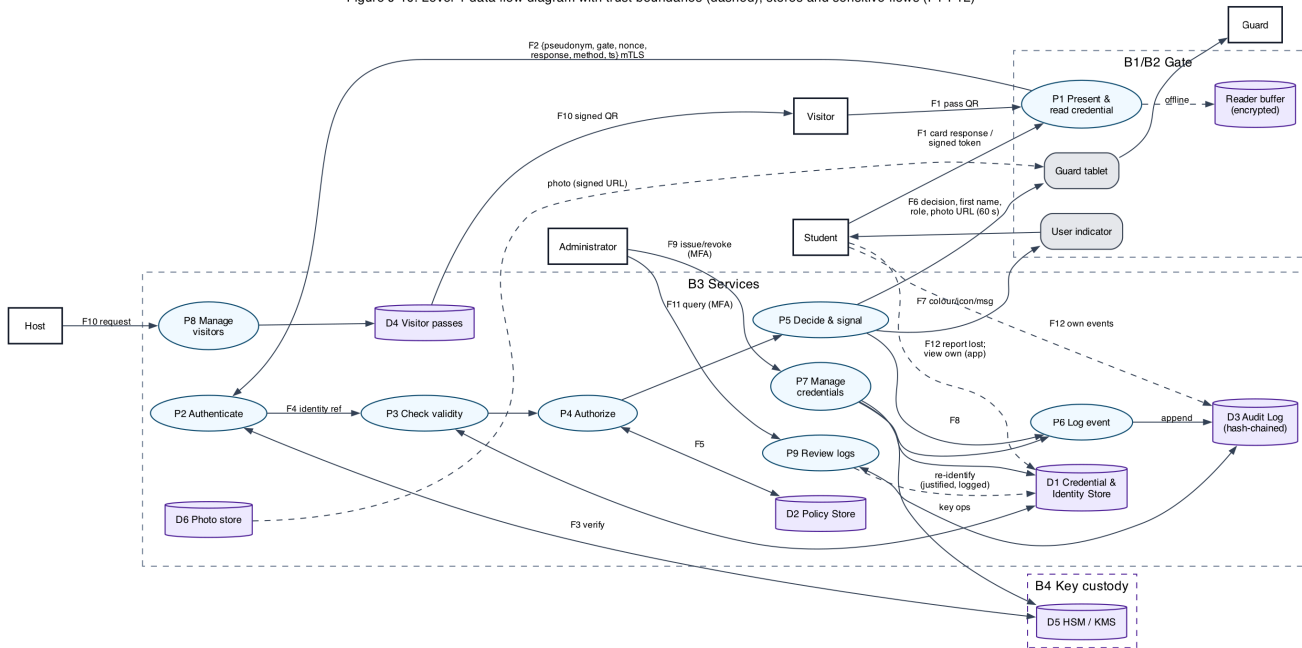


Figure J-10. Data flow diagram

Figure J-11. Privacy data flow: what is collected -> why -> who can access -> where stored -> how long -> deletion. Guard path holds only photo + first name + role.

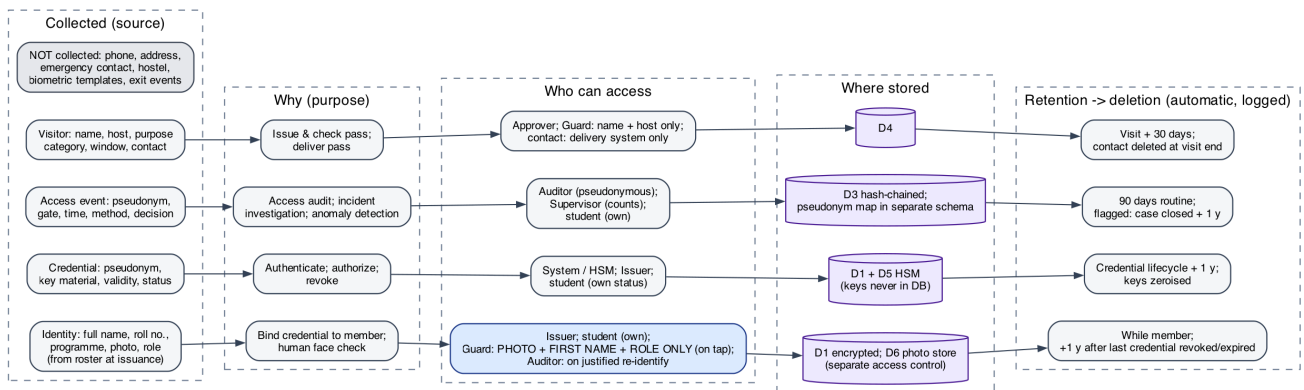


Figure J-11. Privacy data flow

Figure J-12. Administrative credential management (S17/S18): MFA, role check, roster match, two-step confirm, audit log

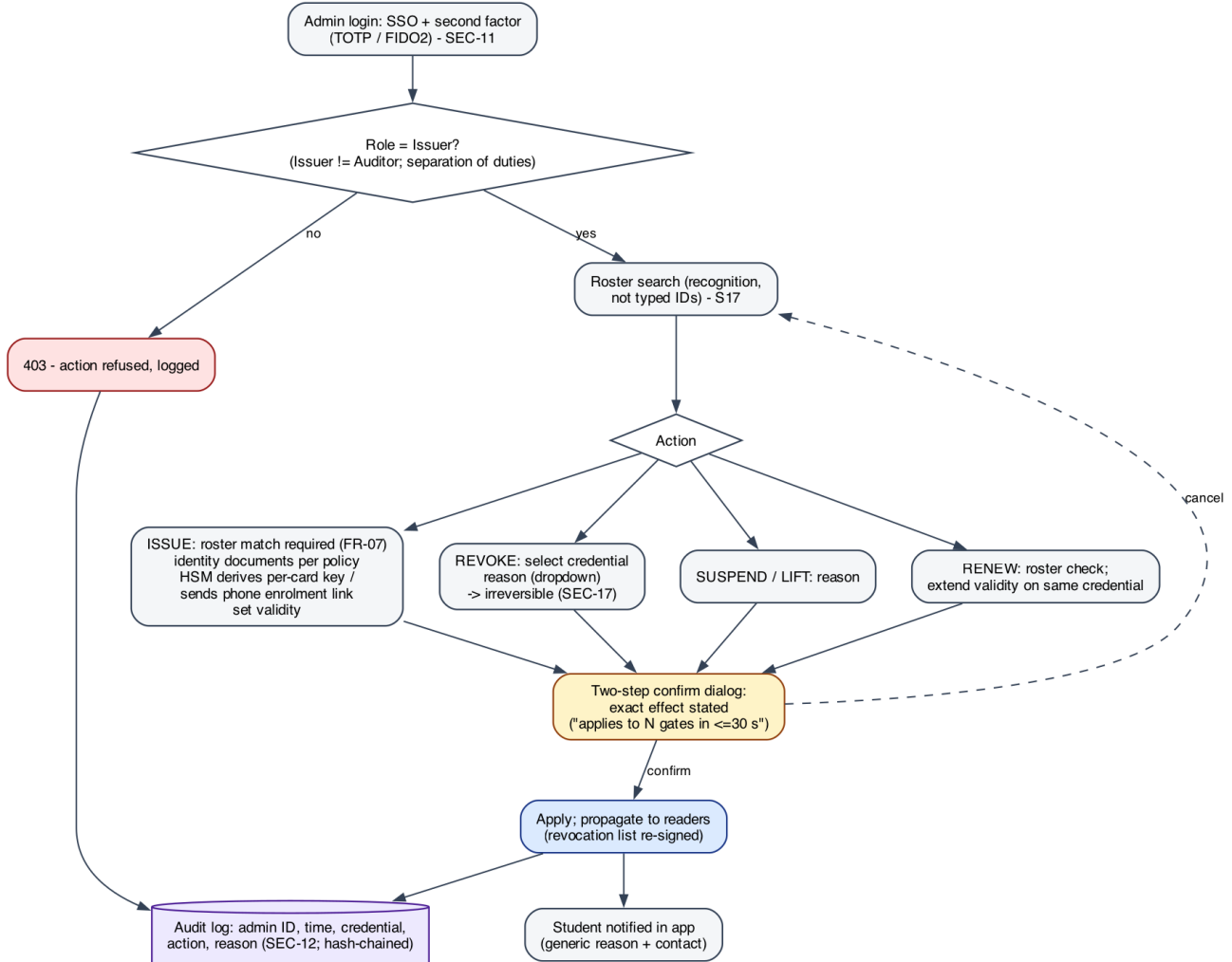


Figure J-12. Admin credential management

Figure J-13. Conceptual system architecture: trust boundaries B1-B7, sensitive data [brackets], attack surfaces and controls

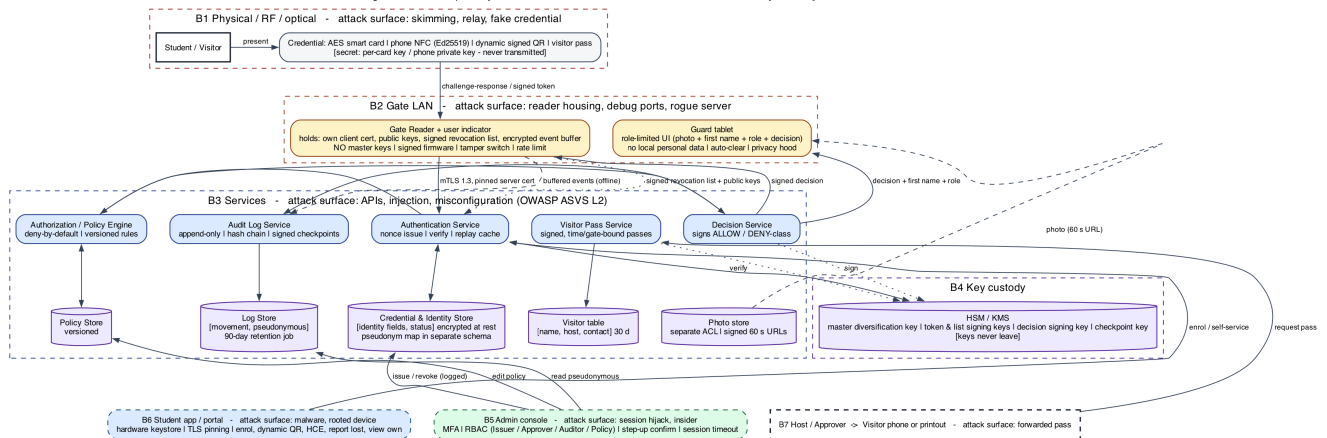


Figure J-13. System architecture